

BRIEFINGS

black hat

Vulnerabilities Assembled! The Vulnerability Factory Inside the Windows Kernel

Angelboy



Who am I

- Angelboy (@scwuaptx)
- Senior security researcher of DEVCORE
- MSRC 2024/2025/2026 MVR Top 100
- Speaker at
 - CODE BLUE, HITCON, Offensive Con, HEXACON
- Retired CTF Player – HITCON CTF Team
- Master of Pwn of Pwn2Own Toronto 2022



Agenda

- **Brief overview of AFD**
- **Architecture & Attack Surface**
- **Assembling Attack Surface**
- **Assembling Vulnerabilities**
- **Conclusion and Future Work**

Tech Editorials

#CVE #Vulnerability #Windows #Kernel #Advisory

Streaming vulnerabilities from Windows Kernel - Proxying to Kernel - Part I

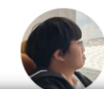


Angelboy 2024-08-23

Tech Editorials

#CVE #Vulnerability #Windows #Kernel #Advisory

Streaming vulnerabilities from Windows Kernel - Proxying to Kernel - Part II



Angelboy 2024-10-05

Tech Editorials

#CVE #Vulnerability #Windows #Kernel #Advisory

Frame by Frame, Kernel Streaming Keeps Giving Vulnerabilities



Angelboy 2025-05-17



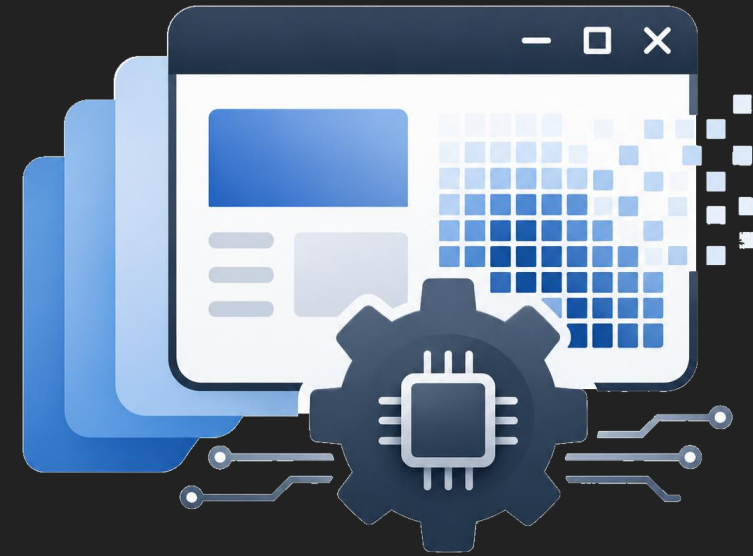
GUEST



NT SYSTEM

In-the-wild bugs are a natural starting point

In-the-Wild Windows Kernel Vulnerabilities



Win32k

CVE-2021-1732
CVE-2021-40449
CVE-2022-21882
CVE-2023-29336
CVE-2025-24983
...



Common Log File System

CVE-2023-28252
CVE-2024-49138
CVE-2025-29824
CVE-2025-32701
CVE-2025-32706
...



Cloud Files Filter

CVE-2023-36036
CVE-2025-62221
...

In-the-Wild Windows Kernel Vulnerabilities



Win32k

- CVE-2021-1732
- CVE-2021-40449
- CVE-2022-21882
- CVE-2023-29336
- CVE-2025-24983
- ...



Ancillary Function Driver for Winsock (AFD)

- CVE-2023-28252
- CVE-2024-38193
- CVE-2024-49138
- CVE-2025-21418
- CVE-2025-29824
- CVE-2025-32701
- CVE-2025-32706
- ...



Cloud Files Filter

- CVE-2023-36036
- CVE-2025-62221
- ...

In-the-Wild Windows Kernel Vulnerabilities



Win32k

- CVE-2021-1732
- CVE-2021-40449
- CVE-2022-21882
- CVE-2023-29336
- CVE-2025-24983
- ...



Ancillary Function Driver for Winsock (AFD)

- CVE-2023-28252
- CVE-2024-38193
- CVE-2024-49138
- CVE-2025-21418
- CVE-2025-29824
- CVE-2025-32709
- CVE-2025-32701
- CVE-2025-32706
- ...



Cloud Files Filter

- CVE-2023-36036
- CVE-2025-62221
- ...

3 ITW bugs in one year

In-the-Wild AFD Vulnerabilities

- The first one is CVE-2024-38193
Exploited by **Lazarus Group**
- Missing validation in **AfdConnect**
led to **Use After Free**
- Patched in **August 2024**



Six months later...

In-the-Wild AFD Vulnerabilities

- CVE-2025-21418
 - The fix for CVE-2024-38193 could be bypassed through **AfdAccept**, leading to the same underlying issue
 - Patched in **February 2025**

Three months later ...

In-the-Wild AFD Vulnerabilities

- CVE-2025-32709
 - The fix for CVE-2025-21418 could be bypassed through **AfdSuperAccept**, leading to the same underlying issue
 - Patched in **May 2025**

Why did the same root cause **keep getting**
bypassed?

Reverse Engineering Windows AFD.sys

Steven Vittitoe
Google

@bool101
bool@google.com

Patch Tuesday → Exploit
Wednesday: Pwning
Windows ancillary function
driver for WinSock (afd.sys)
in 24 hours

Exploiting Windows Kernel Wild Copy With User Fault Handling (CVE-2023-28218)

At Hexacon 2023, we presented our Windows kernel security research, uncovering CVE-2023-28218, a heap overflow in afd.sys. Read our exploit analysis and methodology.

Blackswan Technical Writeup

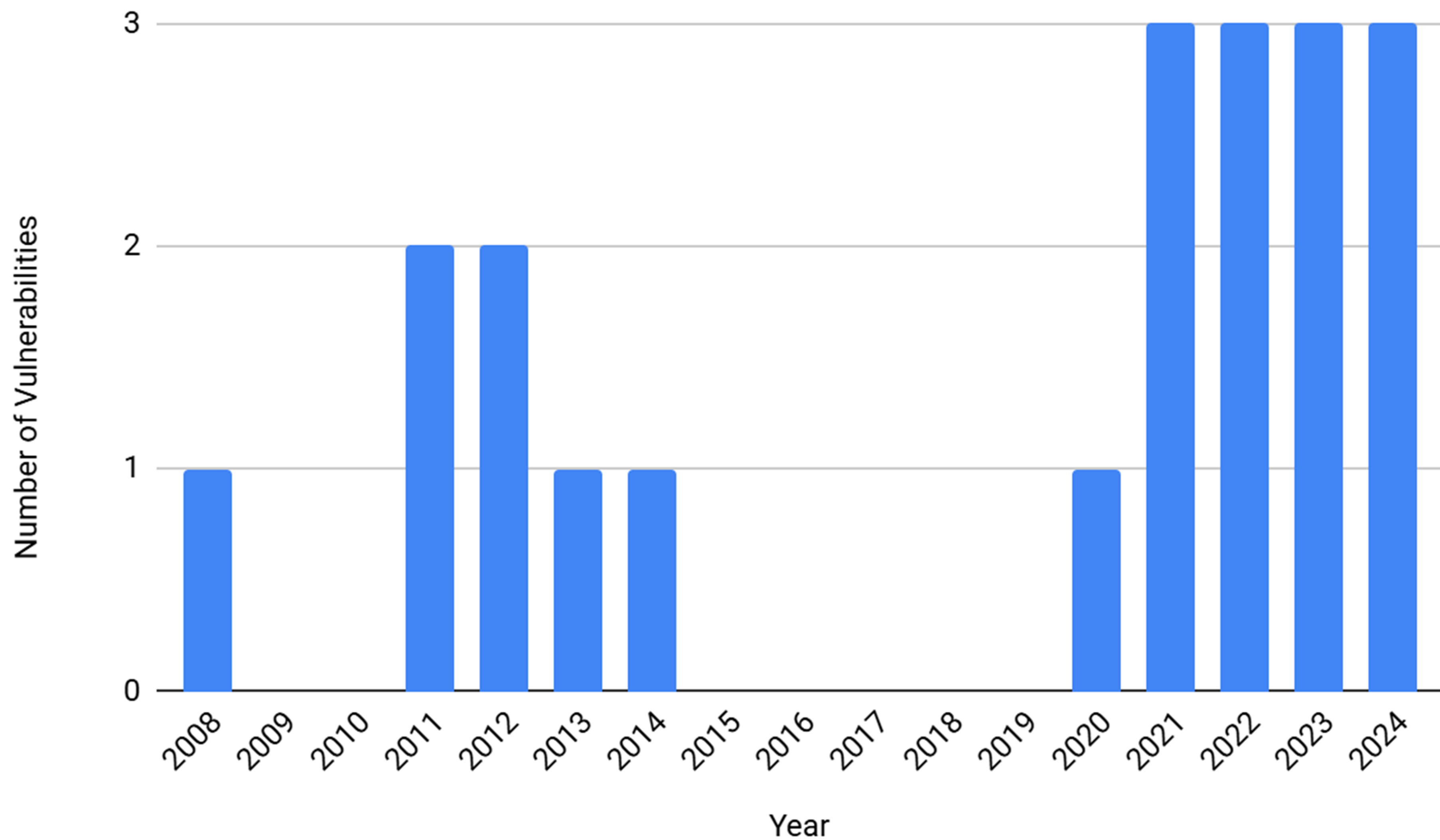
Microsoft 0-day
Vulnerabilities

Erik Egsgard
Principal Security Developer

Published: October 14, 2021



AFD CVE Vulnerability Trend (2008-2024)



After years of patches

CVE-2025-21418



CVE-2024-38193

CVE-2025-32709

AFD should have become **more secure...** right?

Looking at AFD alone
did **not** reveal much

But when I looked **beyond** AFD itself...

CVE-2025-59242

CVE-2026-25176

CVE-2025-47996

CVE-2025-49658

CVE-2025-55679

CVE-2025-49659

CVE-2025-55339

CVE-2025-54093

CVE-2026-20860

CVE-2025-55230

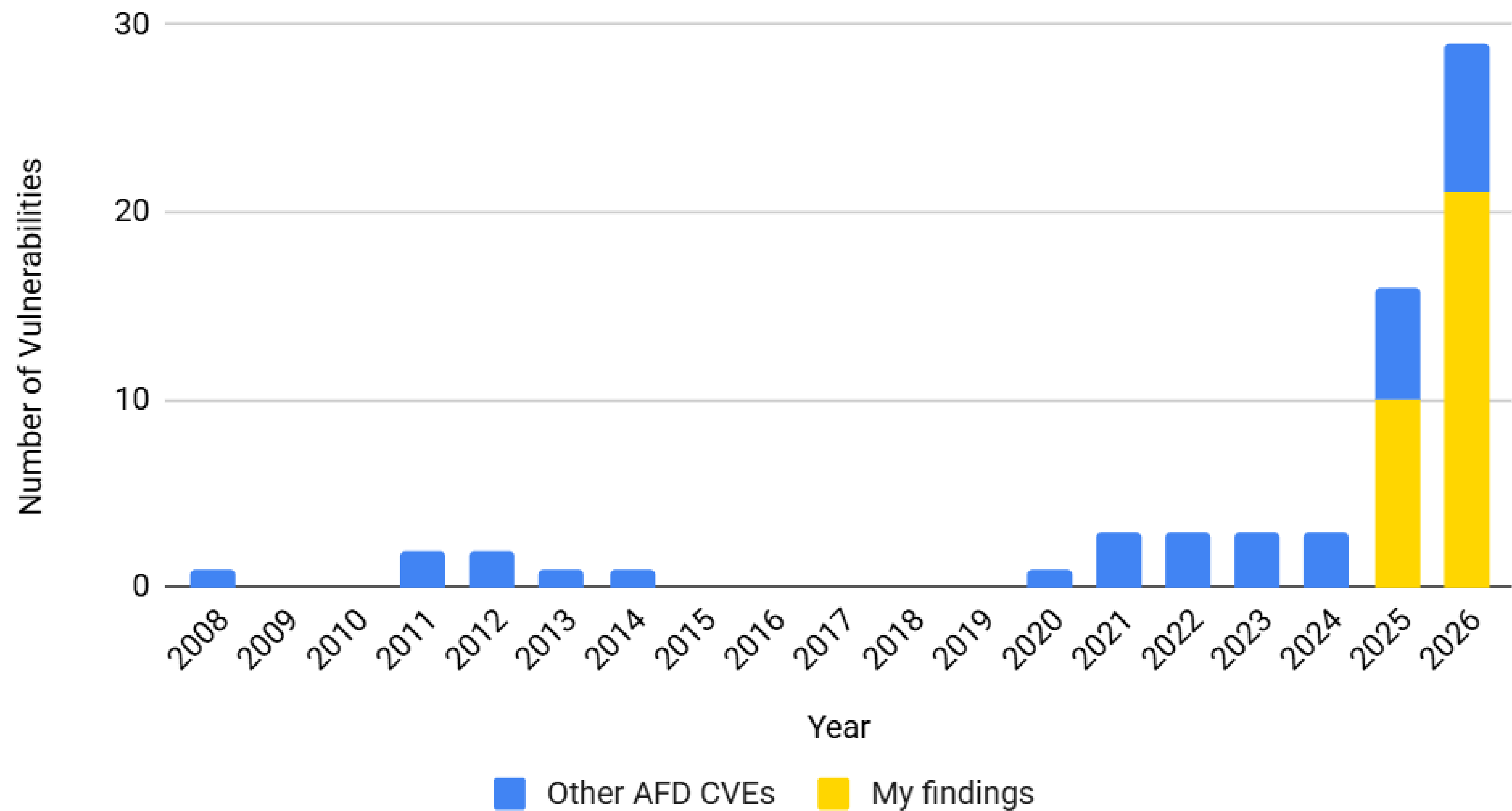
CVE-2025-58714

CVE-2026-34344

CVE-2026-21238



AFD CVE Vulnerability Trend





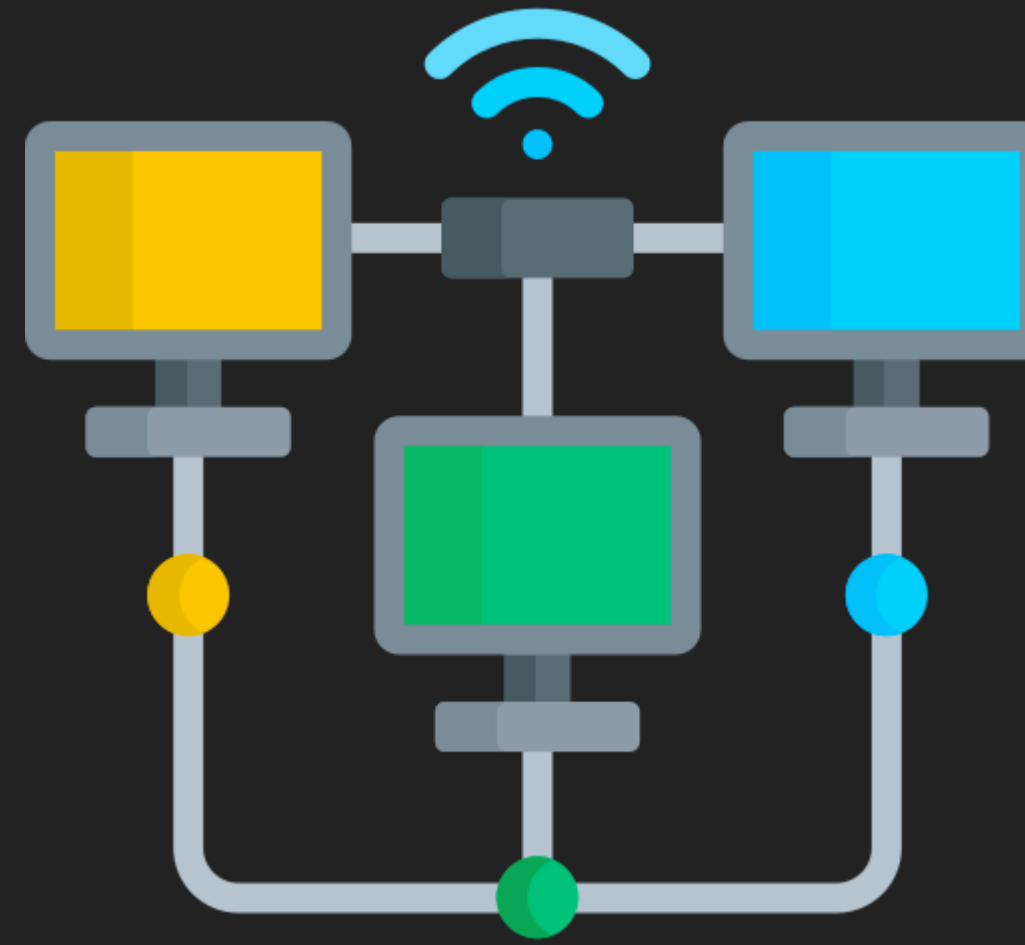
Brief overview of AFD

What is AFD ?

- Ancillary Function Driver for WinSock
 - afd.sys
- Winsock API Kernel Entry Point
- Handles **low-level network operations**
 - Socket management
 - Connection setup
 - Data transfer

What is AFD ?

- Winsock API
 - Socket
 - Bind
 - Connect
 - ...



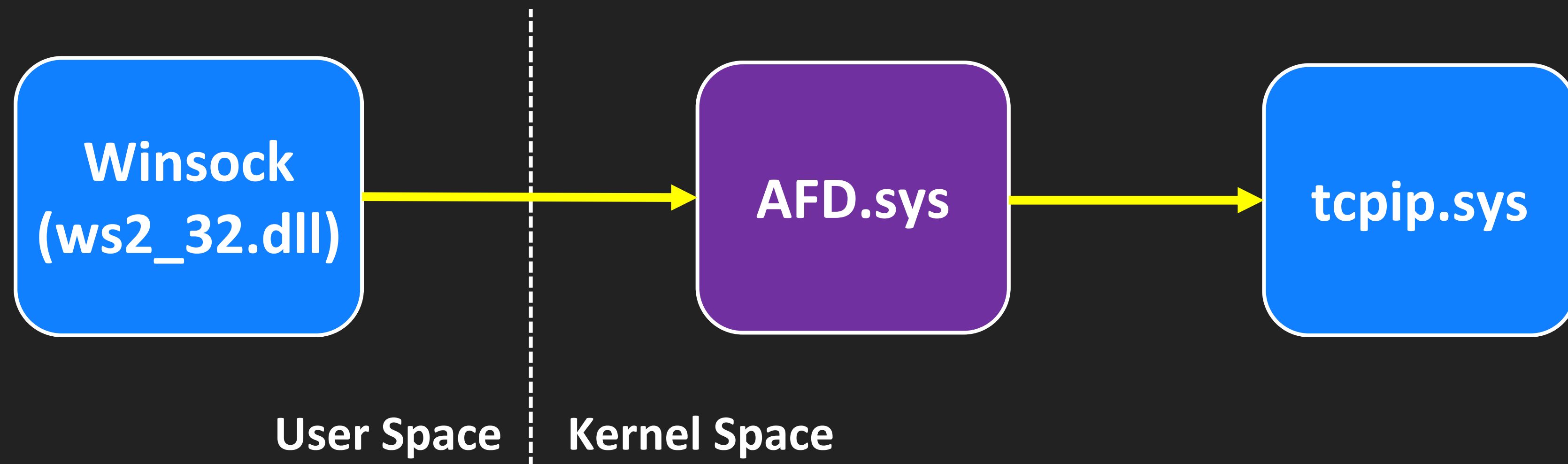
What is AFD ?

- Winsock API
 - AF_INET
 - AF_UNIX
 - AF_HYPERV
 - ...

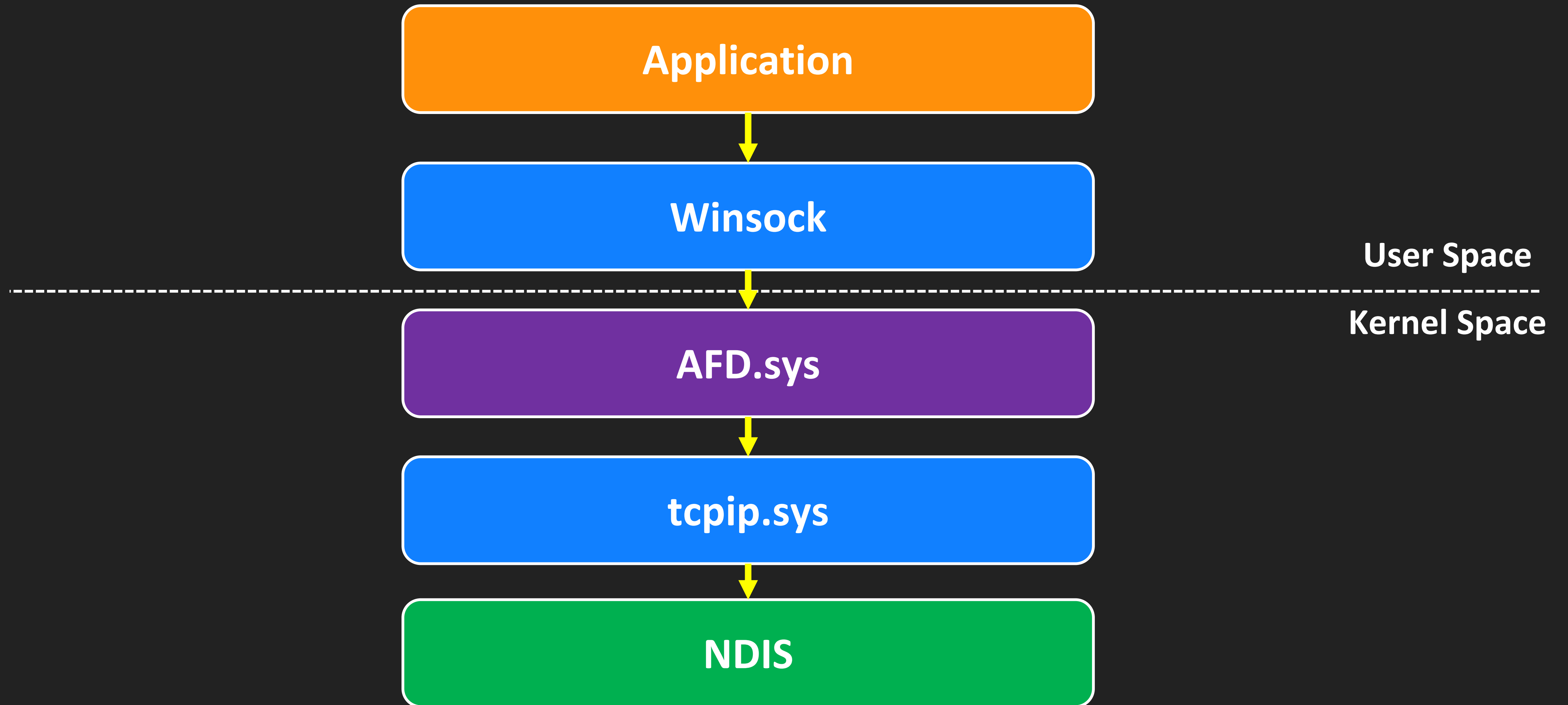
```
socket(AF_INET, SOCK_STREAM, IPPROTO_TCP);
```

What is AFD ?

- For **TCP** and **UDP**, it translates socket operations, such as **send** and **recv**, into kernel I/O requests handled by **tcpip.sys**
- For **Hyper-V** socket, it translates socket operations into kernel I/O requests handled by **hvsocket.sys**

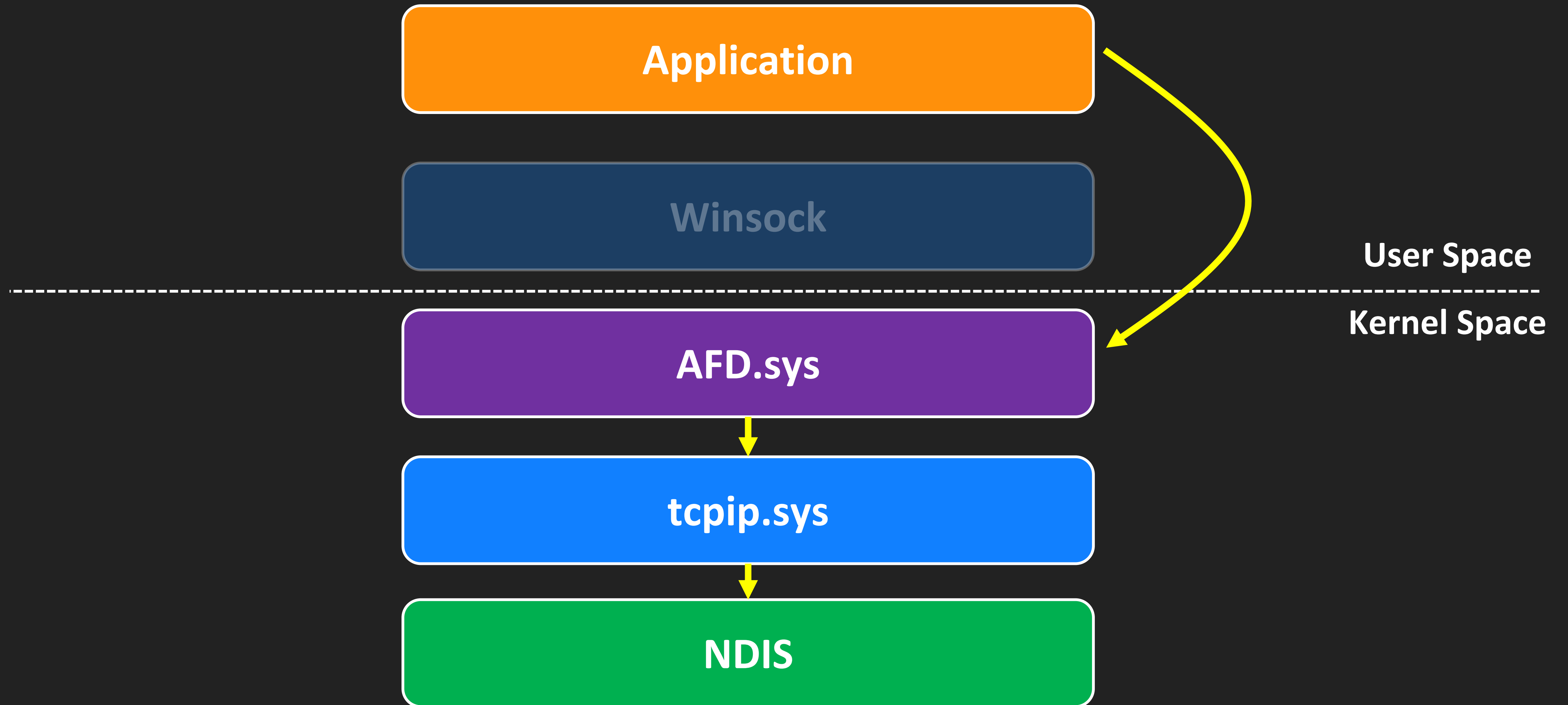


What is AFD ?



**We can also access AFD
directly through the NT API**

What is AFD ?



Create Socket with NtCreateFile

```
UNICODE_STRING DevName;  
RtlInitUnicodeString(&DevName, L"\\Device\\Afd\\Endpoint");  
OBJECT_ATTRIBUTES Object;  
Object = { 0 };  
Object.ObjectName = &DevName;  
Object.Length = 48;  
Object.Attributes = 0x40;  
  
IO_STATUS_BLOCK IoStatusBlock;  
NtCreateFile(Handle, MAXIMUM_ALLOWED, &Object, &IoStatusBlock,  
    NULL, 0, FILE_SHARE_READ | FILE_SHARE_WRITE, 1, 0, &bExtendedAttributes, sizeof(bExtendedAttributes));
```

Create Socket with NtCreateFile

```
UNICODE_STRING DevName;  
RtlInitUnicodeString(&DevName, L"\\Device\\Afd\\Endpoint");  
OBJECT_ATTRIBUTES Object;  
Object = { 0 };  
Object.ObjectName = &DevName;  
Object.Length = 48;  
Object.Attributes = 0x40;  
  
IO_STATUS_BLOCK IoStatusBlock;  
NtCreateFile(Handle, MAXIMUM_ALLOWED, &Object, &IoStatusBlock,  
    NULL, 0, FILE_SHARE_READ | FILE_SHARE_WRITE, 1, 0, &bExtendedAttributes, sizeof(bExtendedAttributes));
```

Extended Attributes

Create Socket with NtCreateFile

```
BYTE bExtendedAttributes[] =
{
    0x00, 0x00, 0x00, 0x00,
    0x00,
    0x0F, // EaNameLength
    0x34-0x16, 0x00, // EaValueLength
    // AfdOpenPacketXX
    0x41, 0x66, 0x64, 0x4F, 0x70, 0x65, 0x6E, 0x50, 0x61, 0x63, 0x6B, 0x65, 0x74, 0x58, 0x58, 0x00, // 0xf bytes of name + ending zero

    0x00, 0x10, 0x01, 0x00, // EndpointFlags
    0x00, 0x00, 0x00, 0x00, // GroupID = 0
    0x02, 0x00, 0x00, 0x00, //AddressFamily = AF_INET
    0x01, 0x00, 0x00, 0x00, //SocketType = SOCK_STREAM
    0x06, 0x00, 0x00, 0x00, //Protocol = IPPROTO_TCP
    0x00, 0x00, 0x00, 0x00, // SizeOfTransportName

    0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00
};
```

socket(AF_INET, SOCK_STREAM, IPPROTO_TCP);

Create Socket with NtCreateFile

```
BYTE bExtendedAttributes[] =
{
    0x00, 0x00, 0x00, 0x00,
    0x00,
    0x0F, // EaNameLength
    0x34, 0x00, // EaValueLength
    // AfdOpenPacketXX
    0x41, 0x66, 0x64, 0x4F, 0x70, 0x65, 0x6E, 0x50, 0x61, 0x63, 0x6B, 0x65, 0x74, 0x58, 0x58, 0x00,

    0x00, 0x10, 0x01, 0x00, // EndpointFlags
    0x00, 0x00, 0x00, 0x00, // GroupID = 0
    0x02, 0x00, 0x00, 0x00, //AddressFamily = AF_INET
    0x01, 0x00, 0x00, 0x00, //SocketType = SOCK_STREAM
    0x06, 0x00, 0x00, 0x00, //Protocol = IPPROTO_TCP
    0x16, 0x00, 0x00, 0x00, // SizeOfTransportName
    // \Device\Tcp
    0x5C, 0x00, 0x44, 0x00, 0x65, 0x00, 0x76, 0x00, 0x69, 0x00, 0x63, 0x00, 0x65, 0x00, 0x5C, 0x00
};
```

\Device\Tcp

I/O Control

- Send IOCTLs to the socket to perform various operations
 - AFD_BIND
 - AFD_CONNECT
 - AFD_SEND
 - AFD_ACCEPT
 - ...



AFD Architecture

Transport Modes

- Sockets can be divided into **three transport** modes
 - TLI (Transport Layer Interface)
 - Hybrid
 - TDI (Transport Driver Interface)

Transport Modes

- TLI (Transport Layer Interface)
 - Used when **only** the **address family**, **socket type**, and **protocol** are specified

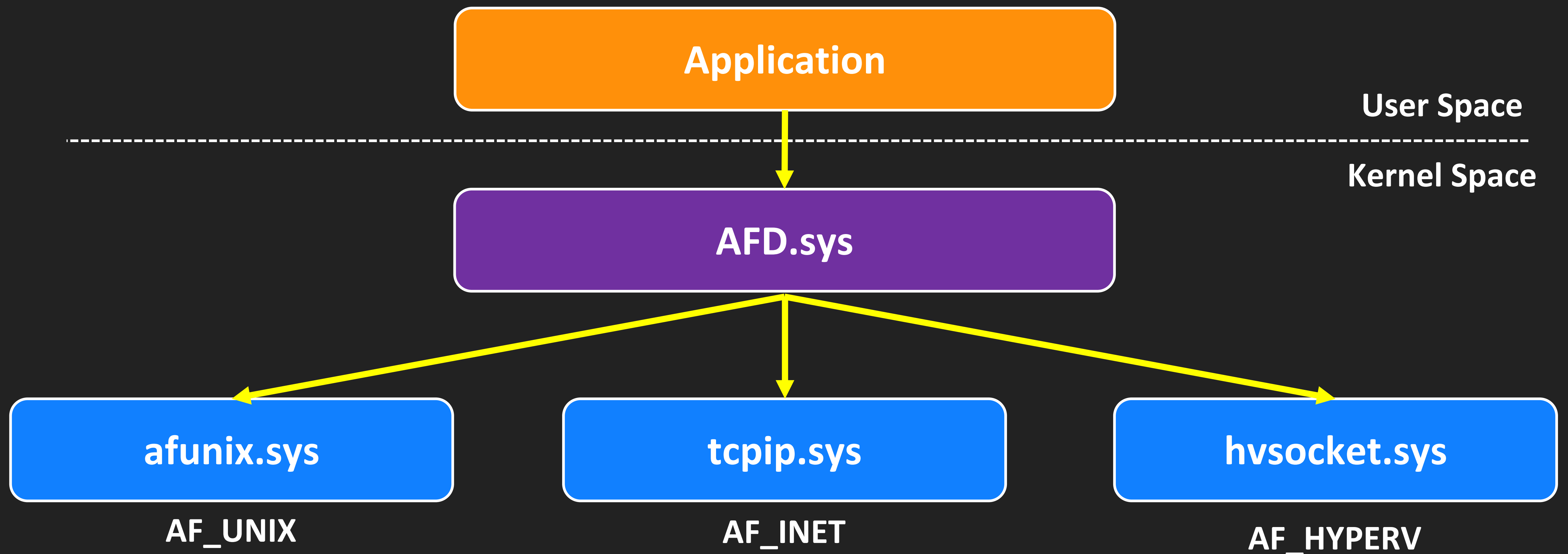
```
BYTE bExtendedAttributes[] =
{
    0x00, 0x00, 0x00, 0x00,
    0x00,
    0x0F, // EaNameLength
    0x34-0x16, 0x00, // EaValueLength
    // AfdOpenPacketXX
    0x41, 0x66, 0x64, 0x4F, 0x70, 0x65, 0x6E, 0x50, 0x61, 0x63, 0x6B, 0x65, 0x74, 0x58, 0x58, 0x00, // 0xf bytes of name + ending zero

    0x00, 0x10, 0x01, 0x00, // EndpointFlags
    0x00, 0x00, 0x00, 0x00, // GroupID = 0
    0x02, 0x00, 0x00, 0x00, //AddressFamily = AF_INET
    0x01, 0x00, 0x00, 0x00, //SocketType = SOCK_STREAM
    0x06, 0x00, 0x00, 0x00, //Protocol = IPPROTO_TCP
    0x00, 0x00, 0x00, 0x00, // SizeOfTransportName

    0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00
};
```


AFD Architecture

- TLI

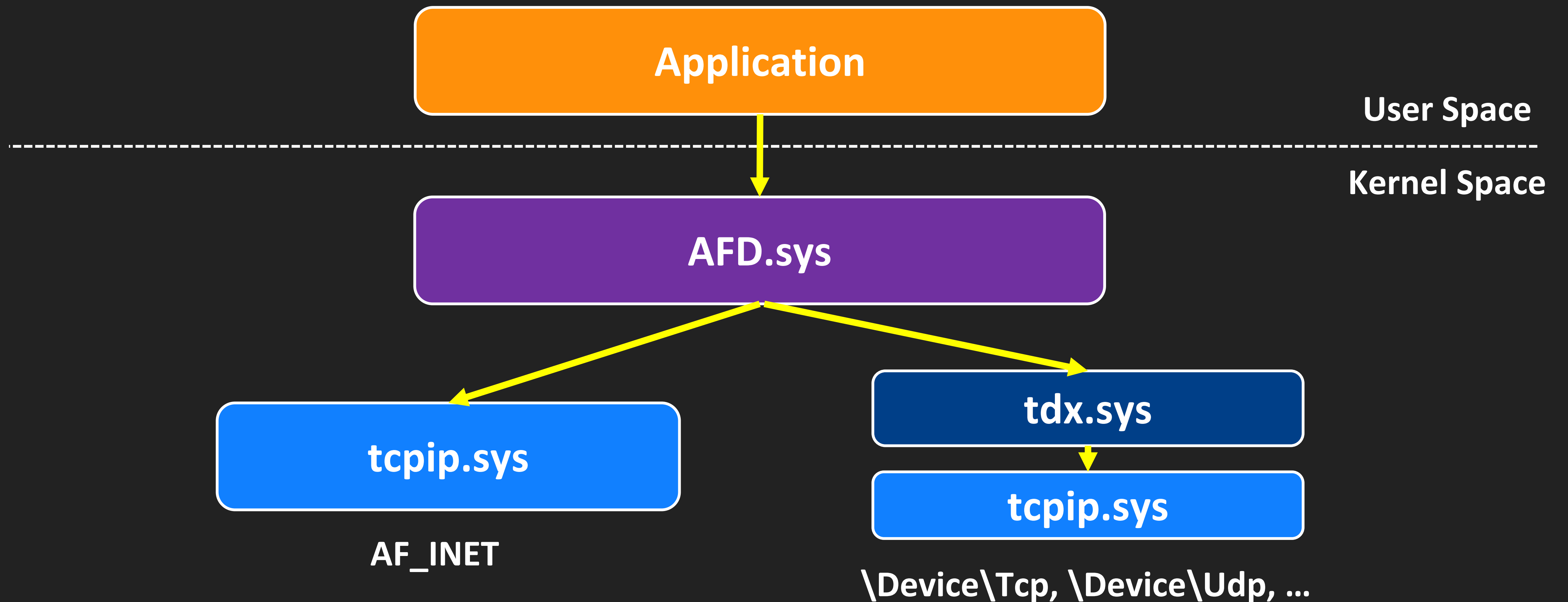


Transport Modes

- Hybrid
 - Specify one of the following **transport paths** with a **compatible** address family, socket type, and protocol
 - \Device\Tcp{6}
 - \Device\Udp{6}
 - \Device\RawIp{6}

AFD Architecture

- Hybrid

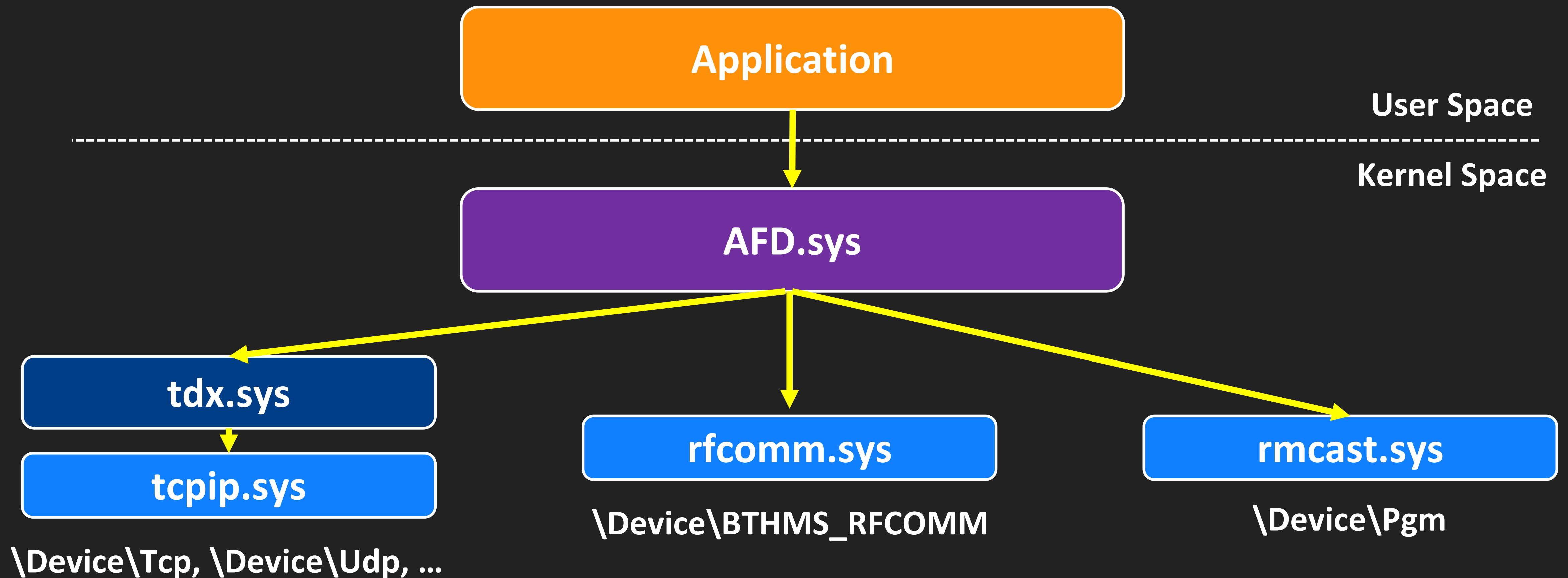


Transport Modes

- TDI (Transport Driver Interface)
 - Specify a **different transport path** in the extended attributes
 - \Device\BTHMS_RFCOMM
 - \Device\Pgm
 - ...

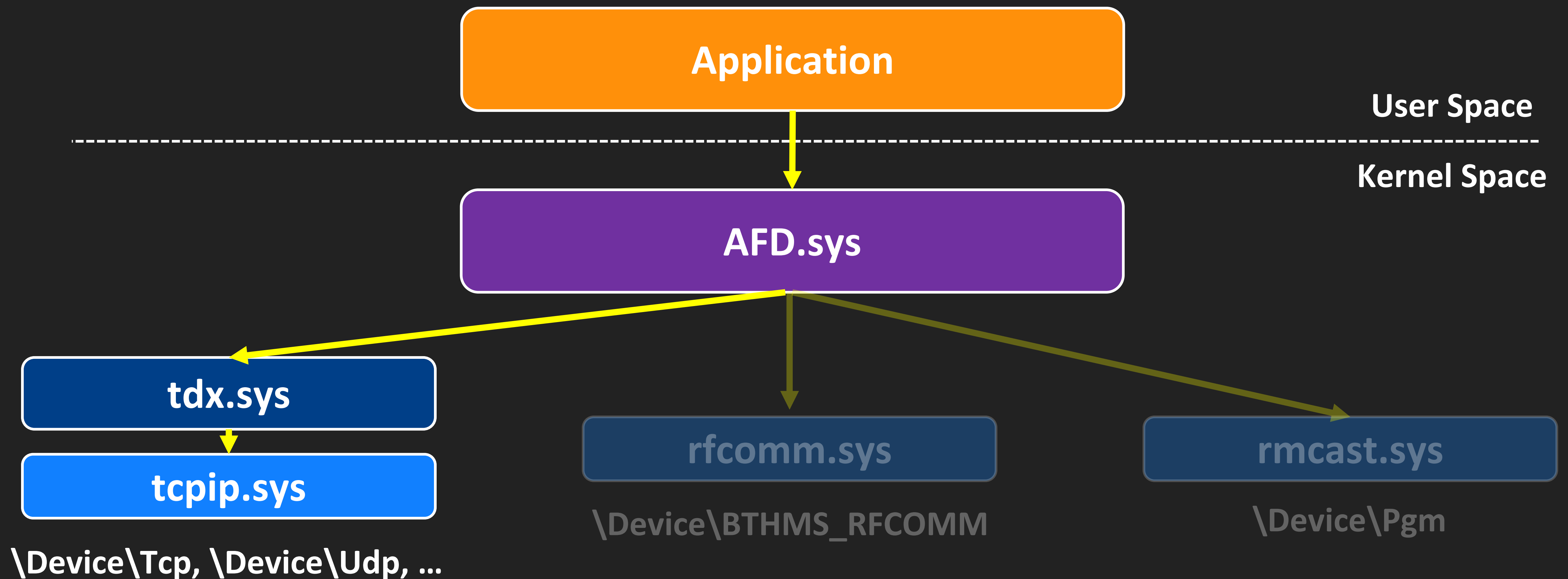
AFD Architecture

- TDI



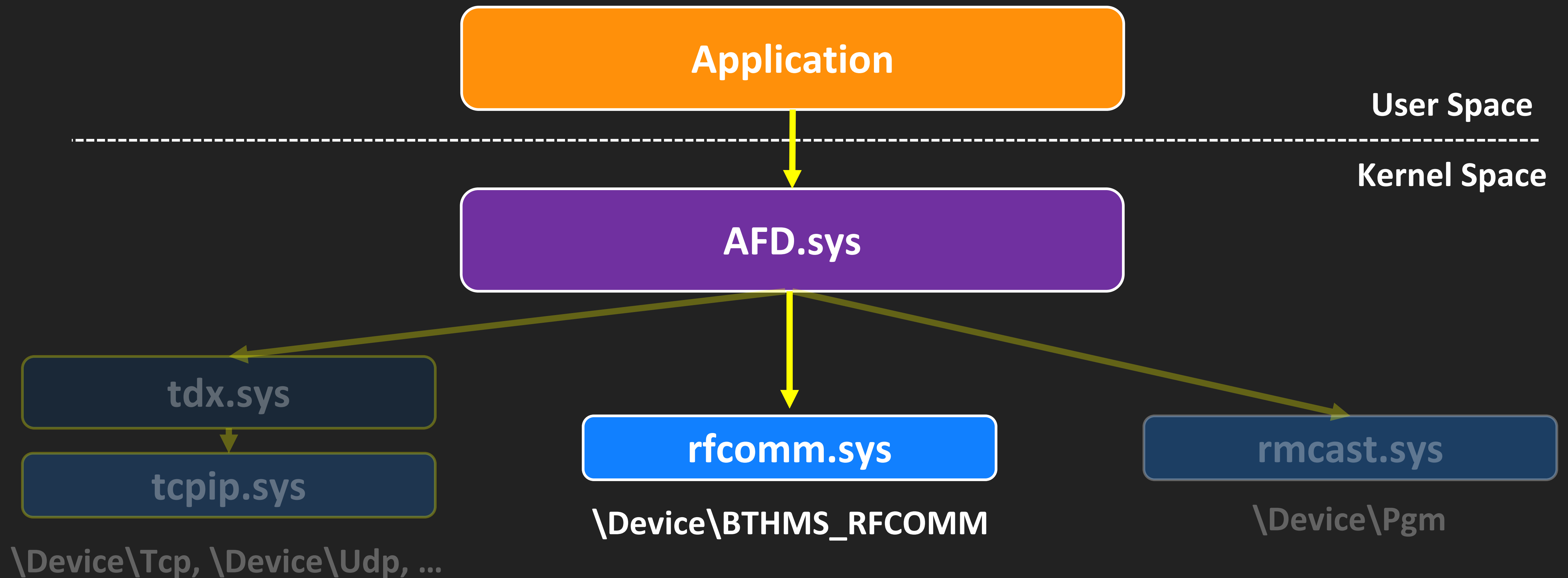
AFD Architecture

- TDI



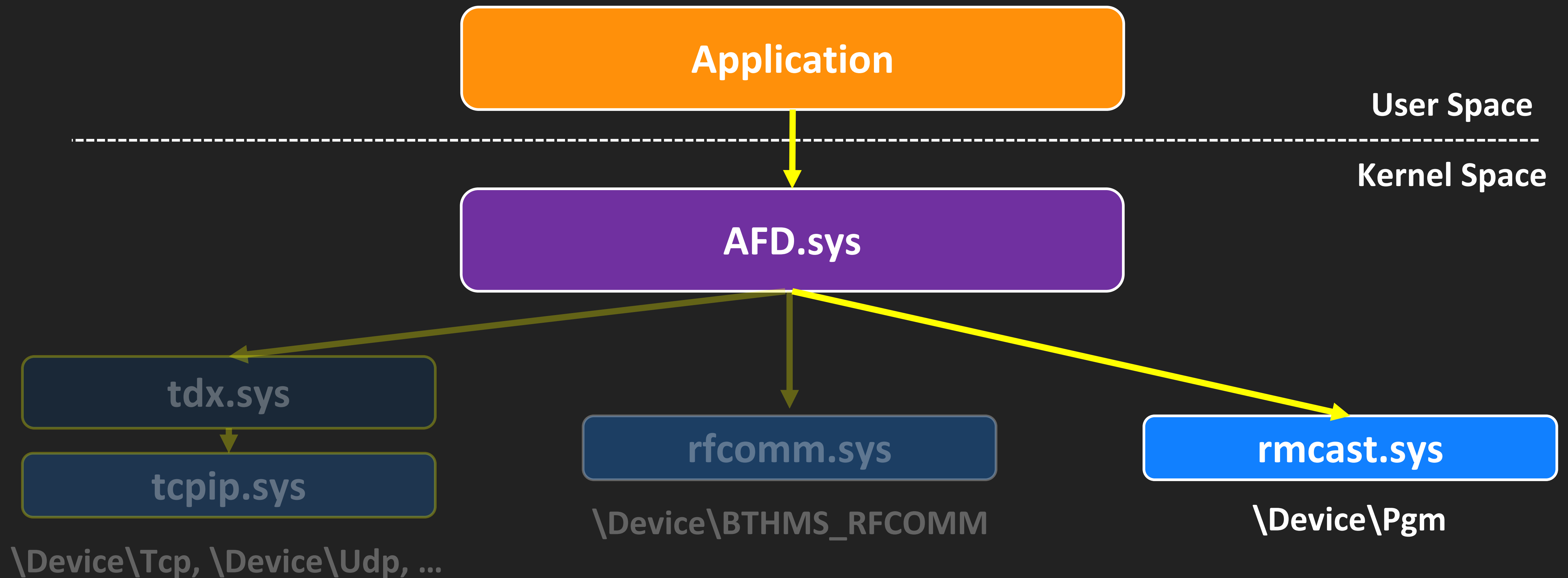
AFD Architecture

- TDI



AFD Architecture

- TDI

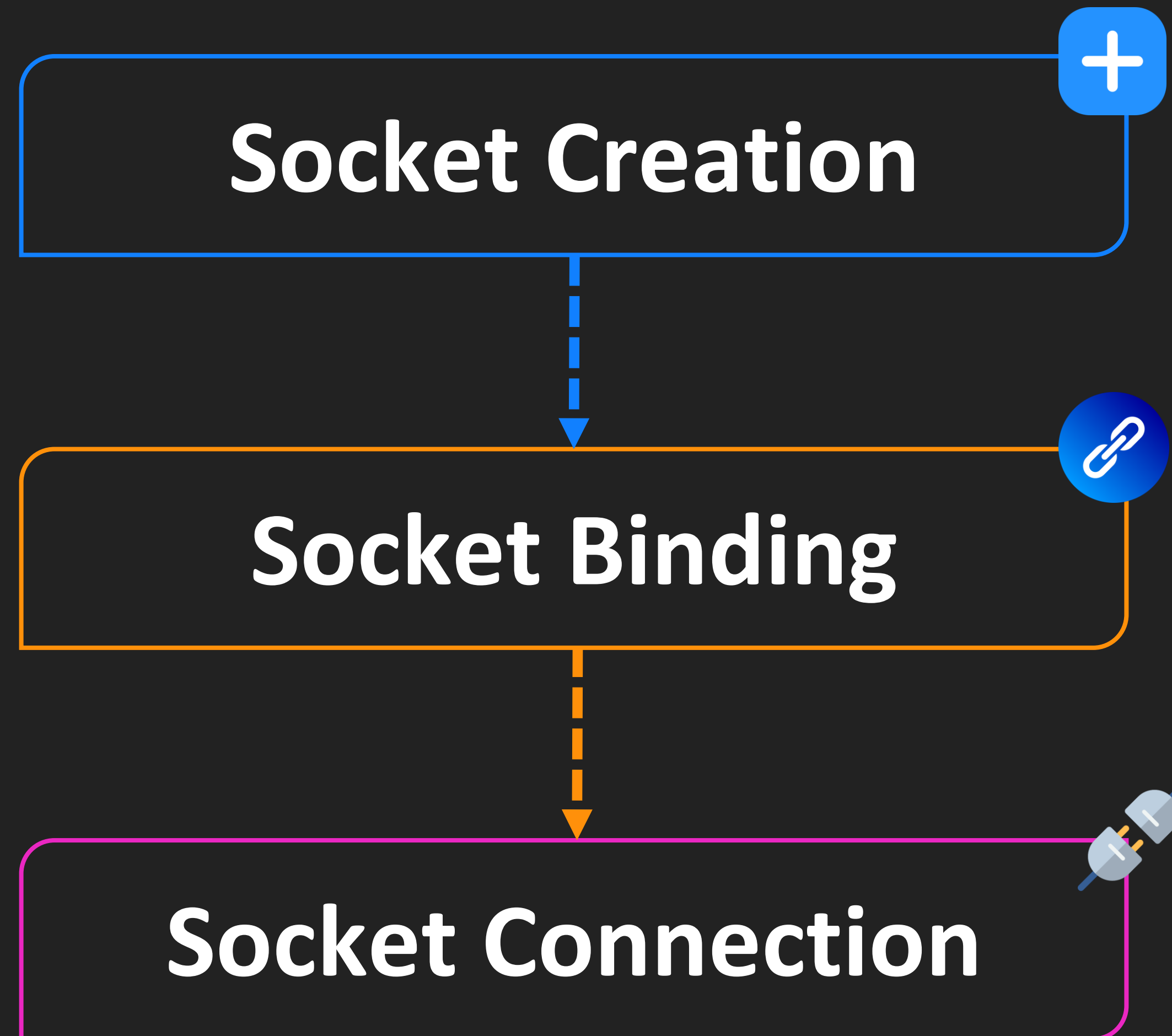


Today, I will focus on **TDI**

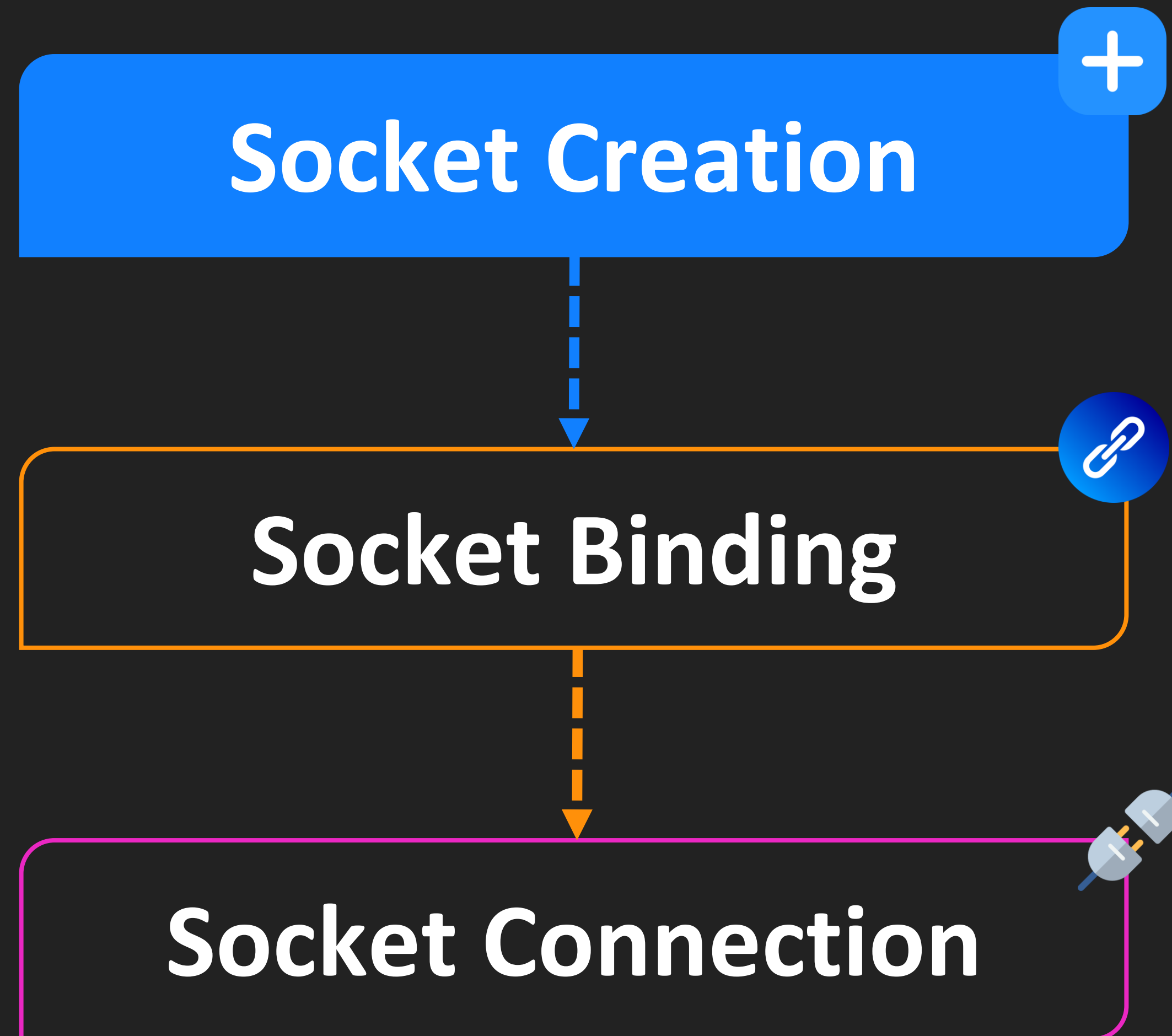


Brief Overview of Sockets

Socket Workflow



Socket Workflow

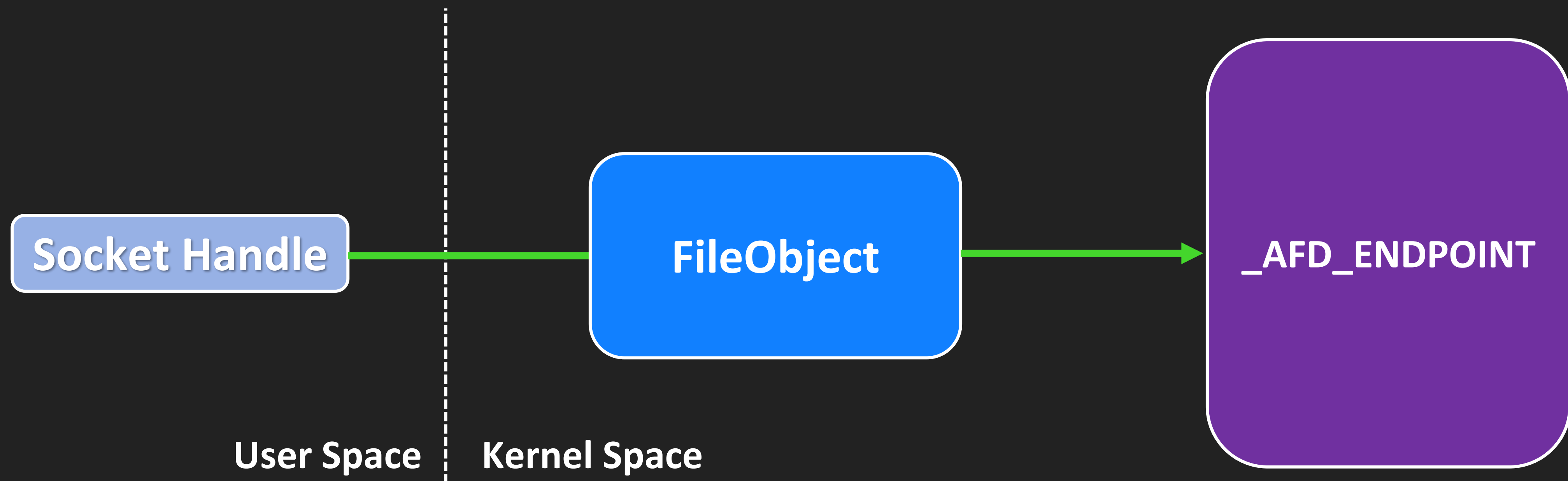


Socket Creation

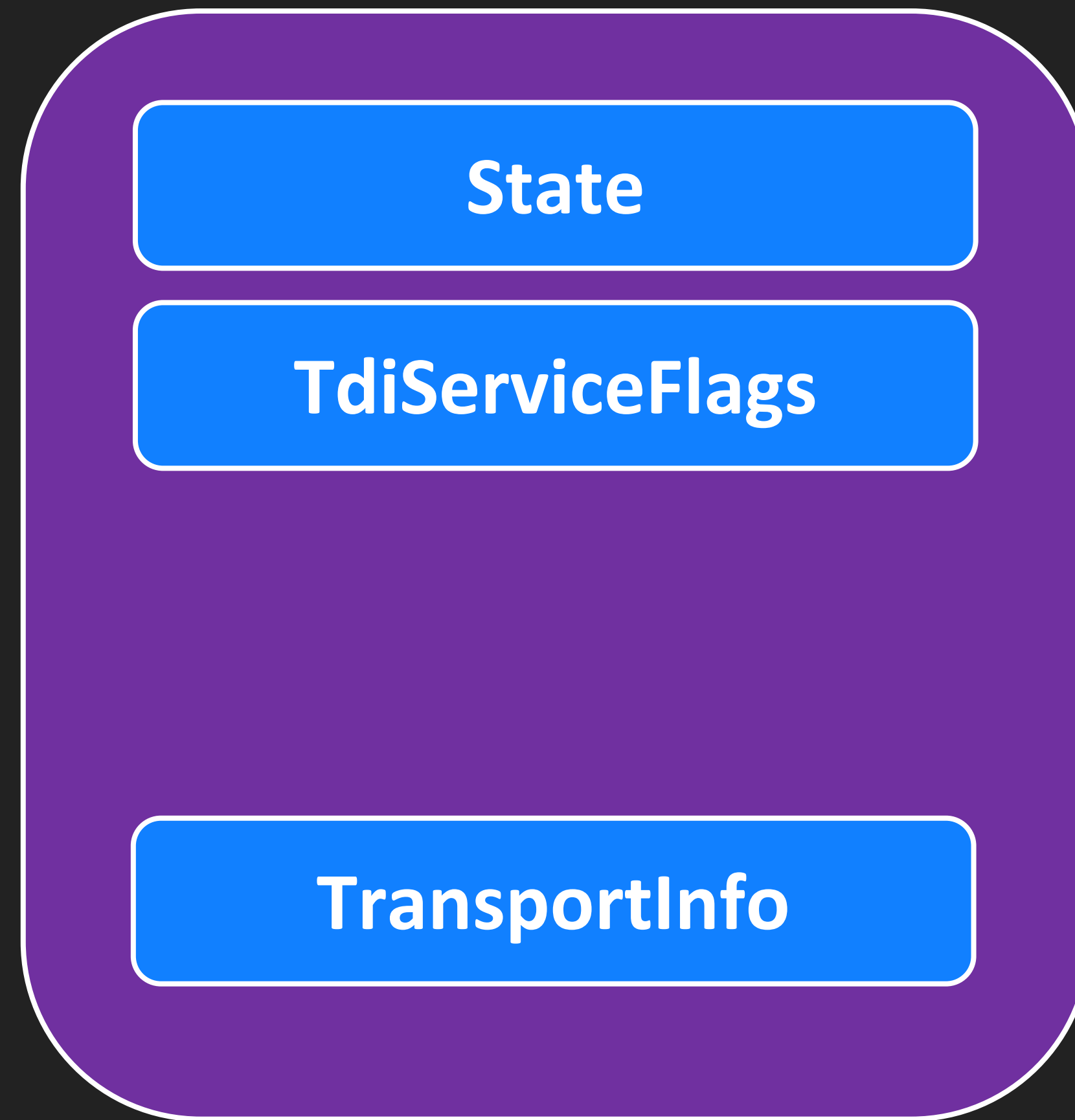
- Like file, sockets also have a `_FILE_OBJECT` in the kernel
- `Endpoint` structure stored in `FileObject->FsContext`

Socket Creation

- Like file, sockets also have a **_FILE_OBJECT** in the kernel
- **Endpoint** structure stored in **FileObject->FsContext**

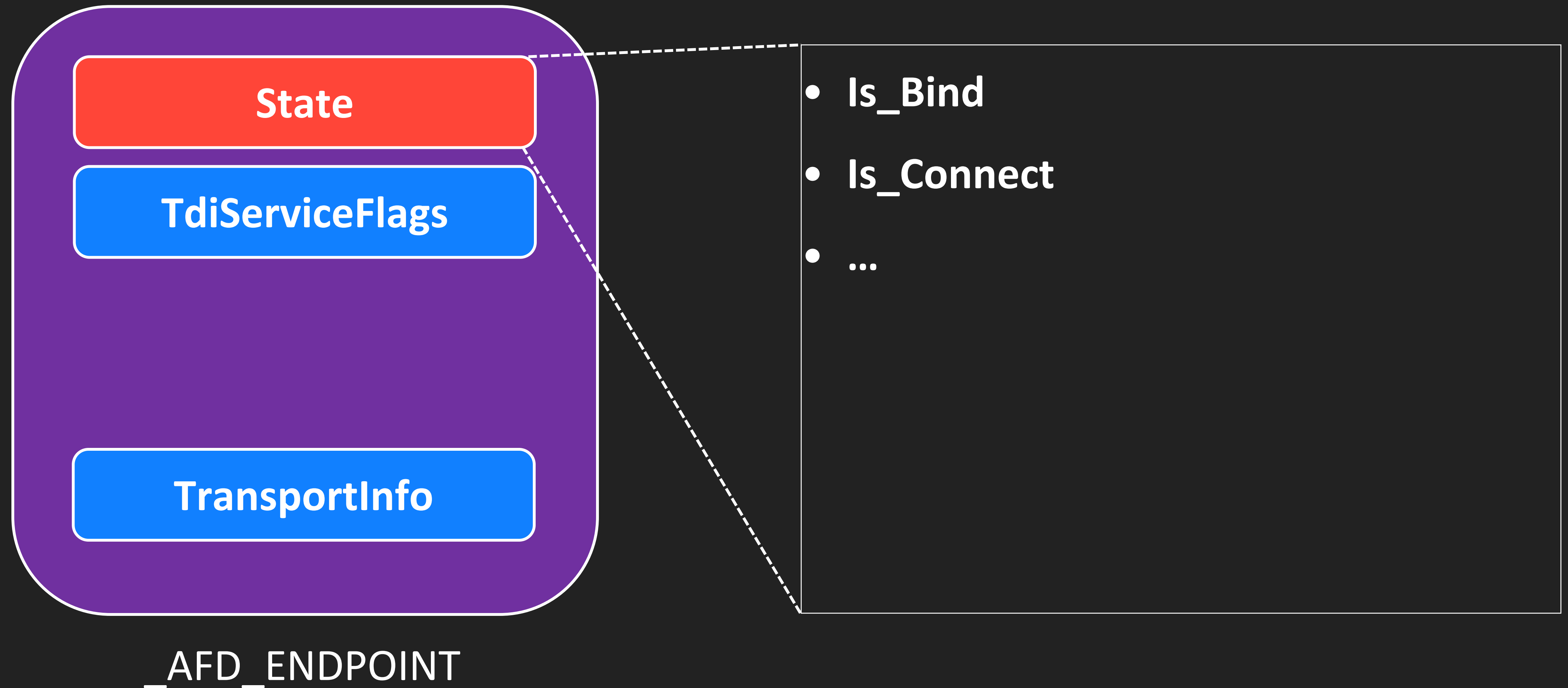


Socket Creation

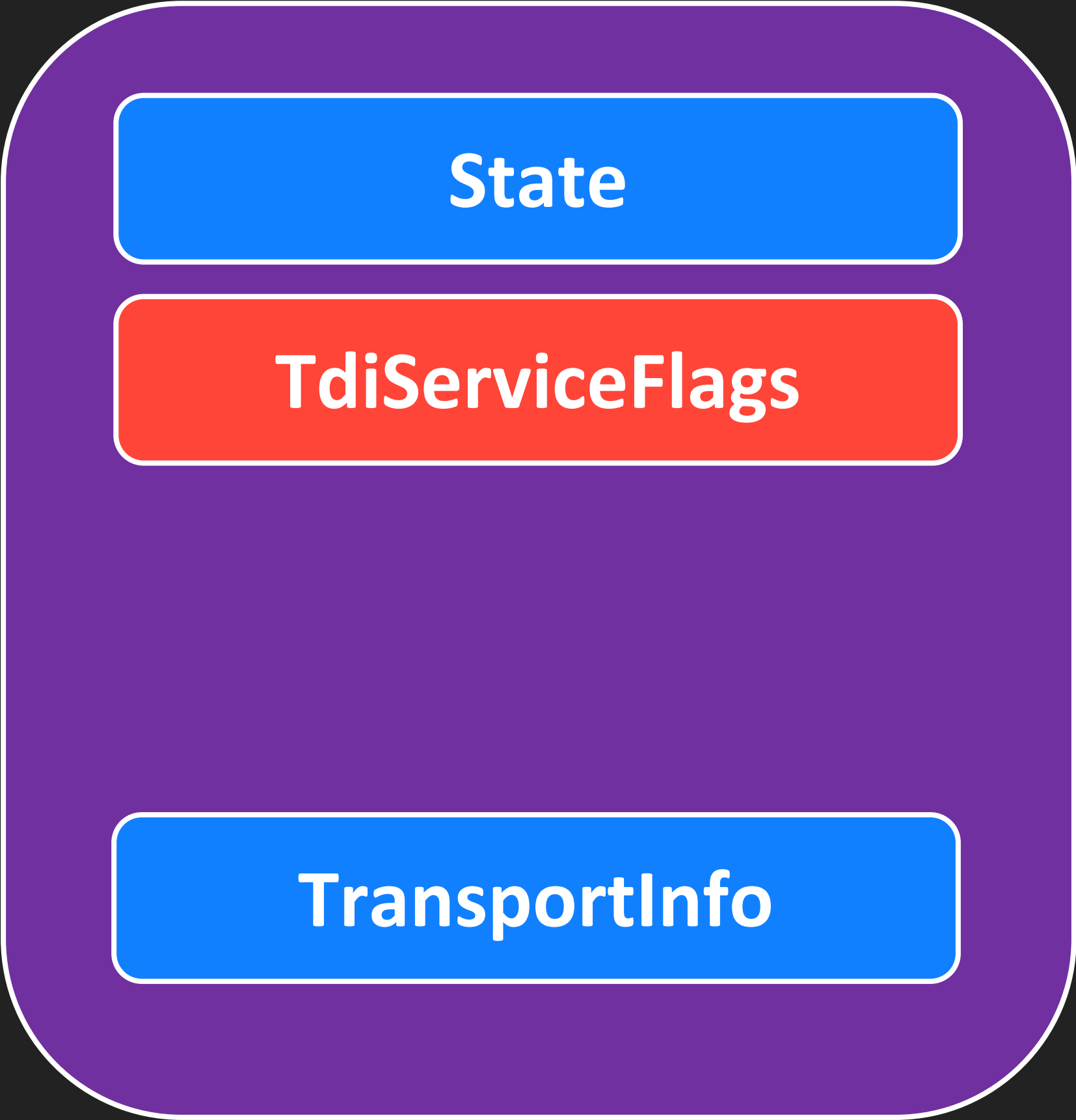


`_AFD_ENDPOINT`

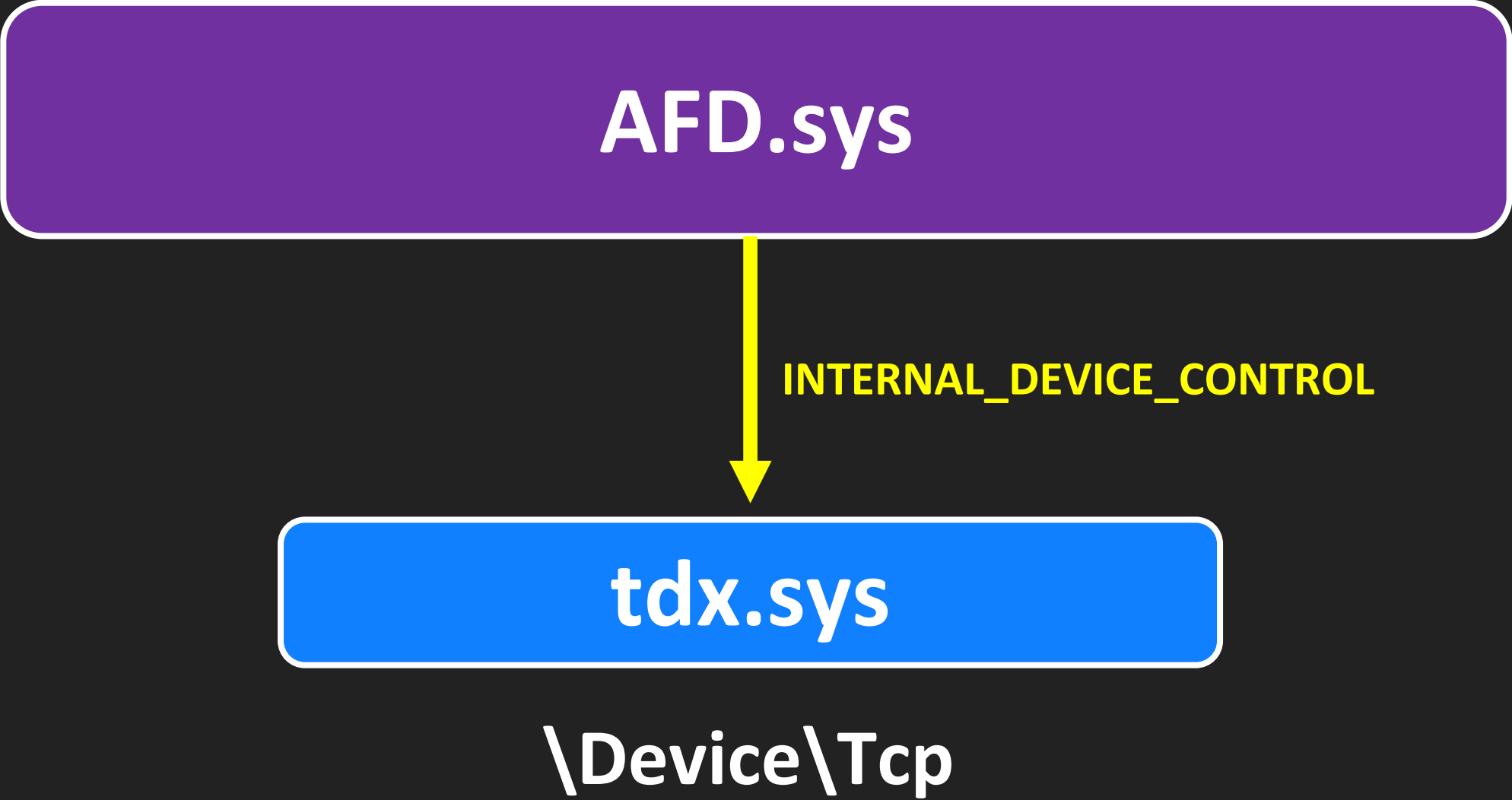
Socket Creation



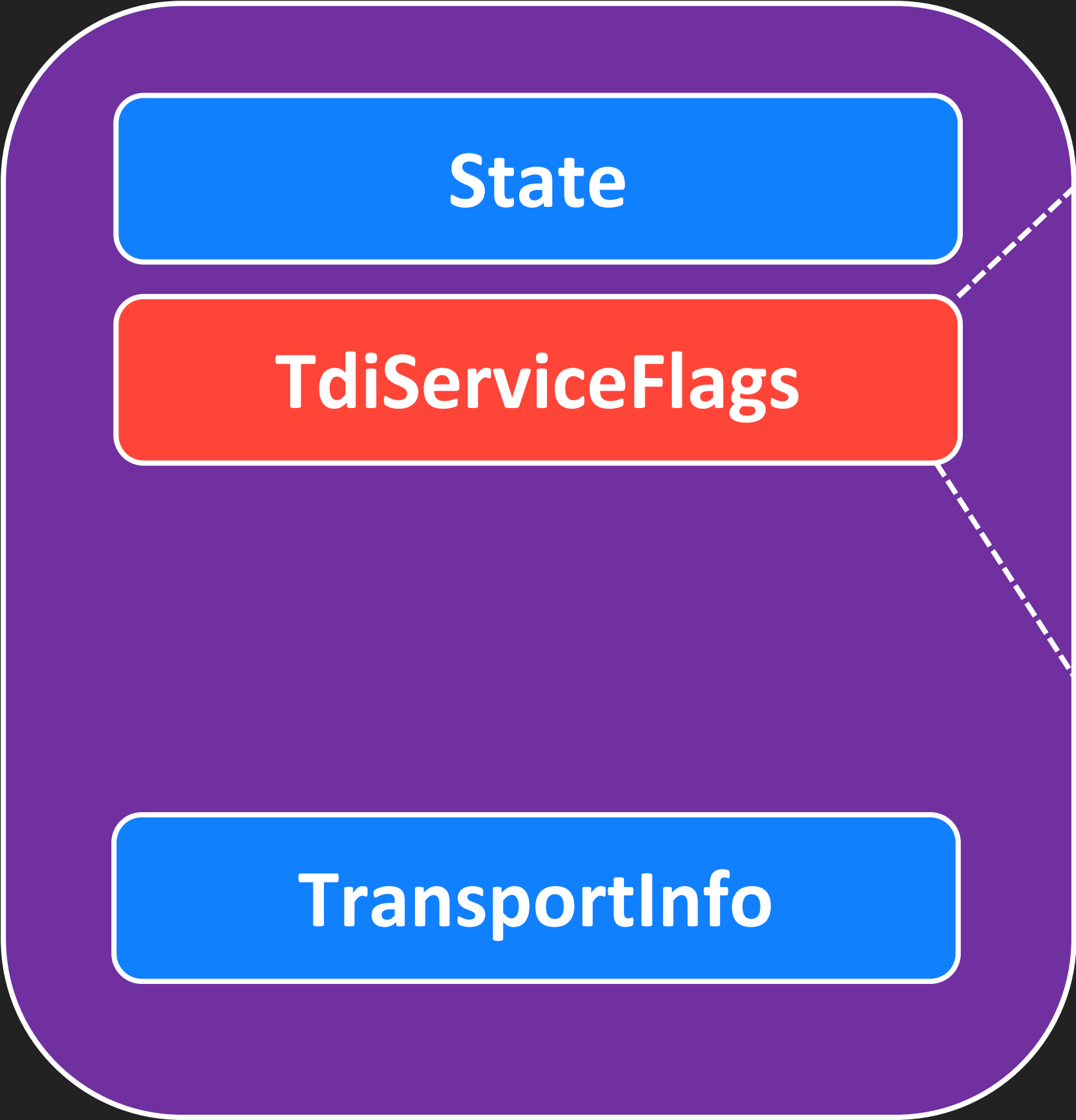
Socket Creation



`_AFD_ENDPOINT`



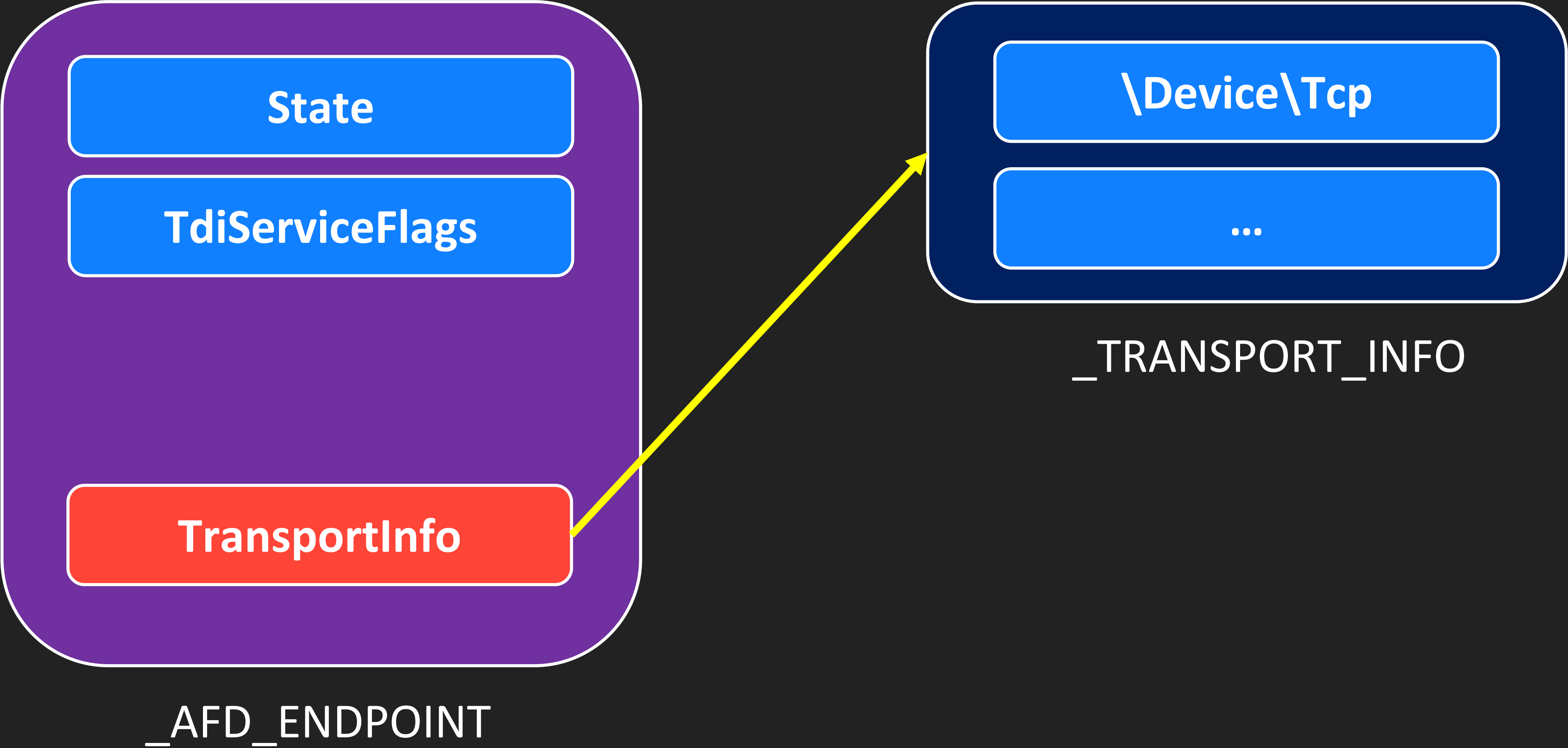
Socket Creation



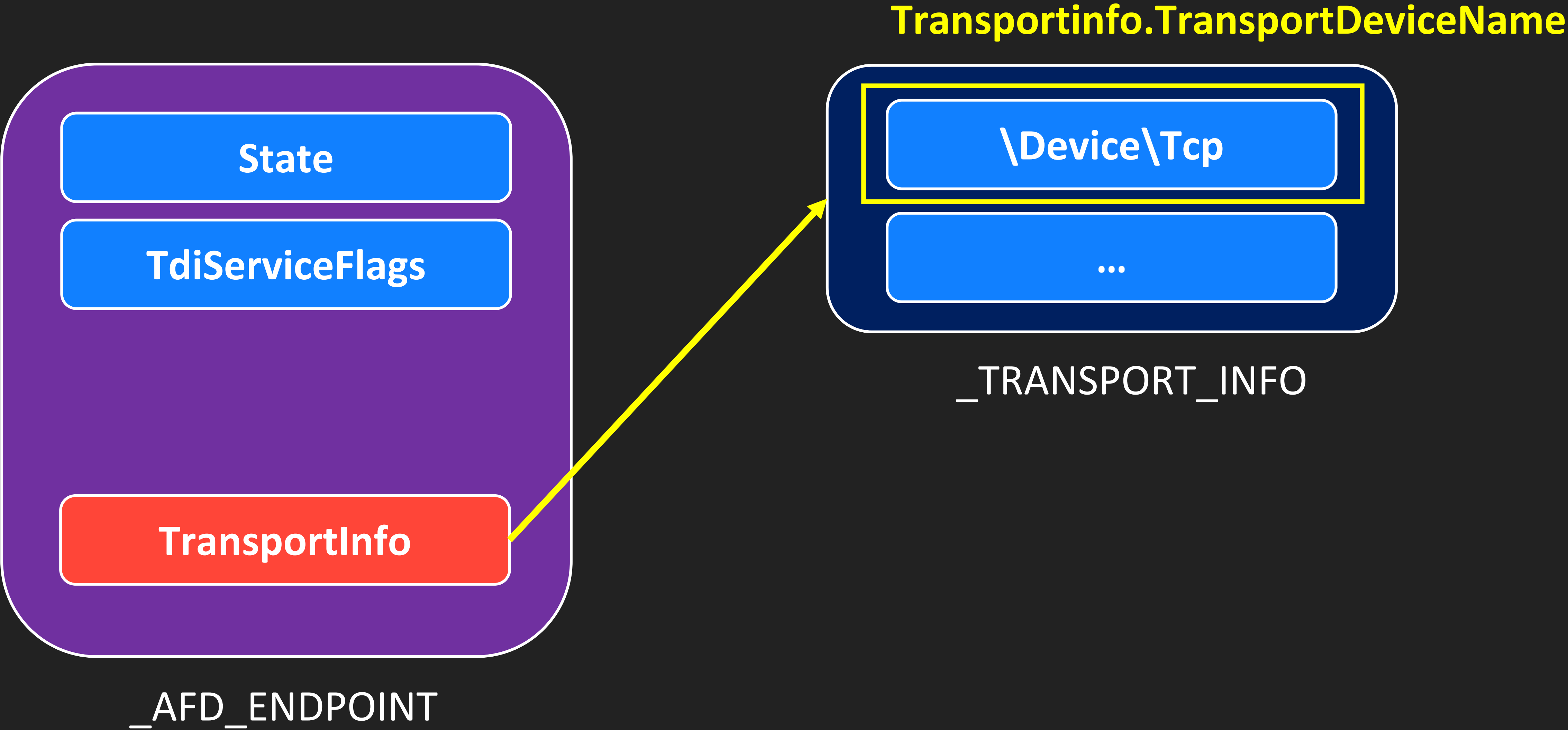
`_AFD_ENDPOINT`

```
#define TDI_SERVICE_CONNECTION_MODE 0x00000001
#define TDI_SERVICE_ORDERLY_RELEASE 0x00000002
#define TDI_SERVICE_CONNECTIONLESS_MODE 0x00000004
#define TDI_SERVICE_ERROR_FREE_DELIVERY 0x00000008
#define TDI_SERVICE_SECURITY_LEVEL 0x00000010
#define TDI_SERVICE_BROADCAST_SUPPORTED 0x00000020
#define TDI_SERVICE_MULTICAST_SUPPORTED 0x00000040
#define TDI_SERVICE_DELAYED_ACCEPTANCE 0x00000080
#define TDI_SERVICE_EXPEDITED_DATA 0x00000100
#define TDI_SERVICE_INTERNAL_BUFFERING 0x00000200
#define TDI_SERVICE_ROUTE_DIRECTED 0x00000400
#define TDI_SERVICE_NO_ZERO_LENGTH 0x00000800
#define TDI_SERVICE_POINT_TO_POINT 0x00001000
#define TDI_SERVICE_MESSAGE_MODE 0x00002000
#define TDI_SERVICE_HALF_DUPLEX 0x00004000
#define TDI_SERVICE_DGRAM_CONNECTION 0x00008000
#define TDI_SERVICE_FORCE_ACCESS_CHECK 0x00010000
#define TDI_SERVICE_SEND_AND_DISCONNECT 0x00020000
#define TDI_SERVICE_DIRECT_ACCEPT 0x00040000
#define TDI_SERVICE_ACCEPT_LOCAL_ADDR 0x00080000
```

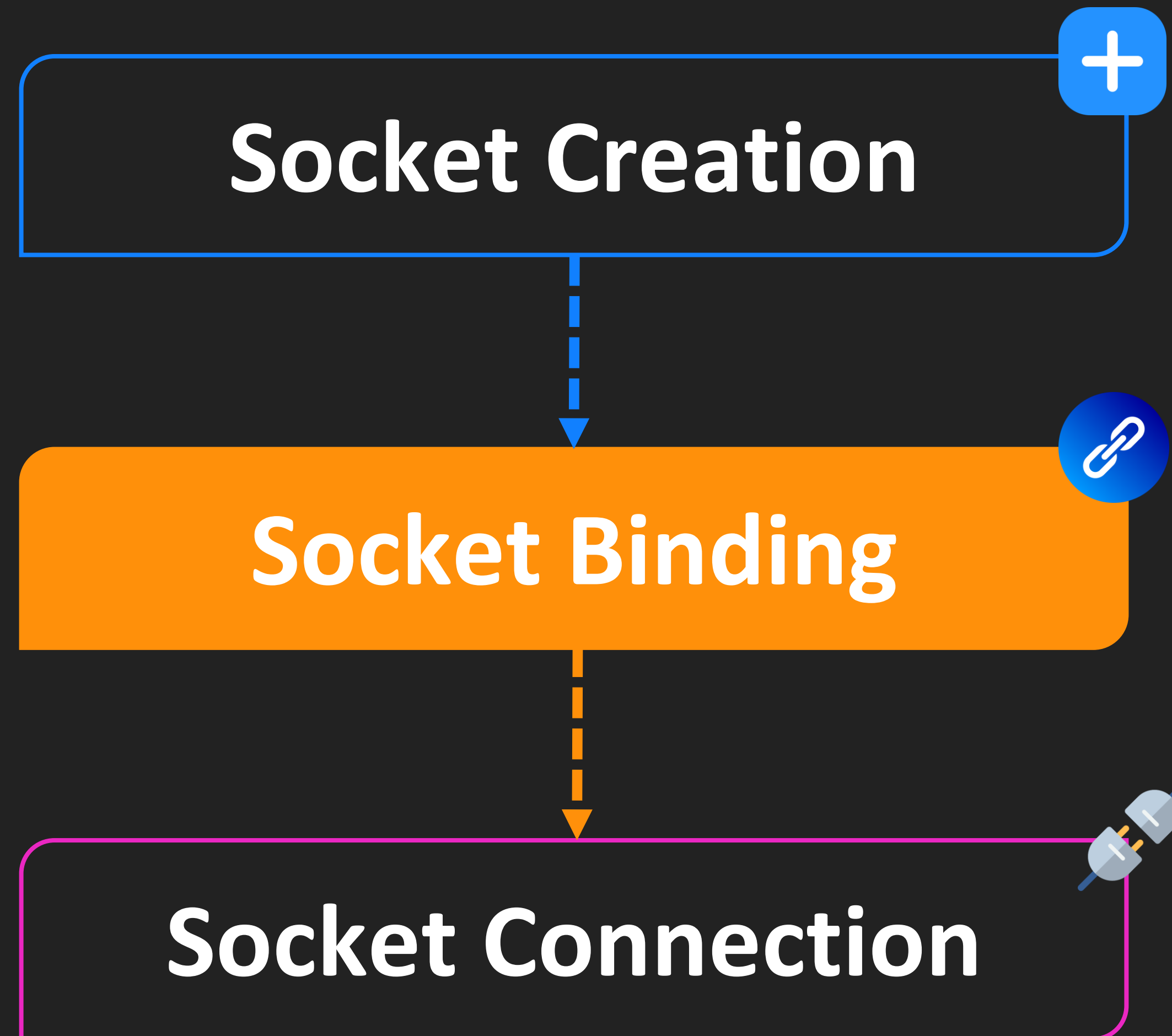

Socket Creation



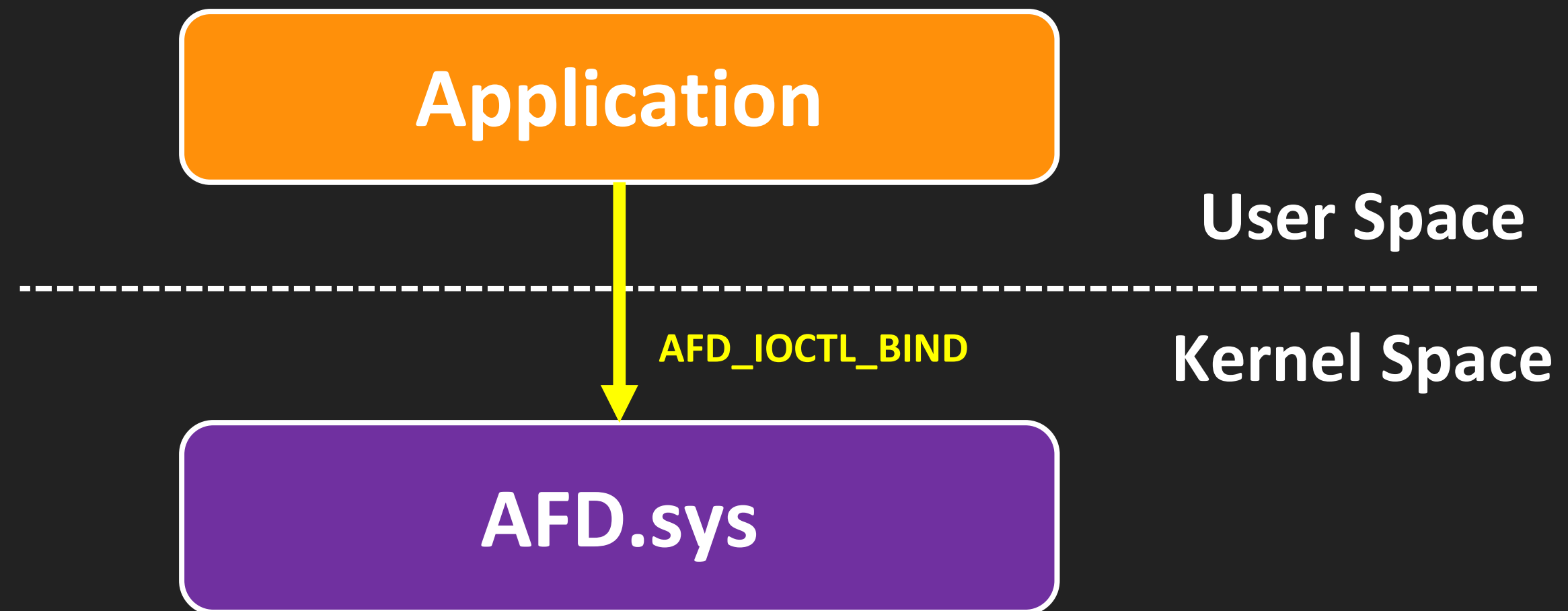
Socket Creation



Socket Workflow



Socket Binding



Socket Binding

- The **address** provided by the user for bind is passed to the transport through **CreateFile**.

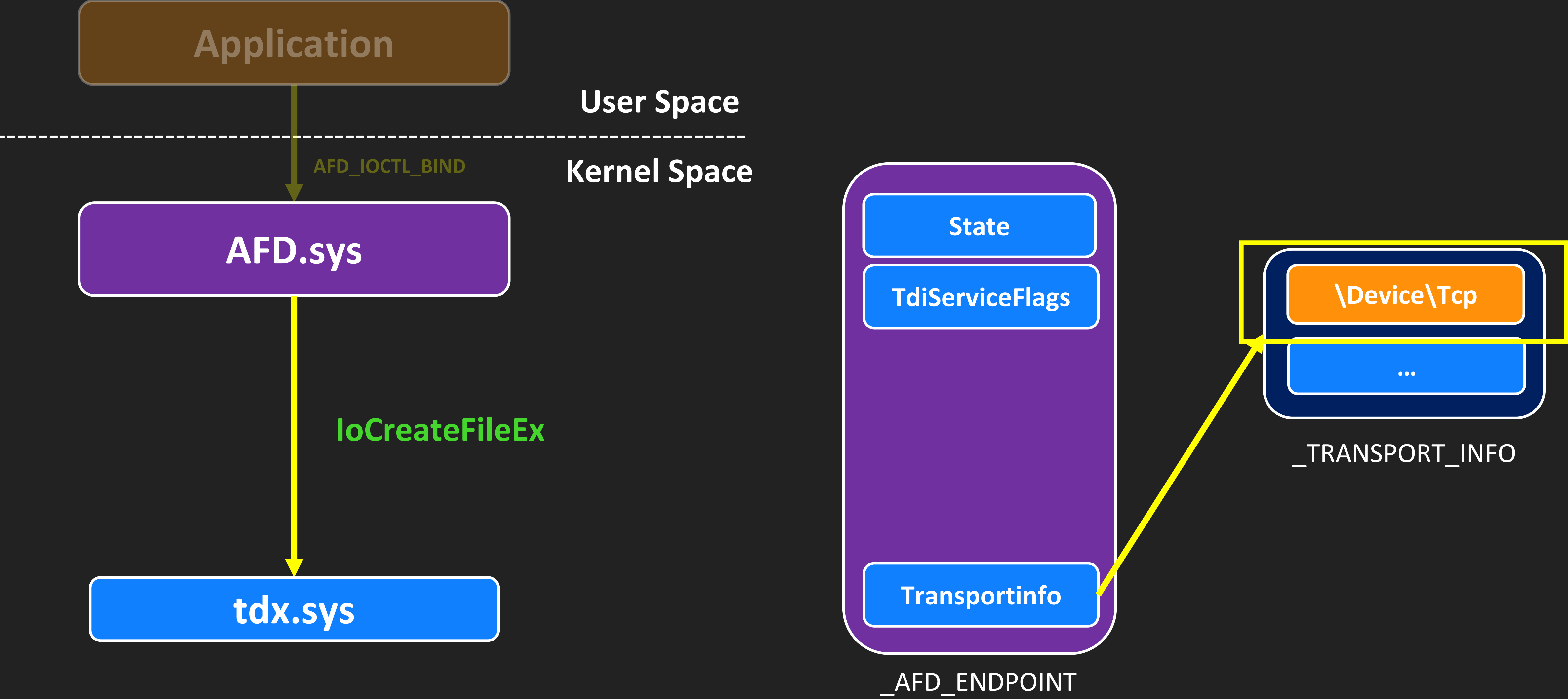
```
__int64 __fastcall AfdTdiCreateAO(...){
    memmove(EaBuffer + 8, "TransportAddress", 0x11u);
    memmove(EaBuffer + 25, inbuffer, (unsigned int)inputsize);
    ...
    ObjectAttributes.Attributes = 0x240;
    ObjectAttributes.ObjectName = &TransportInfo->TransportDeviceName;
    ...
    Status = IoCreateFileEx(
        ...
        &ObjectAttributes,
        ...
        EaBuffer,
        EaLength,
        ...
        Option,
        ...)
}
```

Socket Binding

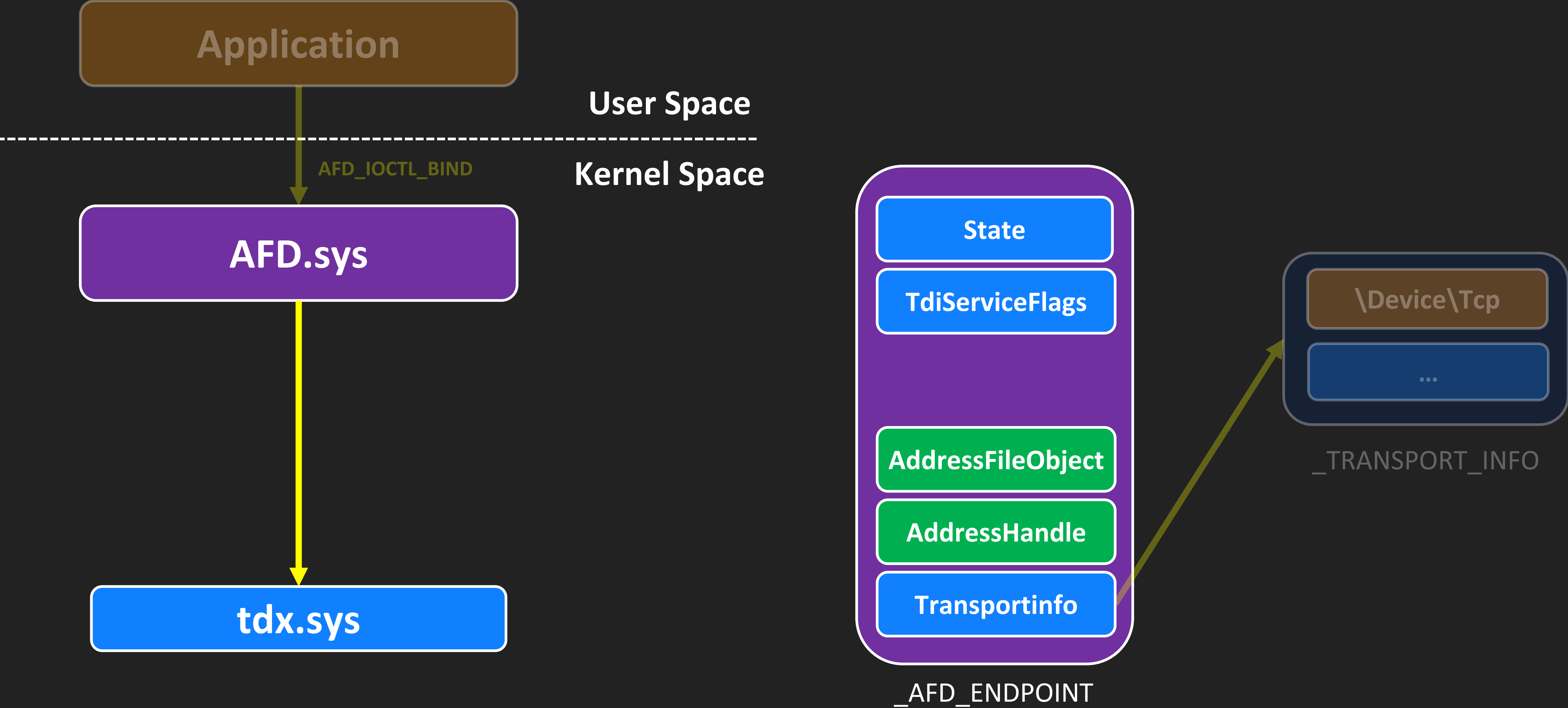
- The **address** provided by the user for bind is passed to the transport through **CreateFile**.

```
__int64 __fastcall AfdTdiCreateAO(...){
    memmove(EaBuffer + 8, "TransportAddress", 0x11u);
    memmove(EaBuffer + 25, inbuffer, (unsigned int)inputsize);
    ...
    ObjectAttributes.Attributes = 0x240;
    ObjectAttributes.ObjectName = &TransportInfo->TransportDeviceName;
    ...
    Status = IoCreateFileEx(
        ...
        &ObjectAttributes,
        ...
        EaBuffer,
        EaLength,
        ...
        Option,
        ...)
}
```

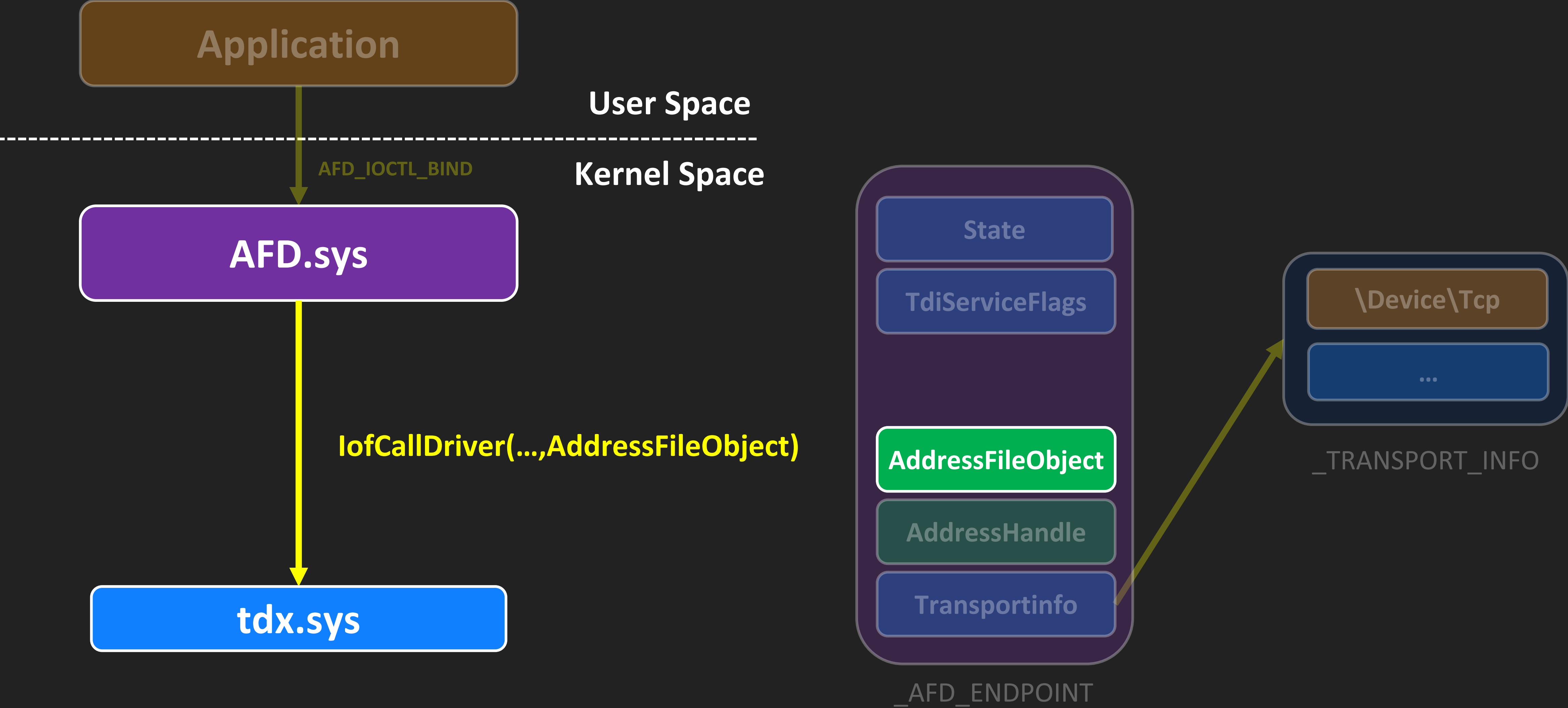
Socket Binding



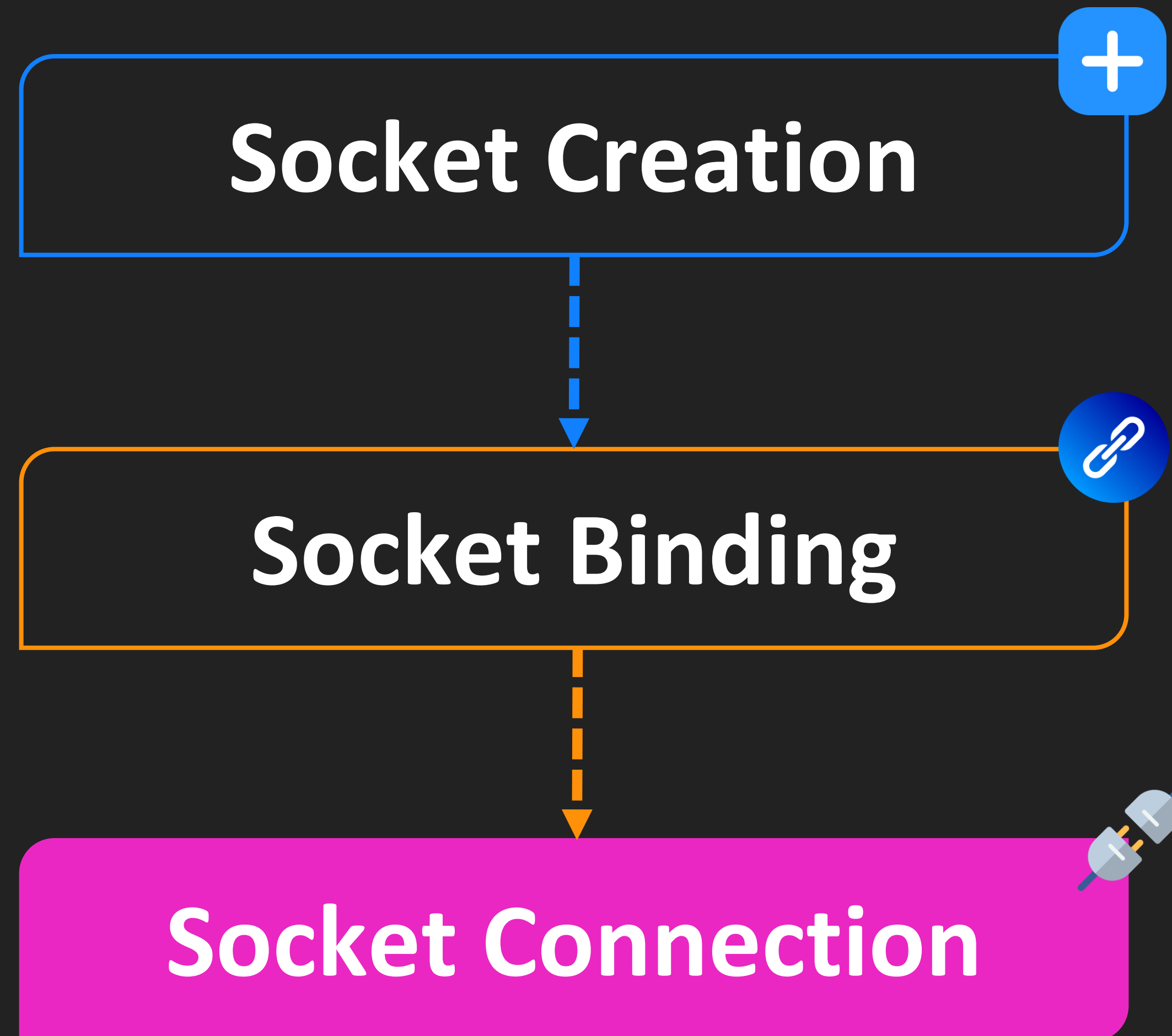
Socket Binding



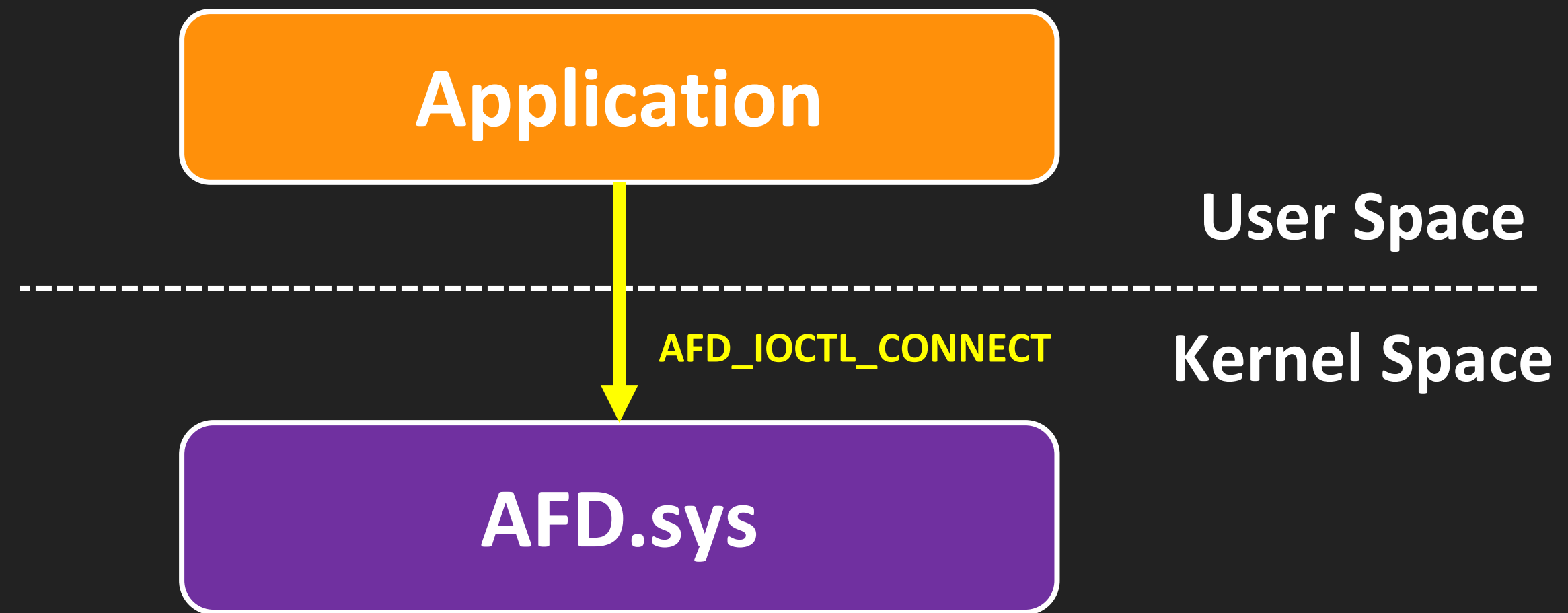
Socket Binding



Socket Workflow



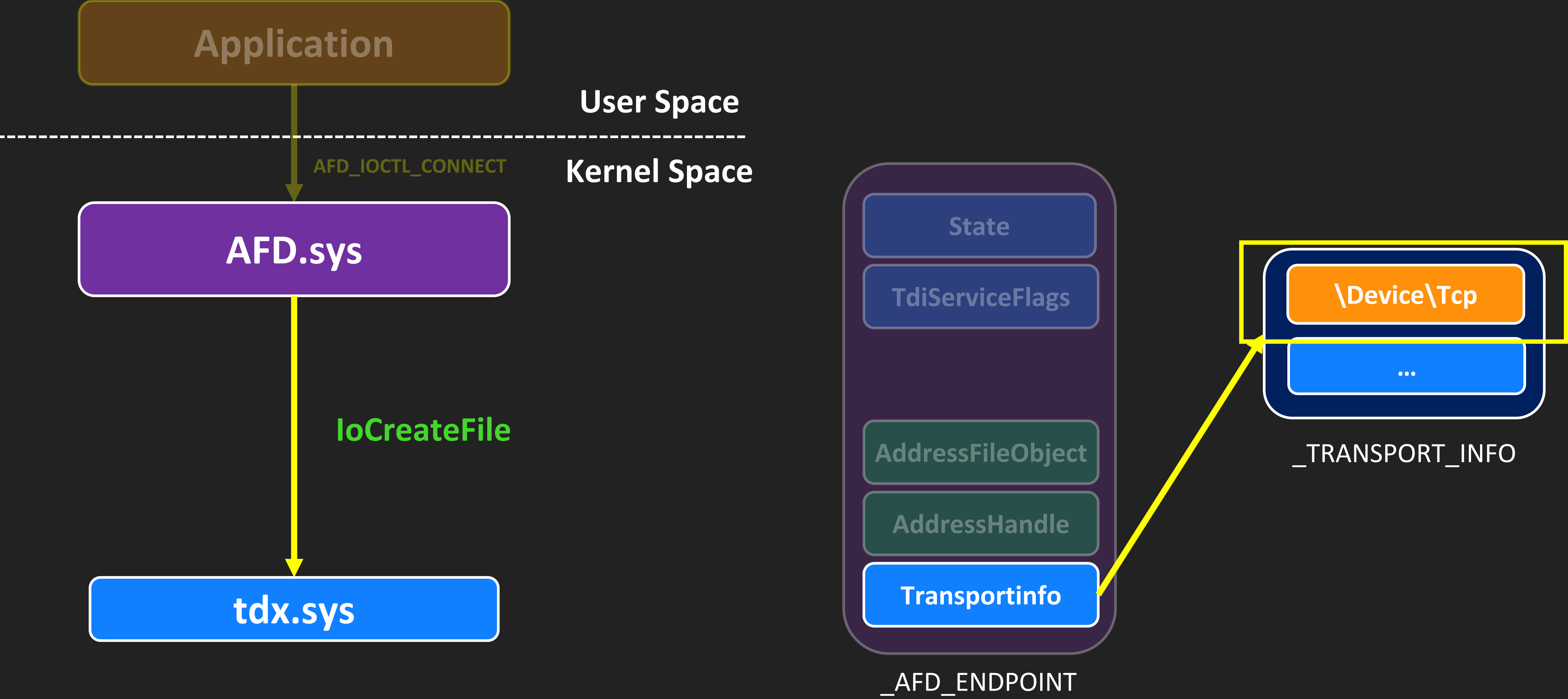
Socket Connection



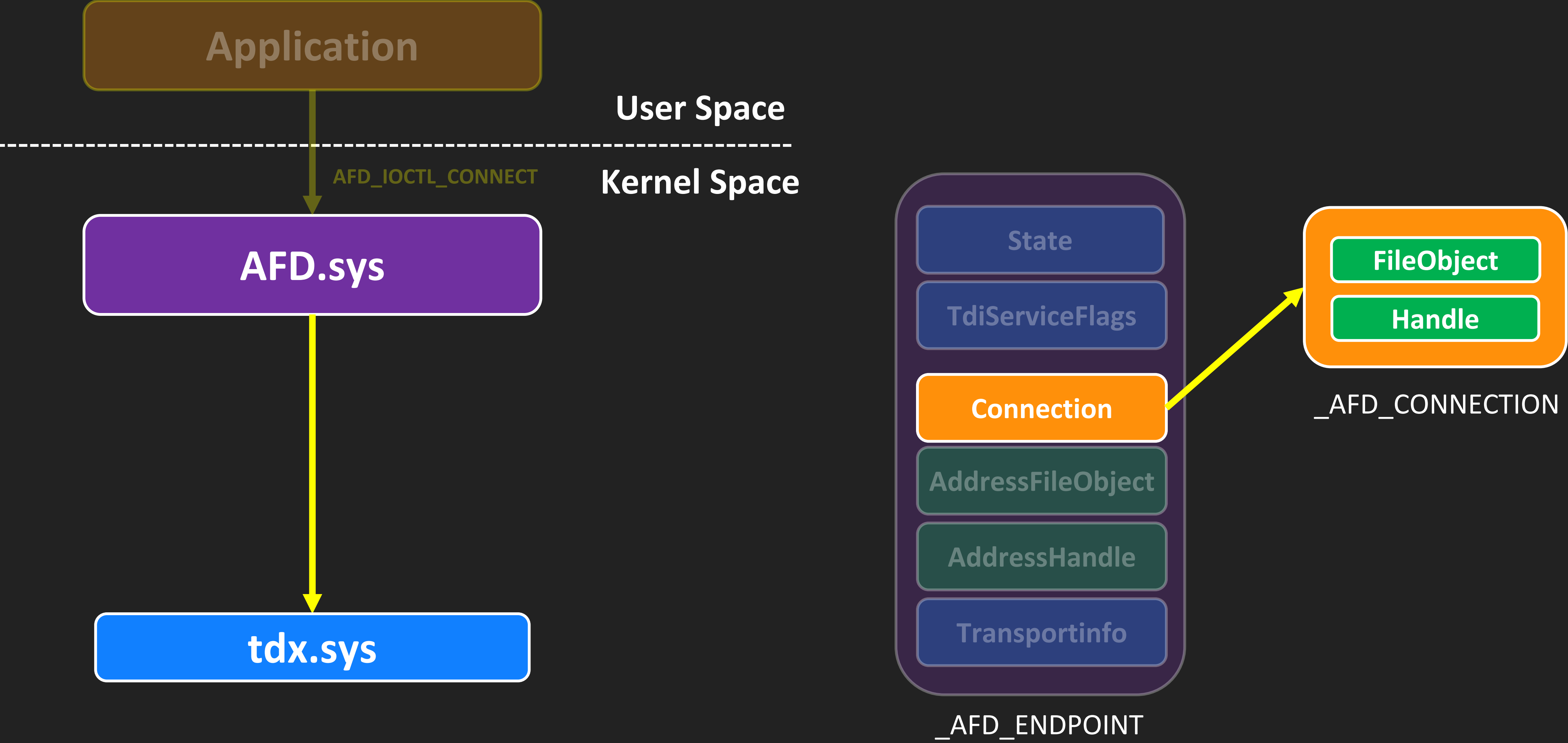
Socket Connection

```
__int64 __fastcall AfdCreateConnection(...){
    ...
    ObjectAttributes.ObjectName = &Object->TransportDeviceName;
    ObjectAttributes.Attributes = 0x240;
    strcpy(v30, "ConnectionContext");
    EaBuffer[1] = 0x81100;
    Status = IoCreateFile(
        ...
        &ObjectAttributes,
        &IoStatusBlock,
        ...
        EaBuffer,
        EaLength: 0x22u,
        ...
        Options: 0x100u);
}
```

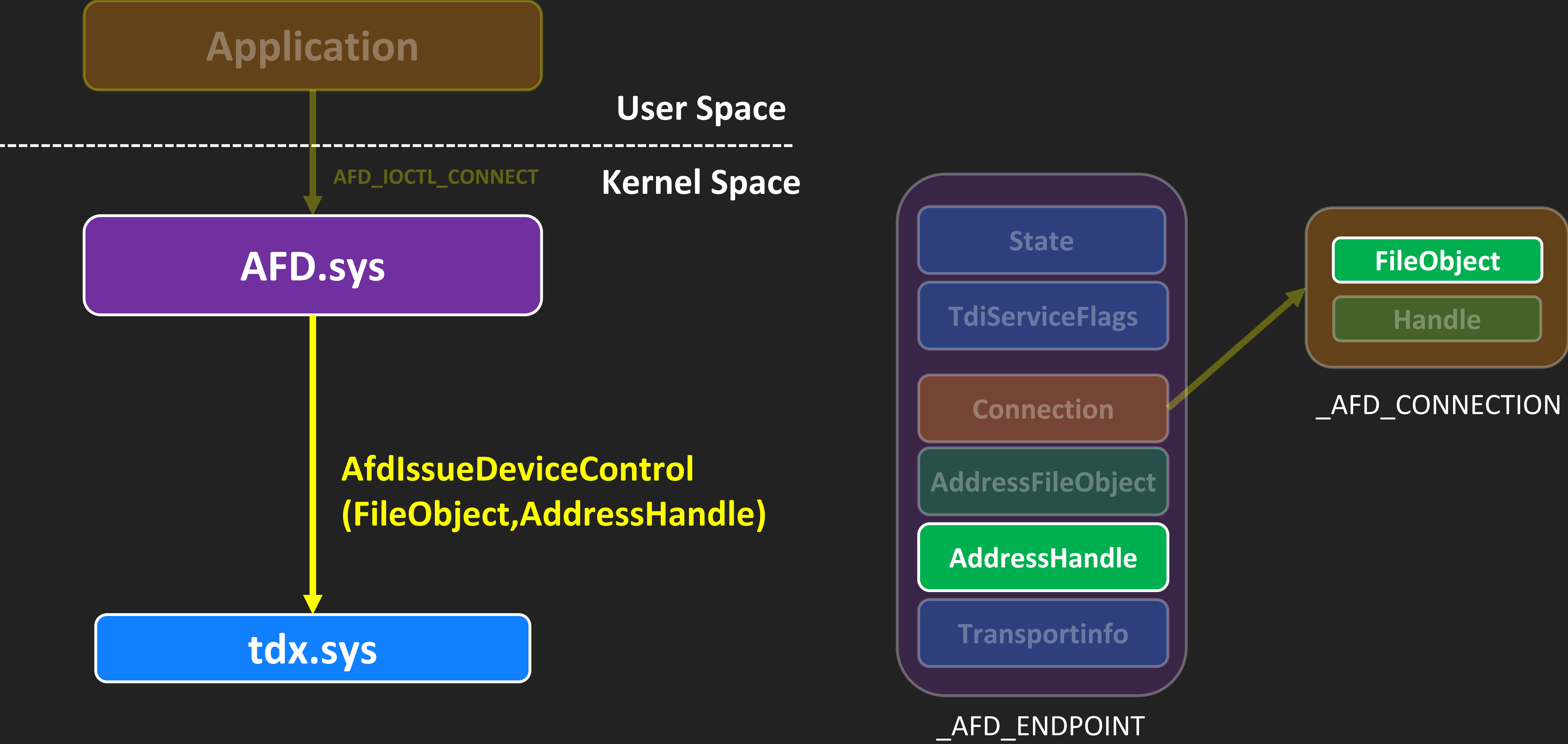
Socket Connection



Socket Connection



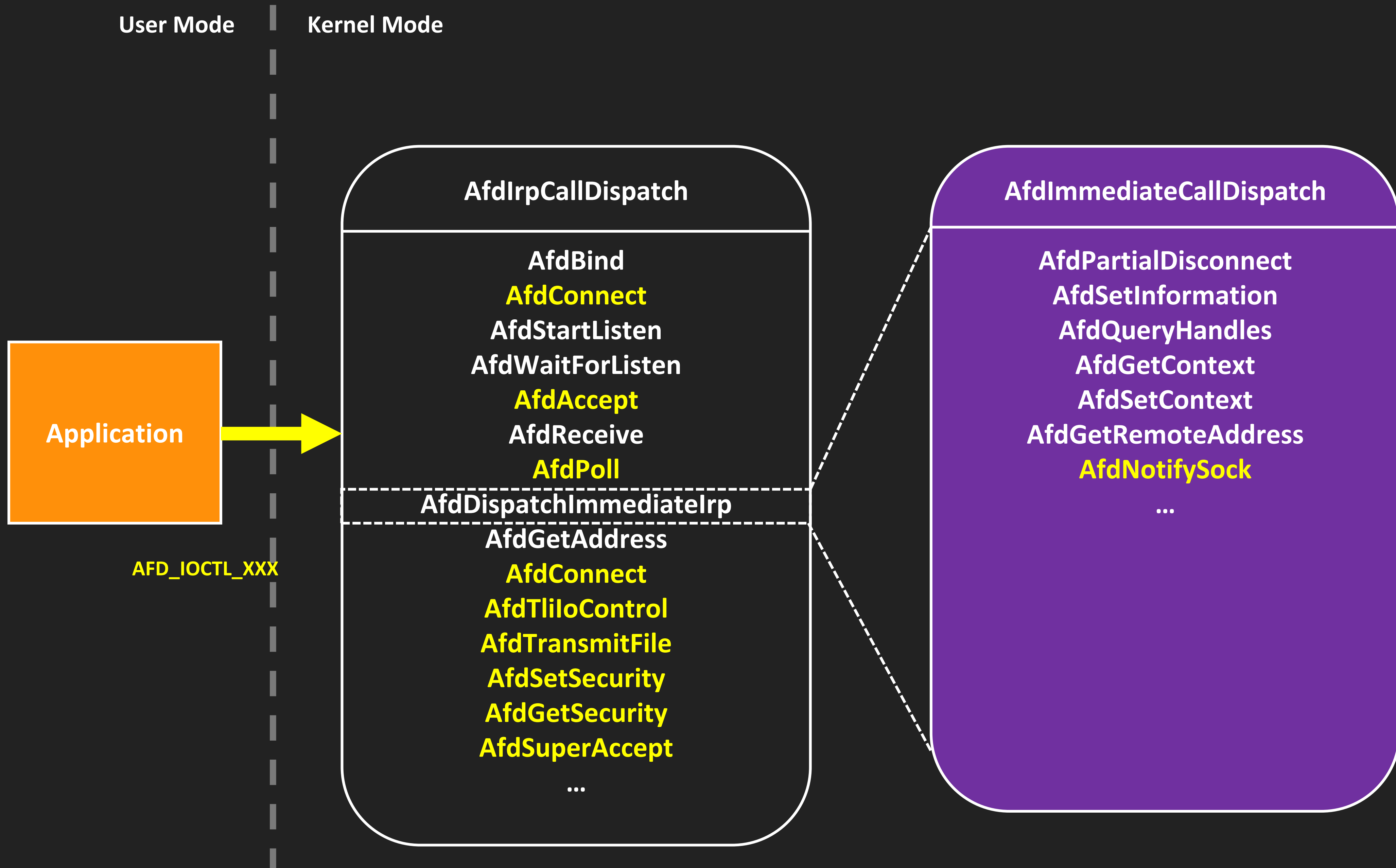
Socket Connection





Attack Surface

The known attack surface



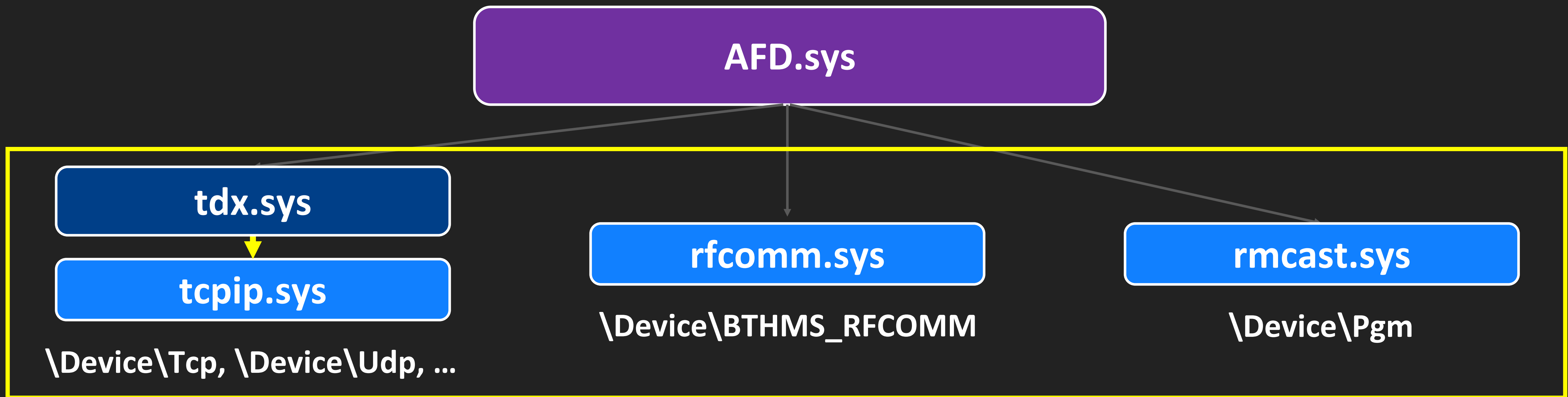
Are there any
other overlooked attack surfaces?



Low-Level Transport Drivers

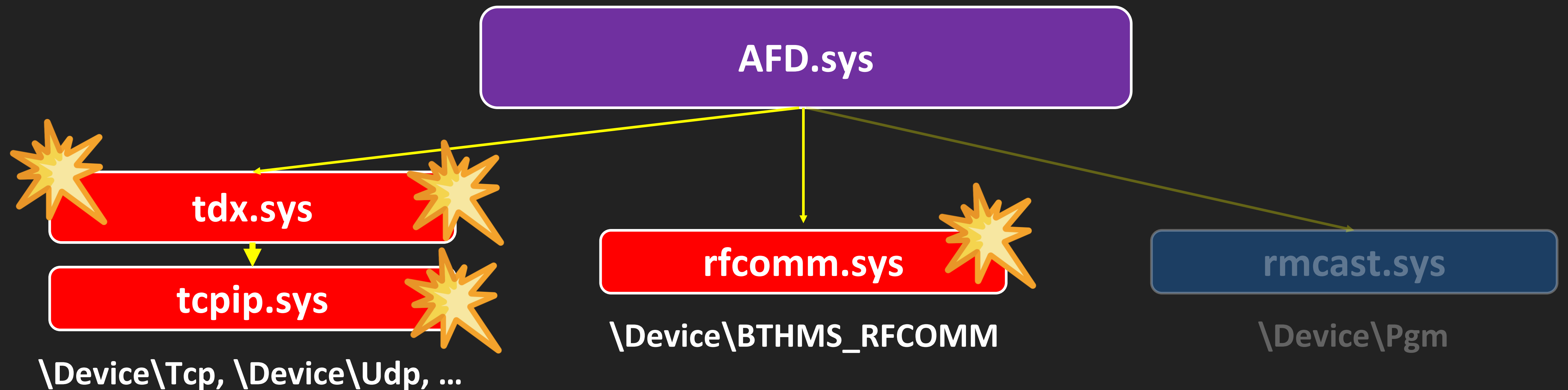
Low-Level Drivers with Minimal Validation

- Lower-layer transports often assume that inputs from AFD have **already been validated**



We found some **trivial** vulnerabilities
in a few days ...

Low-Level Drivers with Minimal Validation



Vulnerabilities

- **tdx.sys**
 - **CVE-2025-49658**
 - **CVE-2025-49659**
- **tcpip.sys**
 - **CVE-2025-54093**
- **rfcomm.sys**
 - **CVE-2025-59513 (found by @_twinklestar03)**

CVE-2025-49659

- afd!AfdFastDatagramSend -> ... -> tdx!TdxSendDatagramTransportAddress

```
_int64 __fastcall TdxSendDatagramTransportAddress(...){  
    ....  
    AddressFamily = *UserInput  
    size = sockaddr_size[AddressFamily];  
    Buffer = ExAllocatePool2(0x40,size,Tag);  
    ...  
    memcpy(Buffer,UserInput,size);  
    ...  
}
```

CVE-2025-49659

- afd!AfdFastDatagramSend -> ... -> tdx!TdxSendDatagramTransportAddress

```
_int64 __fastcall TdxSendDatagramTransportAddress(...){  
    ....  
    AddressFamily = *UserInput  
    size = sockaddr_size[AddressFamily];  
    Buffer = ExAllocatePool2(0x40,size,Tag);  
    ...  
    memcpy(Buffer,UserInput,size);  
    ...  
}
```

CVE-2025-49659

- afd!AfdFastDatagramSend -> ... -> tdx!TdxSendDatagramTransportAddress

```
_int64 __fastcall TdxSendDatagramTransportAddress(...){  
    ....  
    AddressFamily = *UserInput  
    size = sockaddr_size[AddressFamily];  
    Buffer = ExAllocatePool2(0x40,size,Tag);  
    ...  
    memcpy(Buffer,UserInput,size);  
    ...  
}
```

Fixed Size



CVE-2025-49659

- afd!AfdFastDatagramSend -> ... -> tdx!TdxSendDatagramTransportAddress

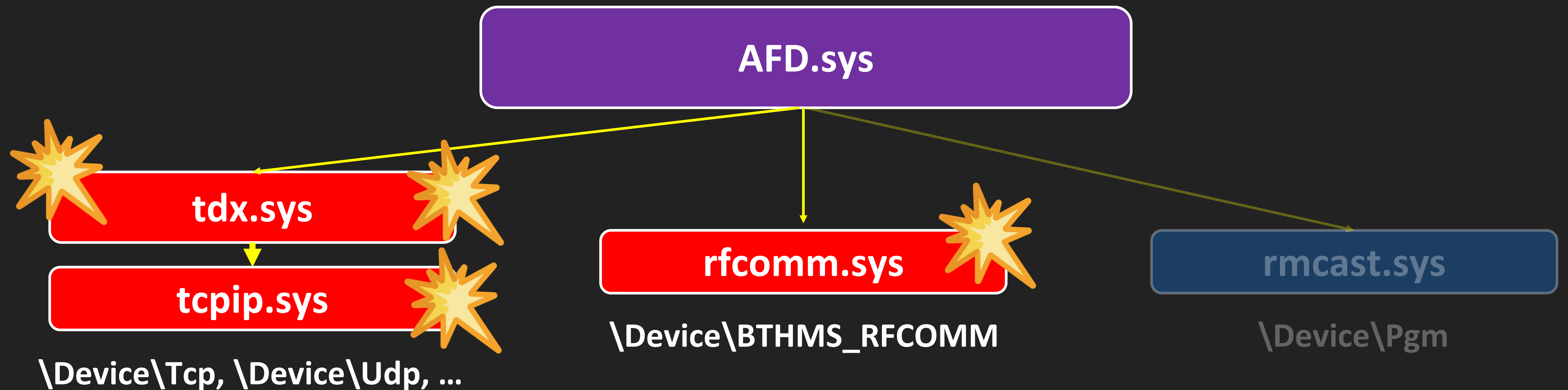
```
_int64 __fastcall TdxSendDatagramTransportAddress(...){  
  
    ....  
    AddressFamily = *UserInput  
    size = sockaddr_size[AddressFamily];  
    Buffer = ExAllocatePool2(0x40, size, Tag);  
    ...  
    memcpy(Buffer, UserInput, size);  
    ...  
}
```

Fixed Size



Out-of-Bounds Read

Low-Level Drivers with Minimal Validation



Can the selected **transport driver** be
something **unexpected**?

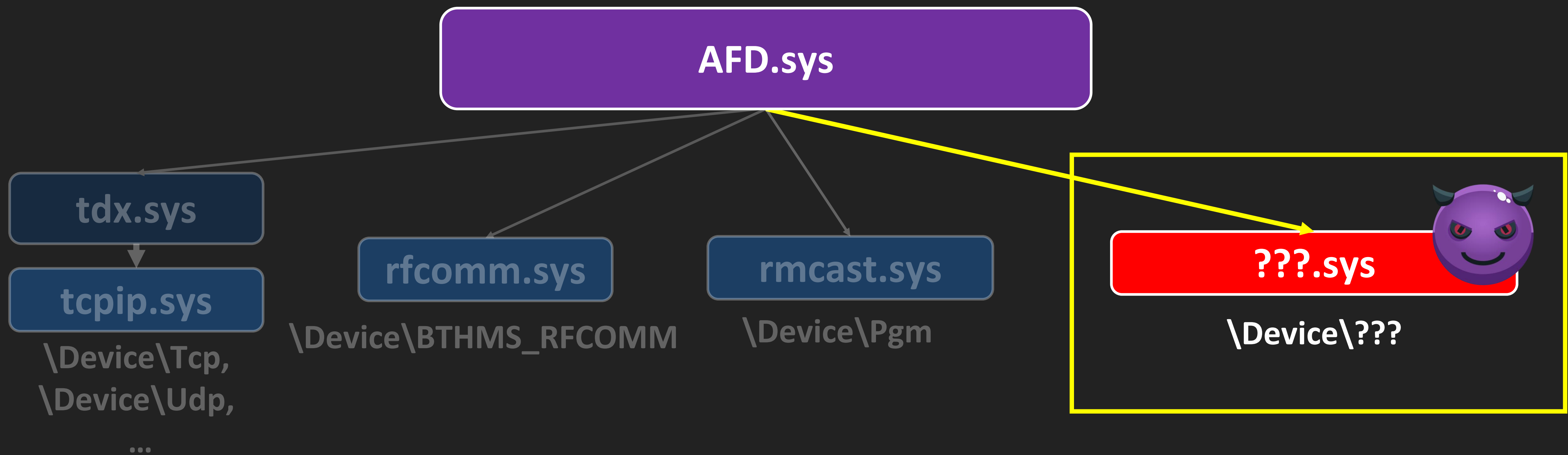


Can the selected **transport driver** be
something **unexpected**?



Attack Surface

- Can the selected **transport driver** be something **unexpected**?



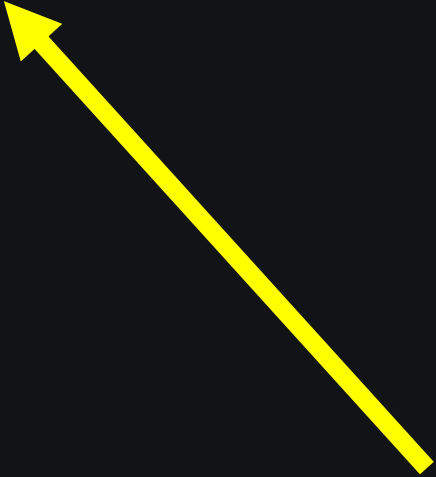


Assembling Attack Surface

Transport Composition

Transport Composition

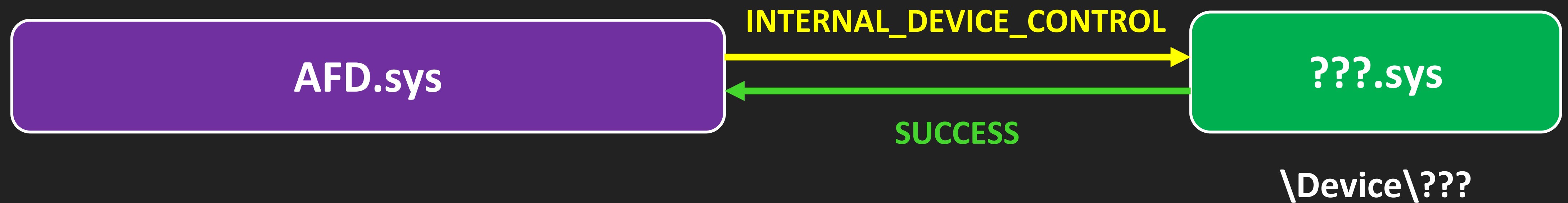
```
__int64 __fastcall AfdQueryProviderInfo(){  
    ...  
    Inputbuffer[0] = 2;  
    Inputbuffer[1] = 0;  
    // Send an internal device I/O control request with minor function 0xC.  
    Status = AfdIssueDeviceControl(DeviceObject, ..., 0xC);  
    if(Status >= 0){  
        ... // a valid transport device  
    }  
    ...  
}
```



User-Controlled Device

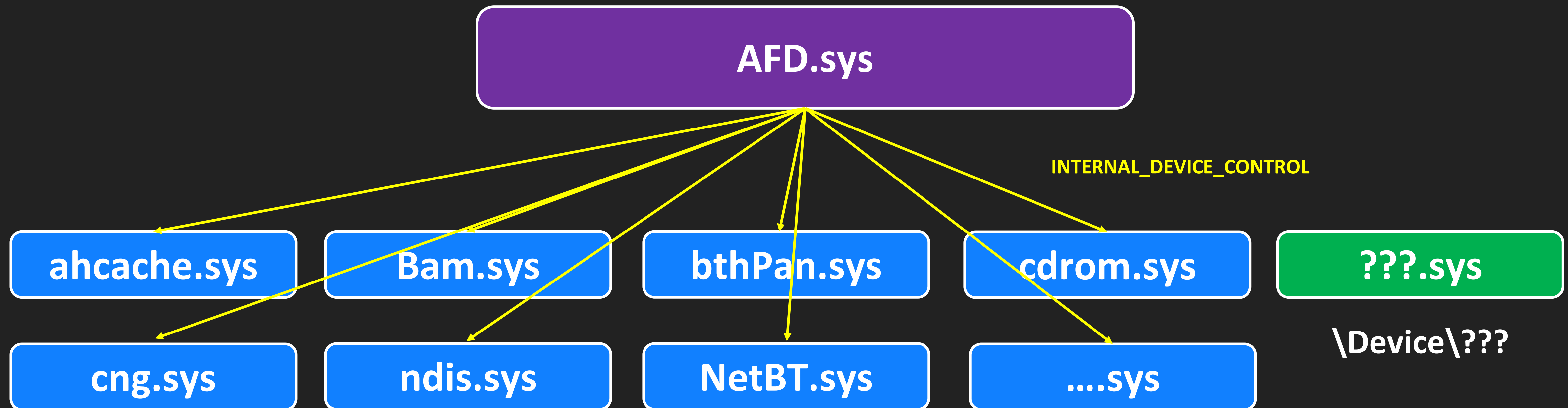
Transport Composition

- Finding a Compatible Device



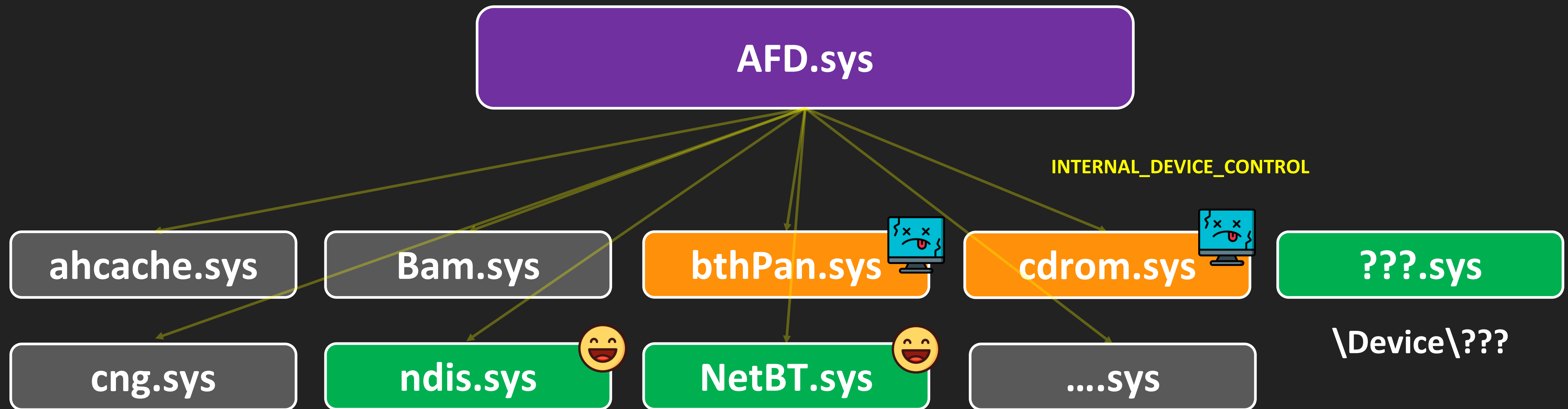
Transport Composition

- Enumeration of valid transport devices



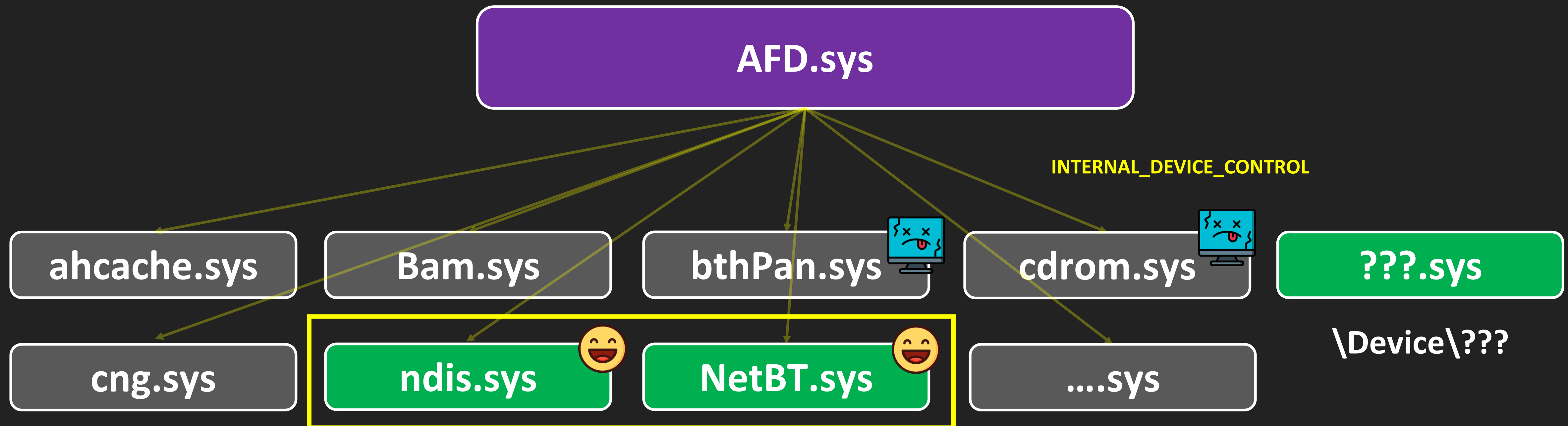
Transport Composition

- Enumeration of valid transport devices



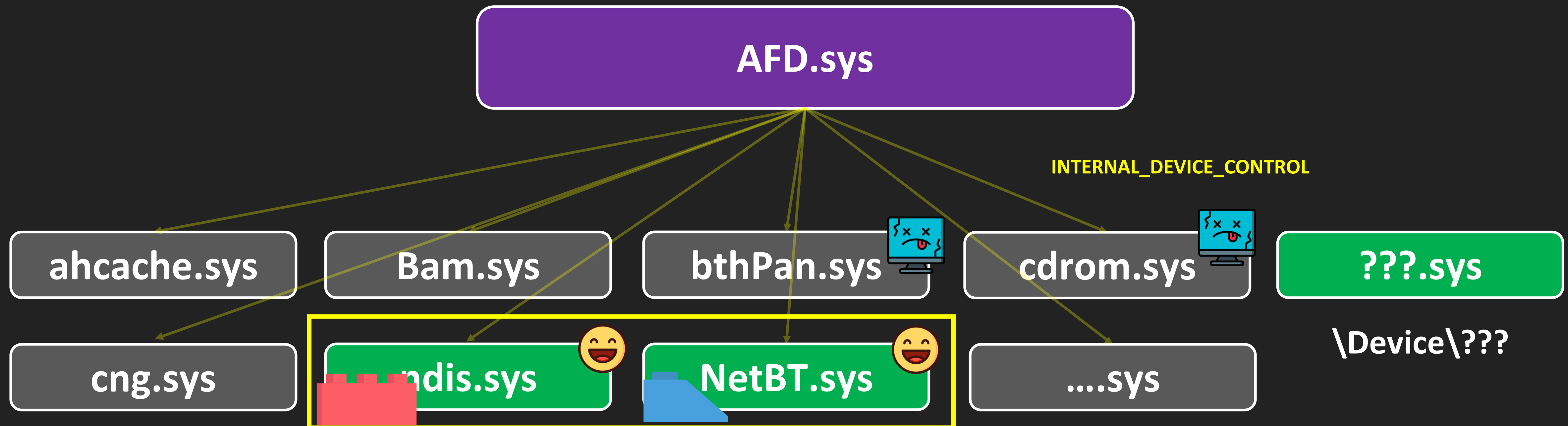
Transport Composition

- Enumeration of valid transport devices



Transport Composition

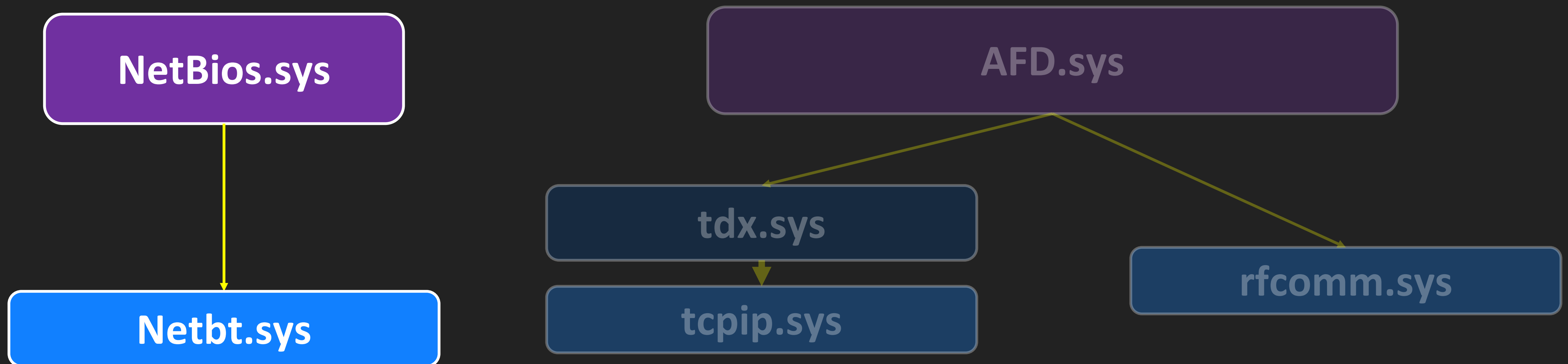
- Enumeration of valid transport devices



Compose with **NetBT**

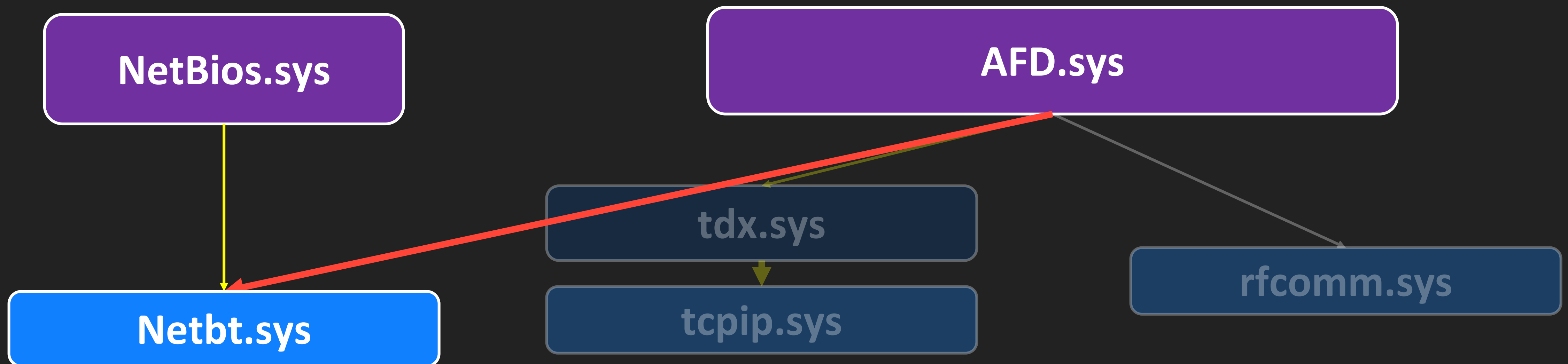
Transport Composition

- NetBT
 - A transport that's supposed to be used by **NetBIOS**



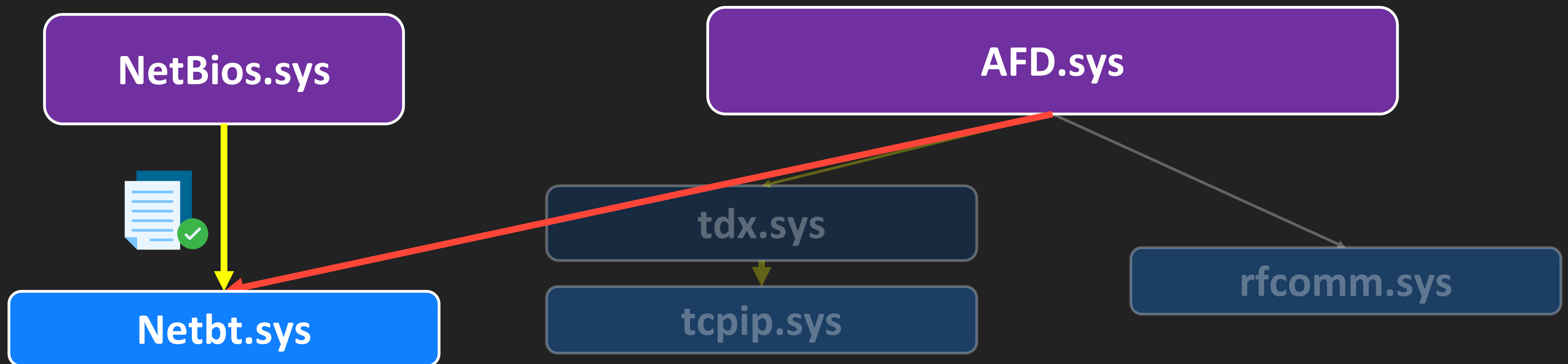
Transport Composition

- NetBT
 - A transport that's supposed to be used by **NetBIOS**



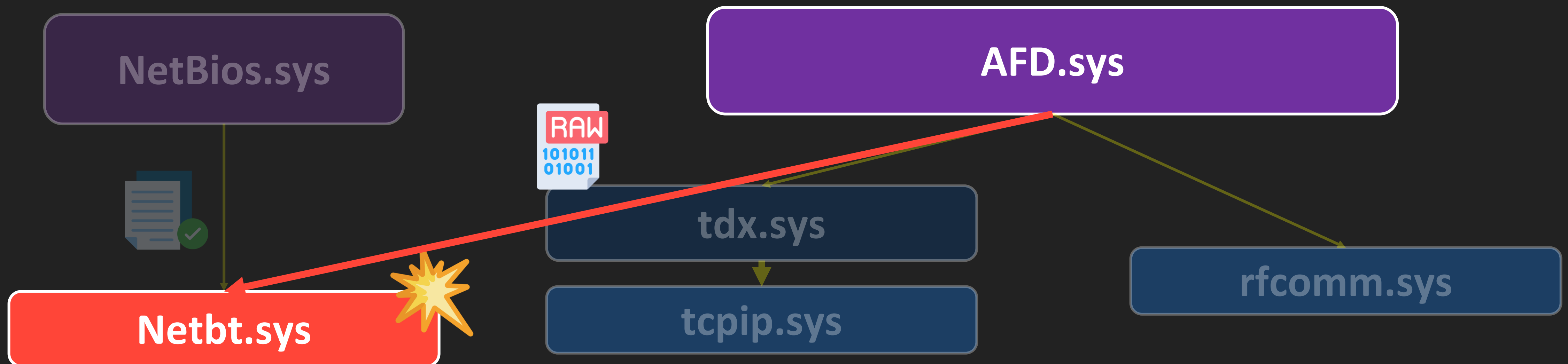
Transport Composition

- NetBT
 - A transport that's supposed to be used by **NetBIOS**



Transport Composition

- NetBT
 - A transport that's supposed to be used by **NetBIOS**



CVE-2025-55230

- `afd!AfdConnect-> ... -> NTConnect -> ... -> NewInternalAddressFromUnicodeAddress`

```
_int64 __fastcall NewInternalAddressFromUnicodeAddress(...)  
{  
    ...  
    SourceString.Buffer = UserInput->EndpointName.Buffer;  
    if ( RtlUpcaseUnicodeStringToOemString(&Endpointname, &SourceString, 1u) < 0 )  
    {  
        RtlFreeOemString(&RemoteName);  
        return 0xC0000141LL;  
    }  
    ...  
}
```


CVE-2025-55230

- `afd!AfdConnect-> ... -> NTConnect -> ... -> NewInternalAddressFromUnicodeAddress`

```
_int64 __fastcall NewInternalAddressFromUnicodeAddress(...)  
{  
    ...  
    SourceString.Buffer = UserInput->EndpointName.Buffer;  
    if ( RtlUppcaseUnicodeStringToOemString(&Endpointname, &SourceString, 1u) < 0 )  
    {  
        RtlFreeOemString(&RemoteName);  
        return 0xC0000141LL;  
    }  
    ...  
}
```

We can pass a kernel pointer !

CVE-2025-55230

- `afd!AfdConnect-> ... -> NTConnect -> ... -> NewInternalAddressFromUnicodeAddress`

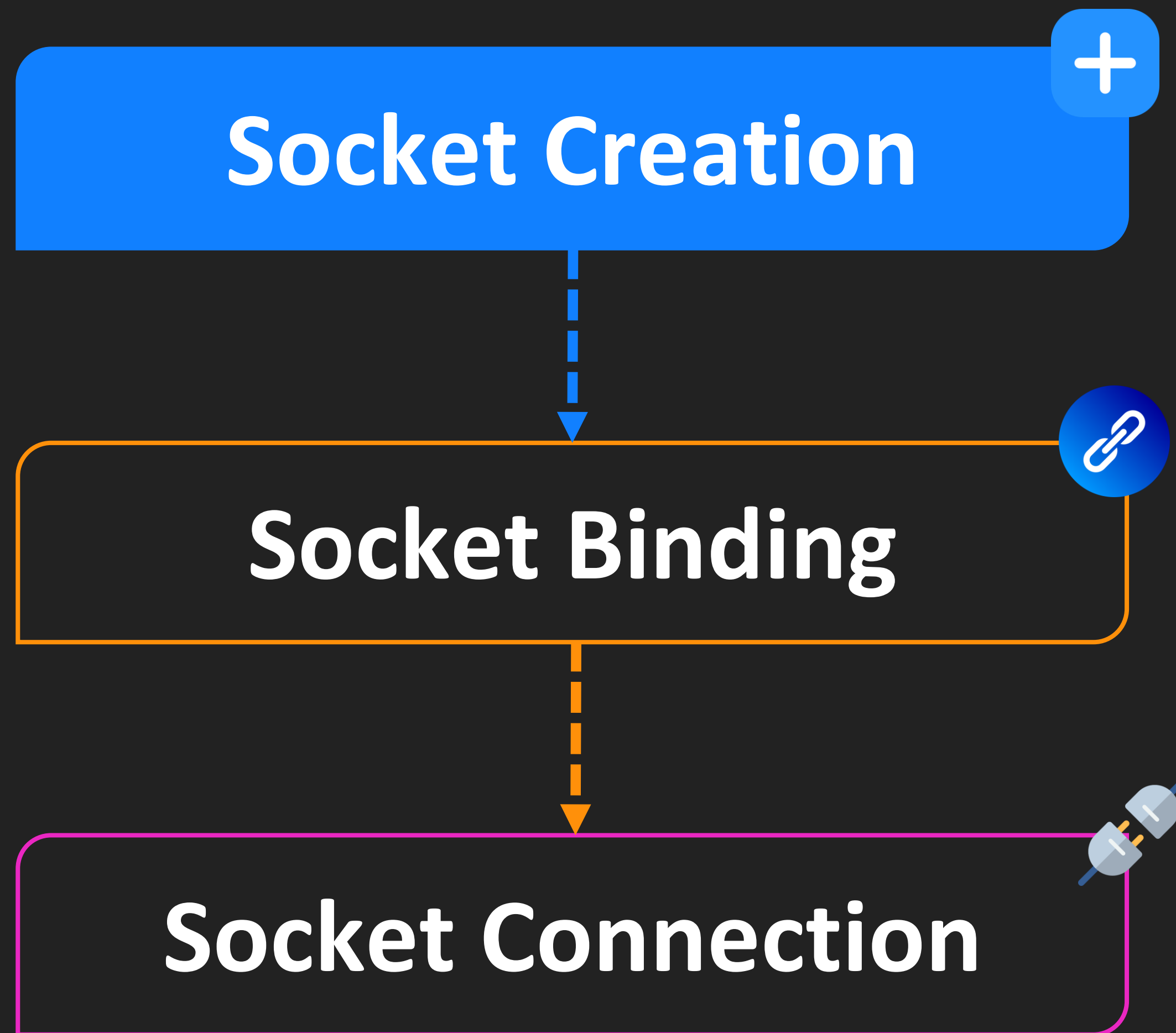
```
_int64 __fastcall NewInternalAddressFromUnicodeAddress(...)  
{  
    ...  
    SourceString.Buffer = UserInput->EndpointName.Buffer;  
    if ( RtlUpcaseUnicodeStringToOemString(&Endpointname, &SourceString, 1u) < 0 )  
    {  
        RtlFreeOemString(&RemoteName);  
        return 0xC0000141LL;  
    }  
    ...  
}
```

We can pass a kernel pointer!

Arbitrary Memory Read

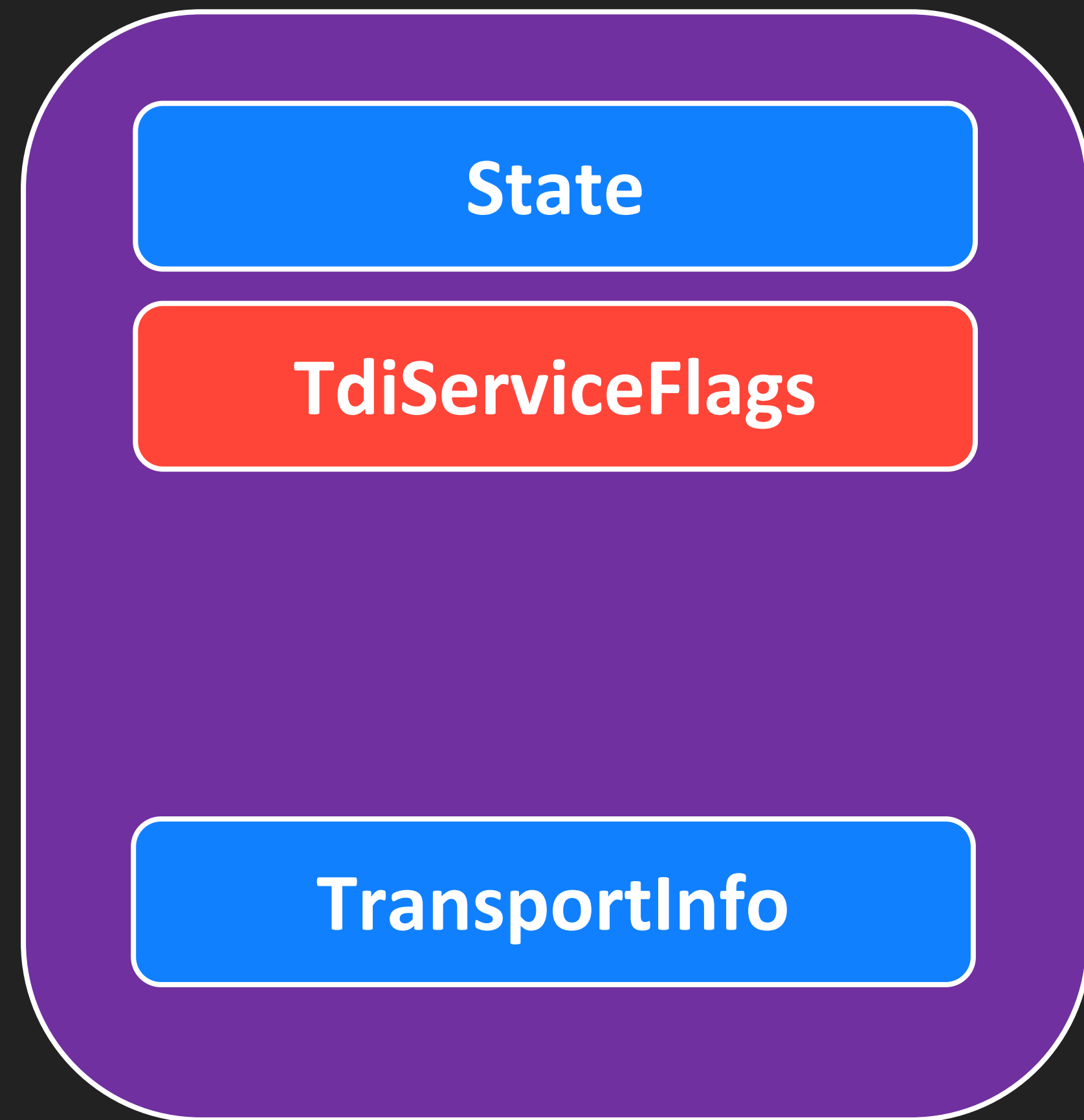
Compose with **NDIS**

Socket Workflow

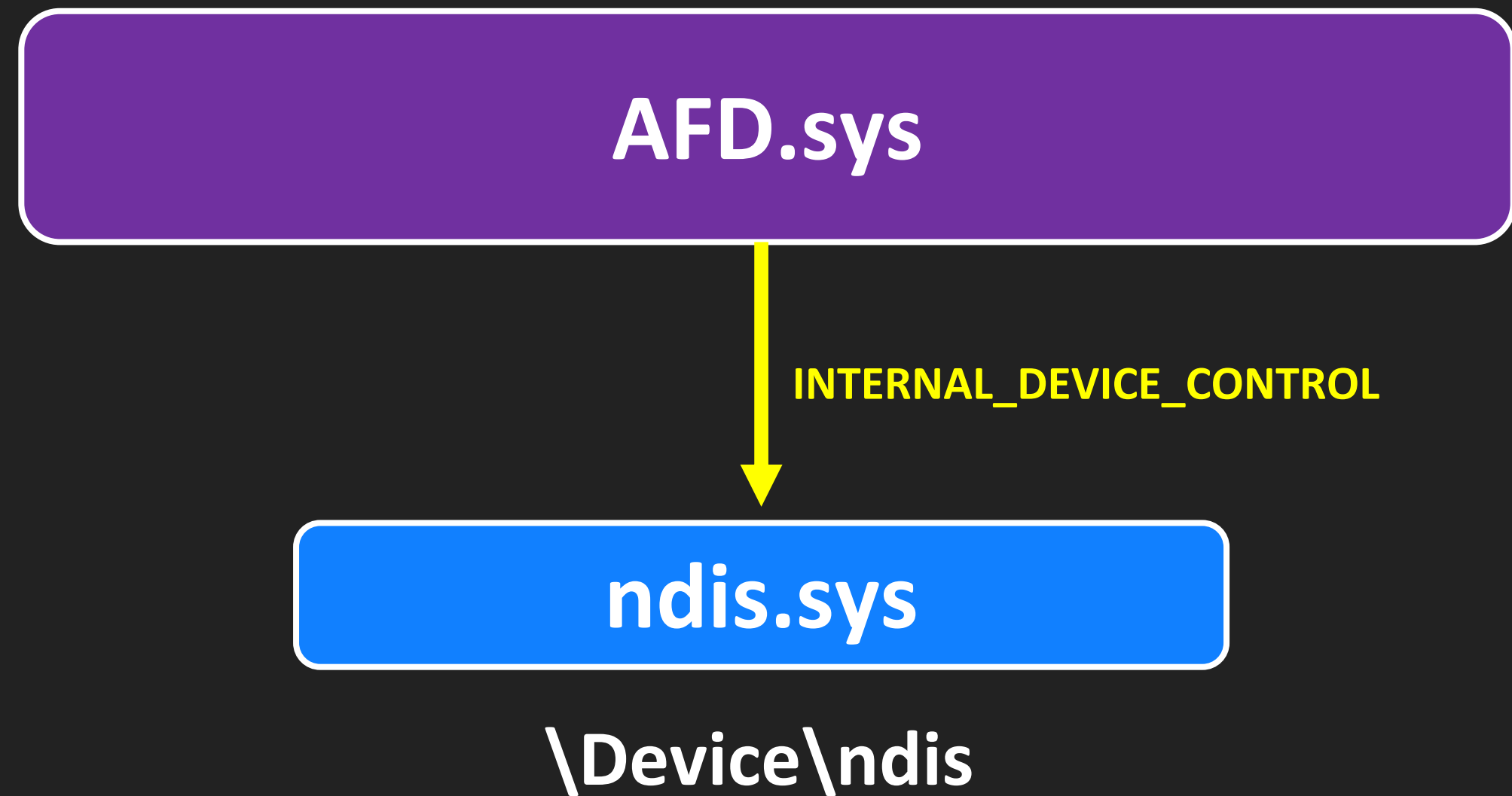


`\Device\ndis`

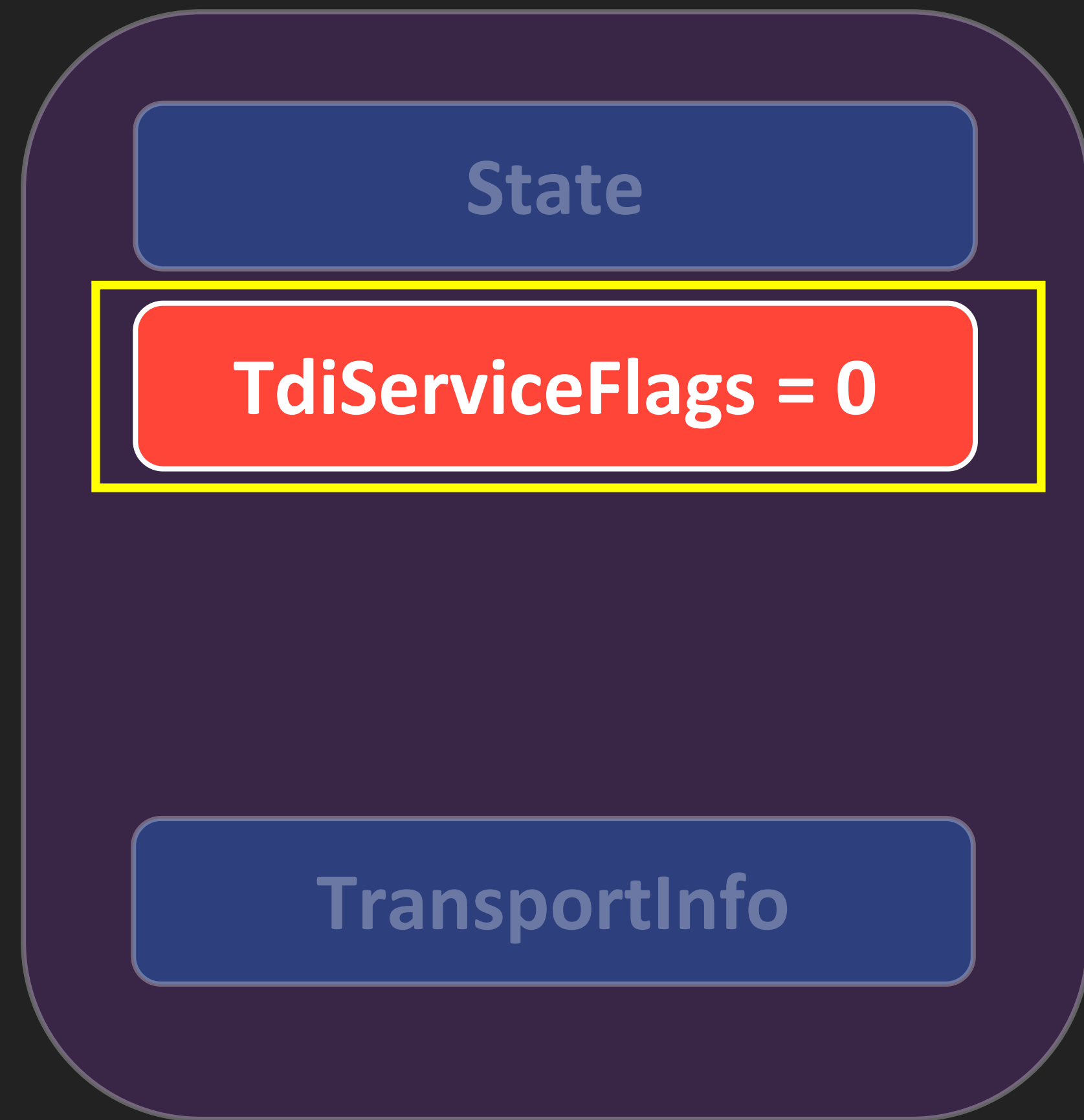
Ndis Socket Creation



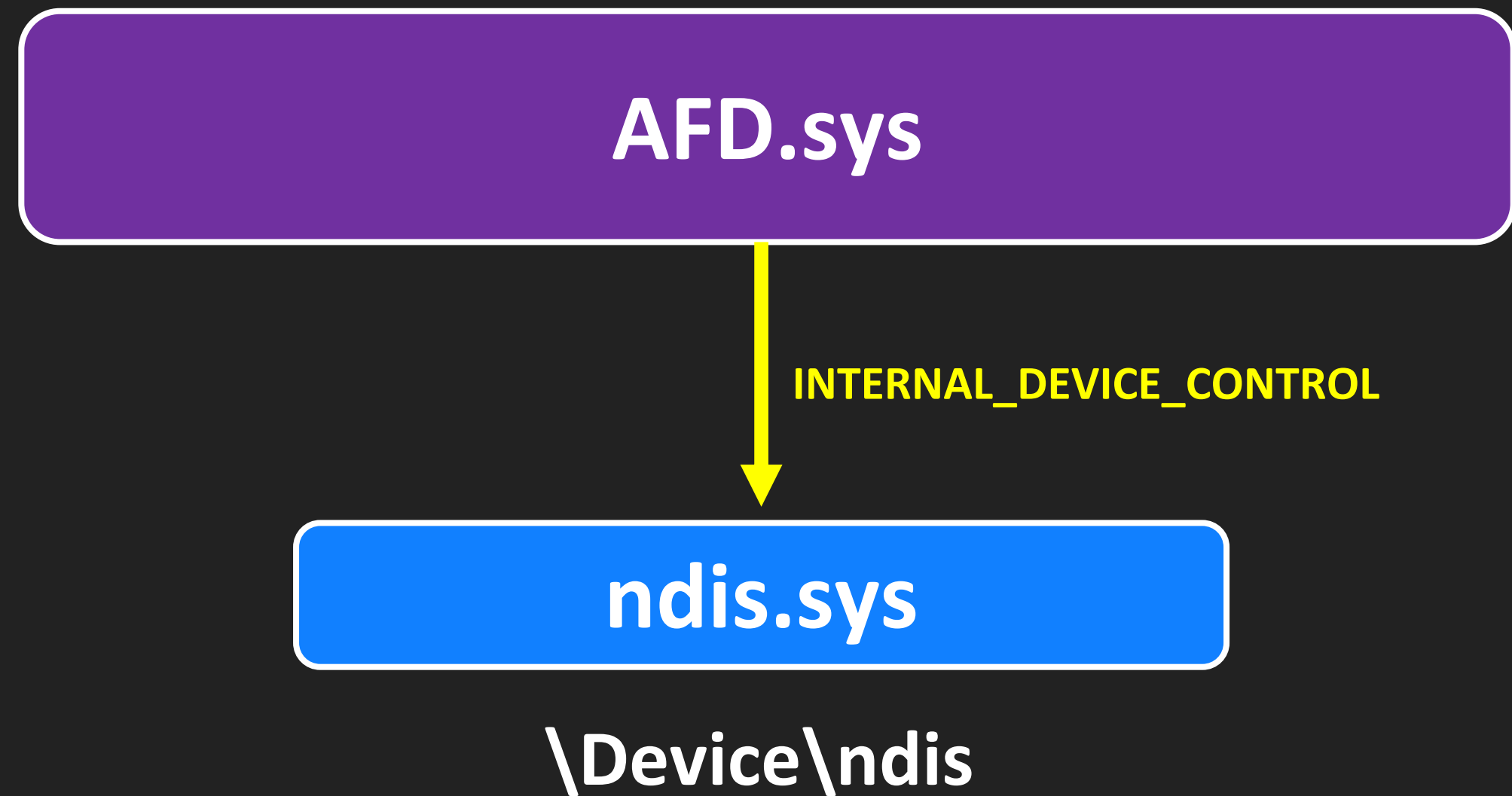
`_AFD_ENDPOINT`



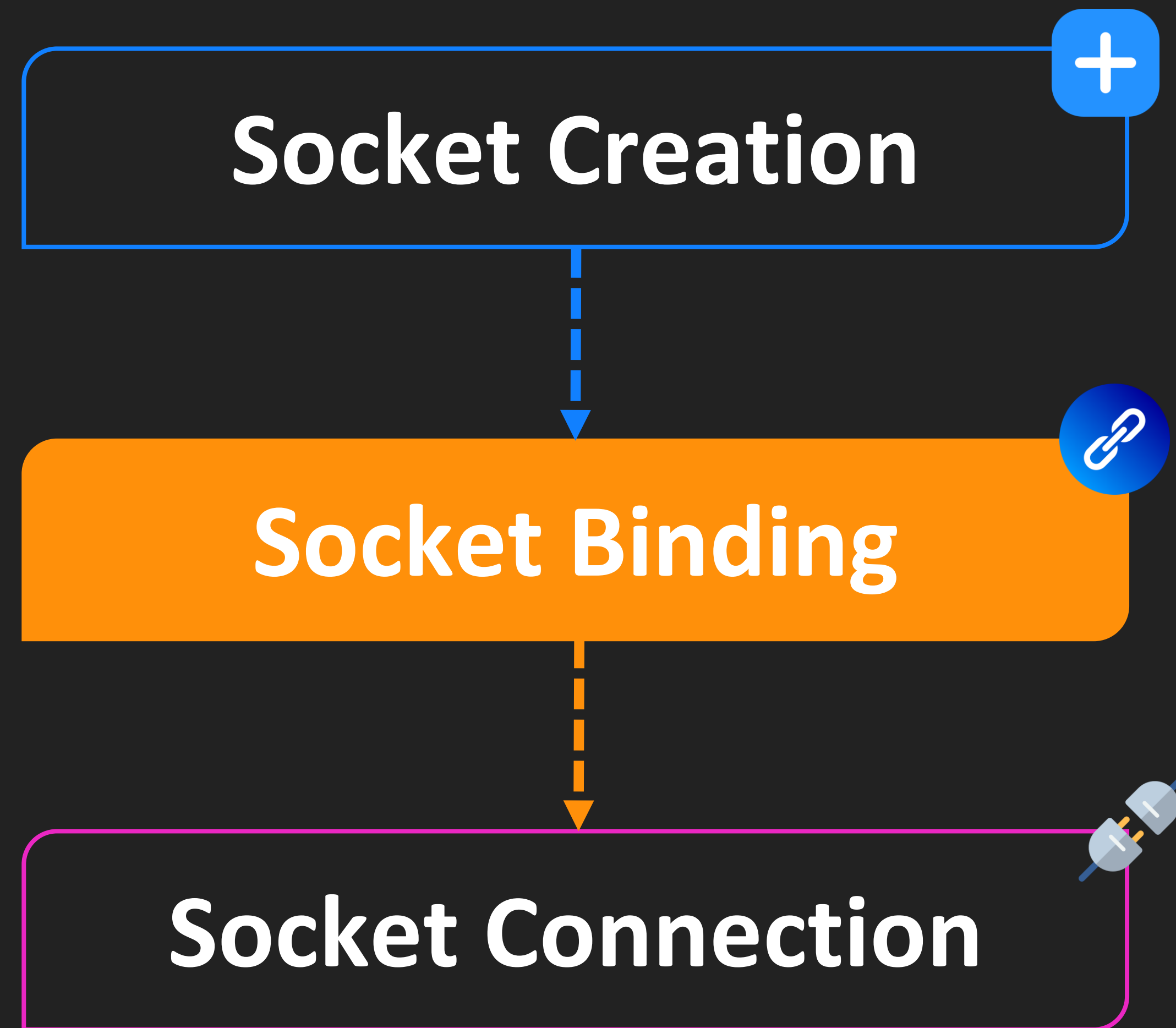
Ndis Socket Creation



`_AFD_ENDPOINT`



Socket Workflow



`\Device\ndis`

Ndis Socket Binding

```
__int64 __fastcall AfdTdiCreateAO(...){
    Option = IO_NO_PARAMETER_CHECKING;
    if ( (EndPoint->TdiServiceFlags & TDI_SERVICE_FORCE_ACCESS_CHECK) != 0 )
    {
        Option = IO_NO_PARAMETER_CHECKING | IO_FORCE_ACCESS_CHECK ;
    }
    ...
    ObjectAttributes.Attributes = OBJ_KERNEL_HANDLE;
    ObjectAttributes.ObjectName = &TransportInfo->TransportDeviceName;
    ...
    Status = IoCreateFileEx(
        ...
        &ObjectAttributes,
        ...
        EaBuffer,
        EaLength,
        ...
        Option,
        ...
    )
}
```

State

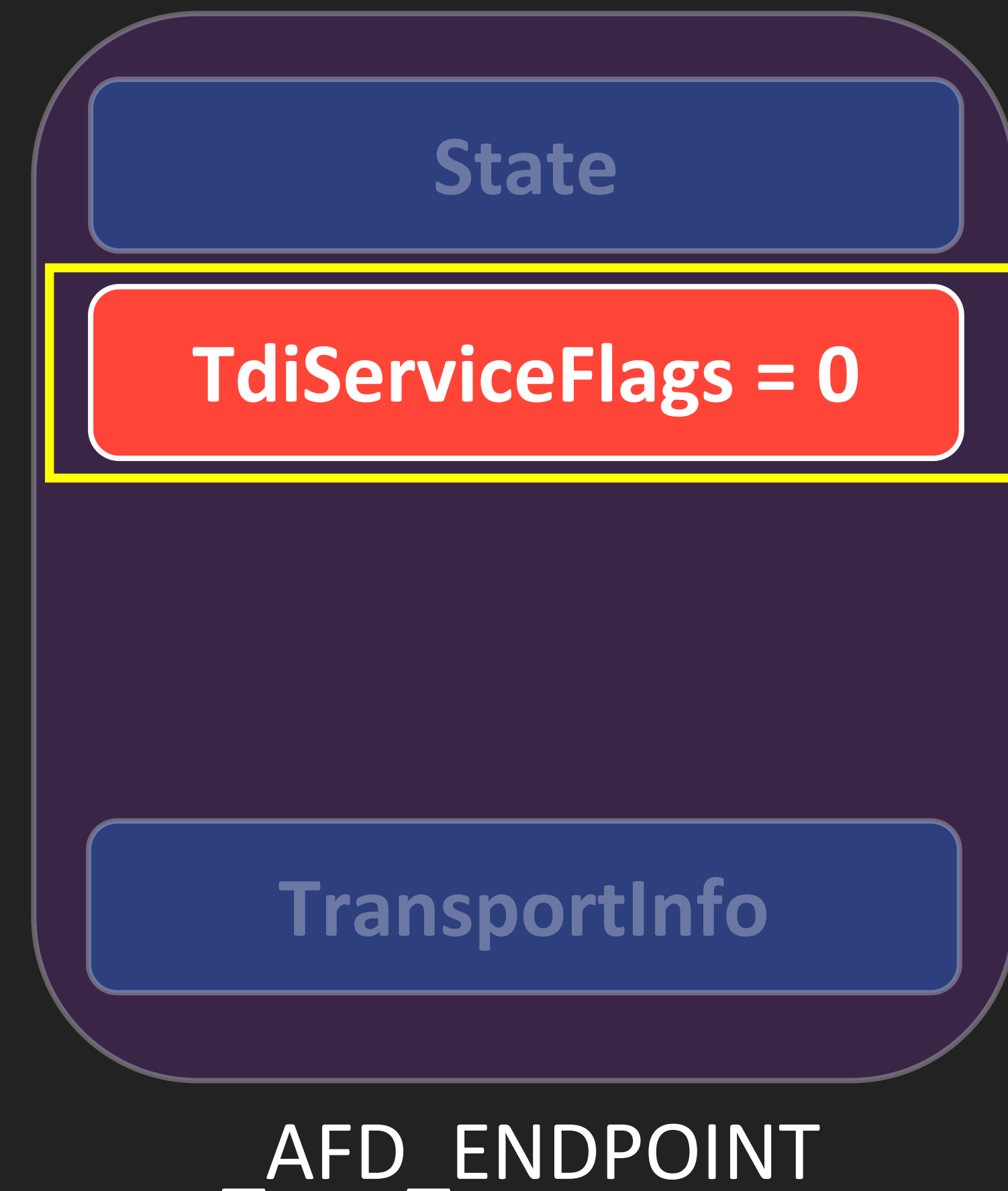
TdiServiceFlags = 0

TransportInfo

_AFD_ENDPOINT

Ndis Socket Binding

```
__int64 __fastcall AfdTdiCreateAO(...){
    Option = IO_NO_PARAMETER_CHECKING;
    if ( (EndPoint->TdiServiceFlags & TDI_SERVICE_FORCE_ACCESS_CHECK) != 0 )
    {
        Option = IO_NO_PARAMETER_CHECKING | IO_FORCE_ACCESS_CHECK ;
    }
    ...
    ObjectAttributes.Attributes = OBJ_KERNEL_HANDLE;
    ObjectAttributes.ObjectName = &TransportInfo->TransportDeviceName;
    ...
    Status = IoCreateFileEx(
        ...
        &ObjectAttributes,
        ...
        EaBuffer,
        EaLength,
        ...
        Option,
        ...
    )
}
```



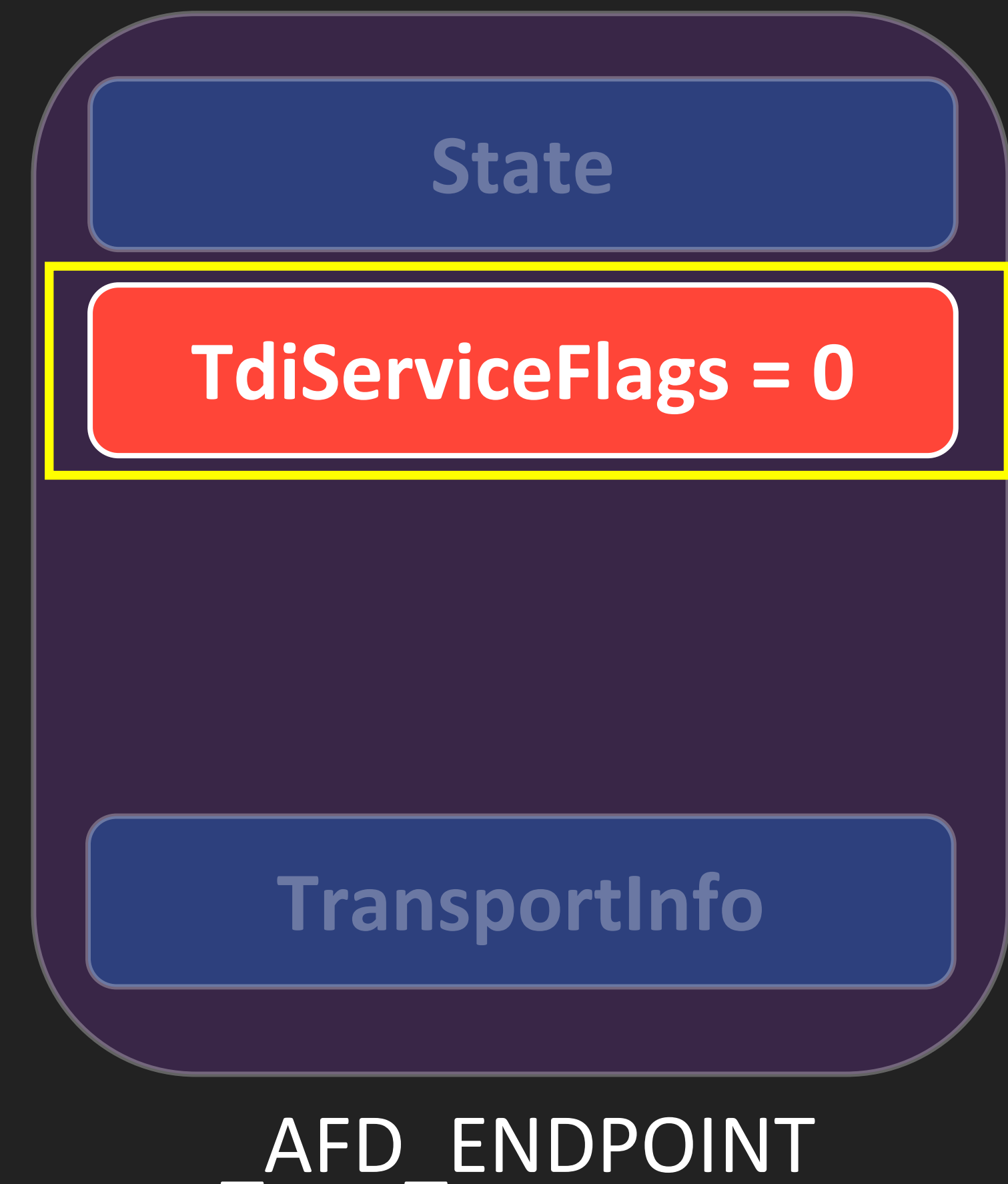
Ndis Socket Binding

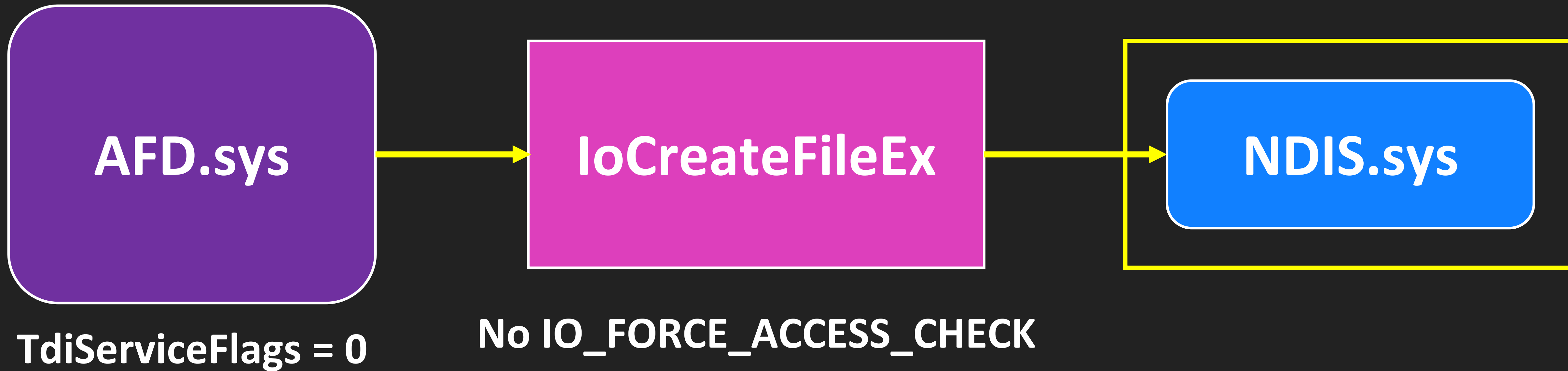
```
__int64 __fastcall AfdTdiCreateAO(...){
    Option = IO_NO_PARAMETER_CHECKING;
    if ( (EndPoint->TdiServiceFlags & TDI_SERVICE_FORCE_ACCESS_CHECK == 0 ) )
    {
        Option = IO_NO_PARAMETER_CHECKING | IO_FORCE_ACCESS_CHECK ;
    }
    ...

    ObjectAttributes.Attributes = OBJ_KERNEL_HANDLE;
    ObjectAttributes.ObjectName = &TransportInfo->TransportDeviceName;
    ...
    Status = IoCreateFileEx(
        ...
        &ObjectAttributes,
        ...
        EaBuffer,
        EaLength,
        ...
        Option,
        ... )
}
```

No IO_FORCE_ACCESS_CHECK

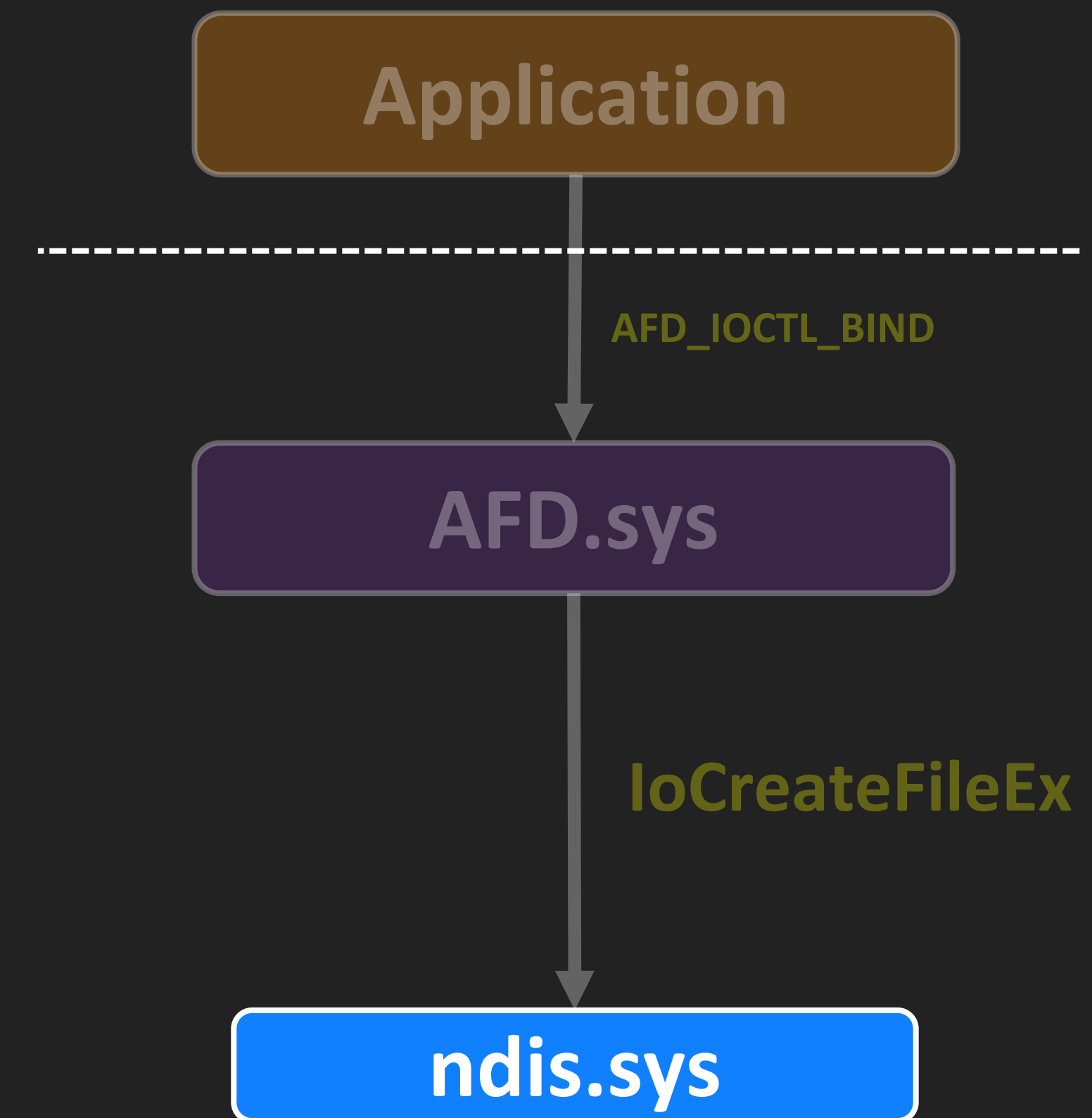
No OBJ_FORCE_ACCESS_CHECK





Ndis Access Check

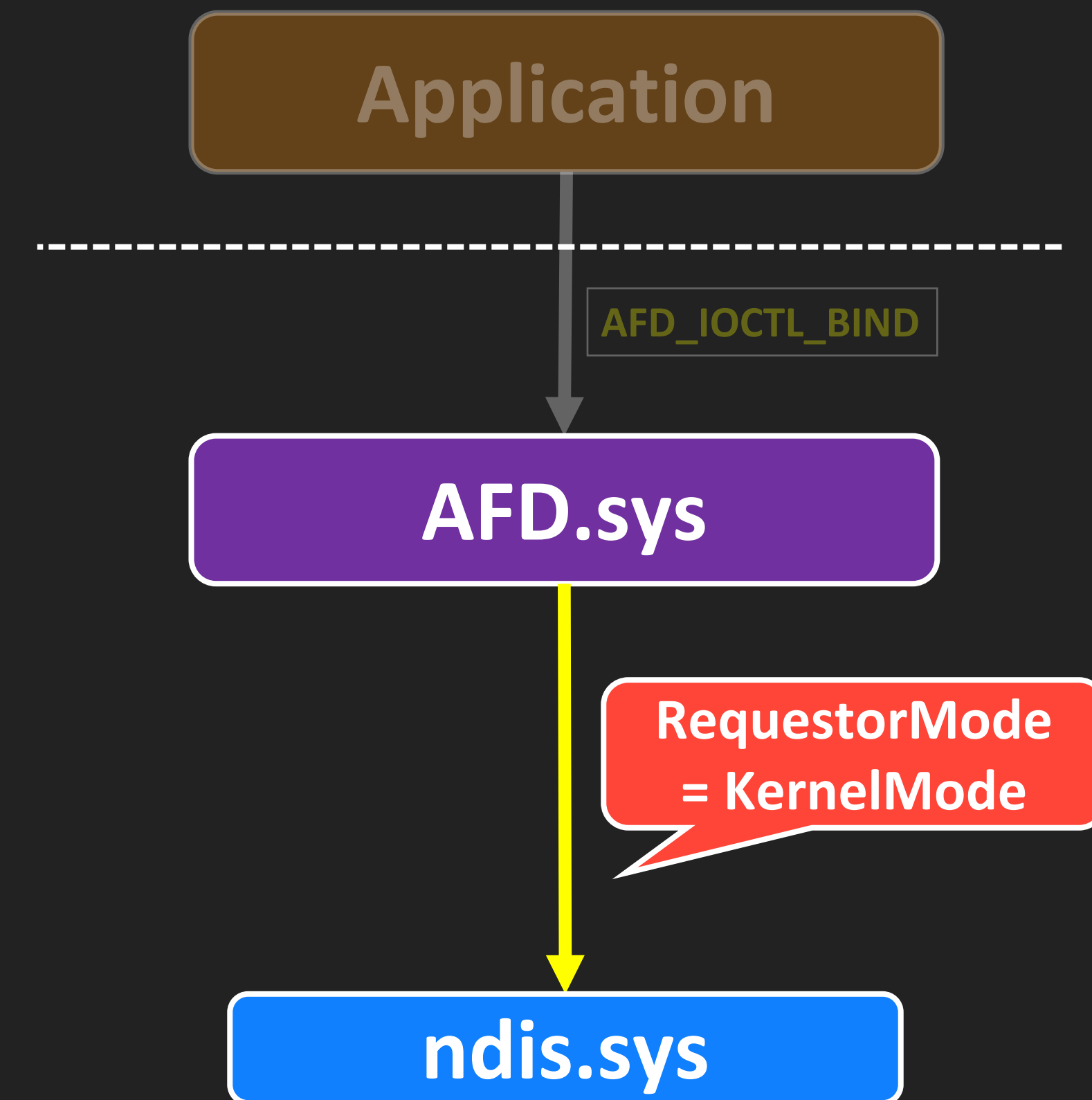
```
__int64 __fastcall ndisCheckAccess(...)  
{  
    ...  
    AccessMode = 1;  
    if ( (CurrentStackLocation->Flags & IO_FORCE_ACCESS_CHECK) == 0 )  
        AccessMode = Irp->RequestorMode;  
    is_privileged = SeAccessCheck(  
        SecurityDescriptor,  
        SubjectSecurityContext: &AccessState->SubjectSecurityContext,  
        SubjectContextLocked: 1u,  
        DesiredAccess: AccessMask,  
        PreviouslyGrantedAccess: 0,  
        Privileges: &Privileges,  
        GenericMapping,  
        AccessMode,  
        GrantedAccess: &GrantedAccess,  
        AccessStatus: &AccessStatus);  
    ...  
}
```



Ndis Access Check

```
__int64 __fastcall ndisCheckAccess(...)  
{  
    ...  
    AccessMode = 1;  
    if ( (CurrentStackLocation->Flags & IO_FORCE_ACCESS_CHECK) == 0 )  
        AccessMode = Irp->RequestorMode;  
    is_privileged = SeAccessCheck(  
        SecurityDescriptor,  
        SubjectSecurityContext: &AccessState->SubjectSecurityContext,  
        SubjectContextLocked: 1u,  
        DesiredAccess: AccessMask,  
        PreviouslyGrantedAccess: 0,  
        Privileges: &Privileges,  
        GenericMapping,  
        AccessMode,  
        GrantedAccess: &GrantedAccess,  
        AccessStatus: &AccessStatus);  
    ...  
}
```

Kernel Mode

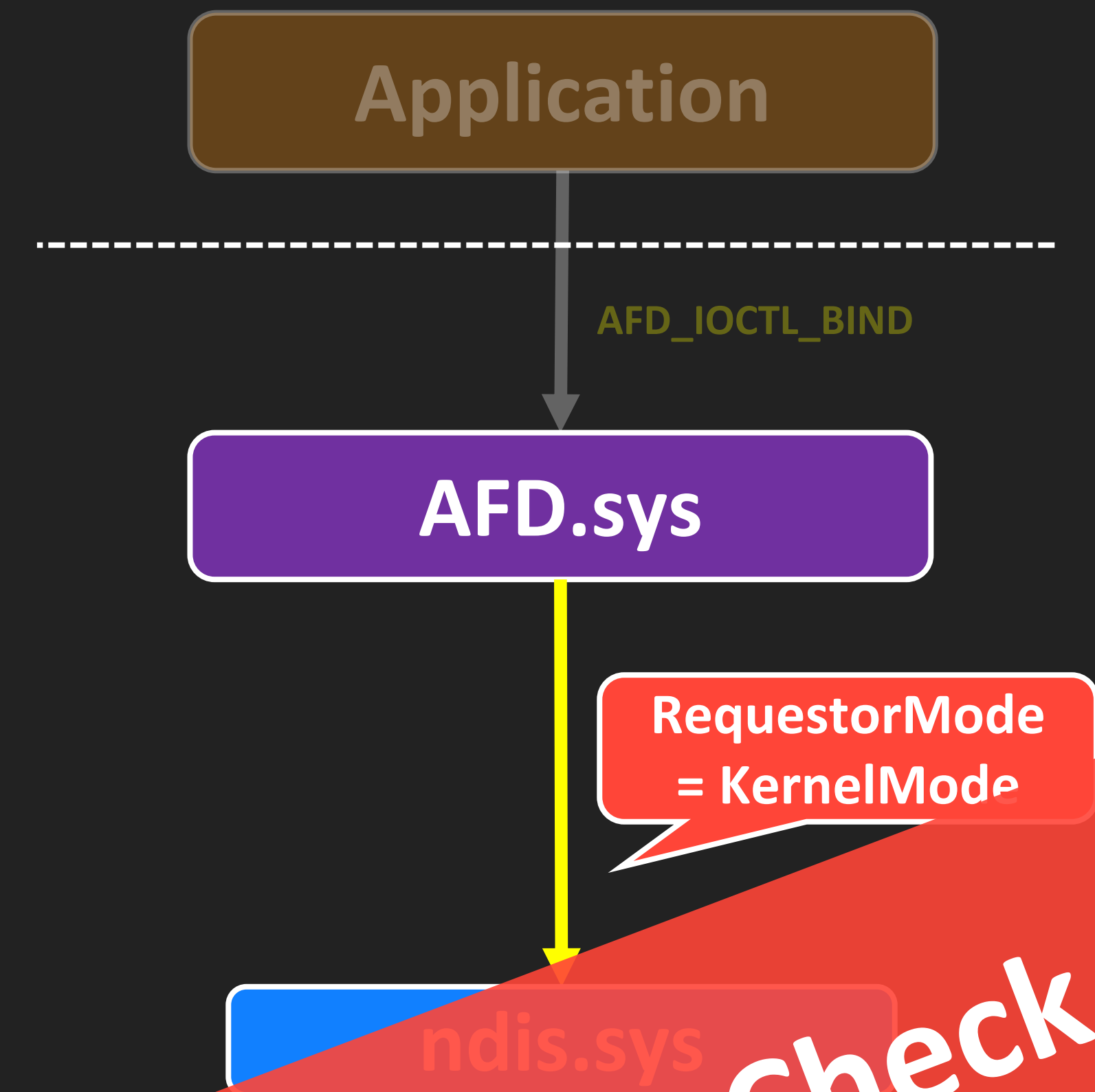


Ndis Access Check

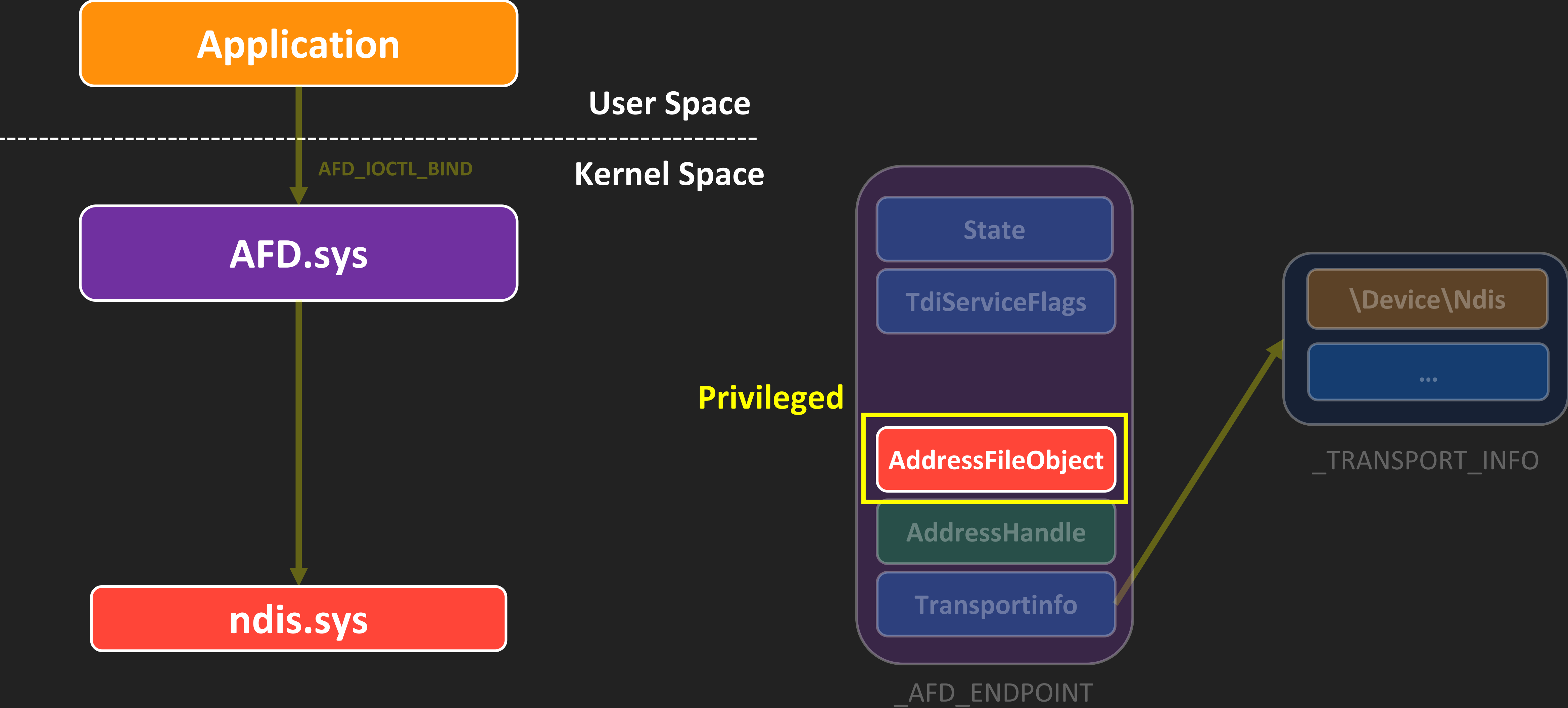
```
__int64 __fastcall ndisCheckAccess(...)  
{  
    ...  
    AccessMode = 1;  
    if ( (CurrentStackLocation->Flags & IO_FORCE_ACCESS_CHECK) == 0 )  
        AccessMode = Irp->RequestorMode;  
    is_privileged = SeAccessCheck(  
        SecurityDescriptor,  
        SubjectSecurityContext: &AccessState->SubjectSecurityContext,  
        SubjectContextLocked: 1u,  
        DesiredAccess: AccessMask,  
        PreviouslyGrantedAccess: 0,  
        Privileges: &Privileges,  
        GenericMapping,  
        AccessMode,  
        GrantedAccess: &GrantedAccess,  
        AccessStatus: &AccessStatus);  
    ...  
}
```

Kernel Mode

Bypass Access Check



Ndis Binding



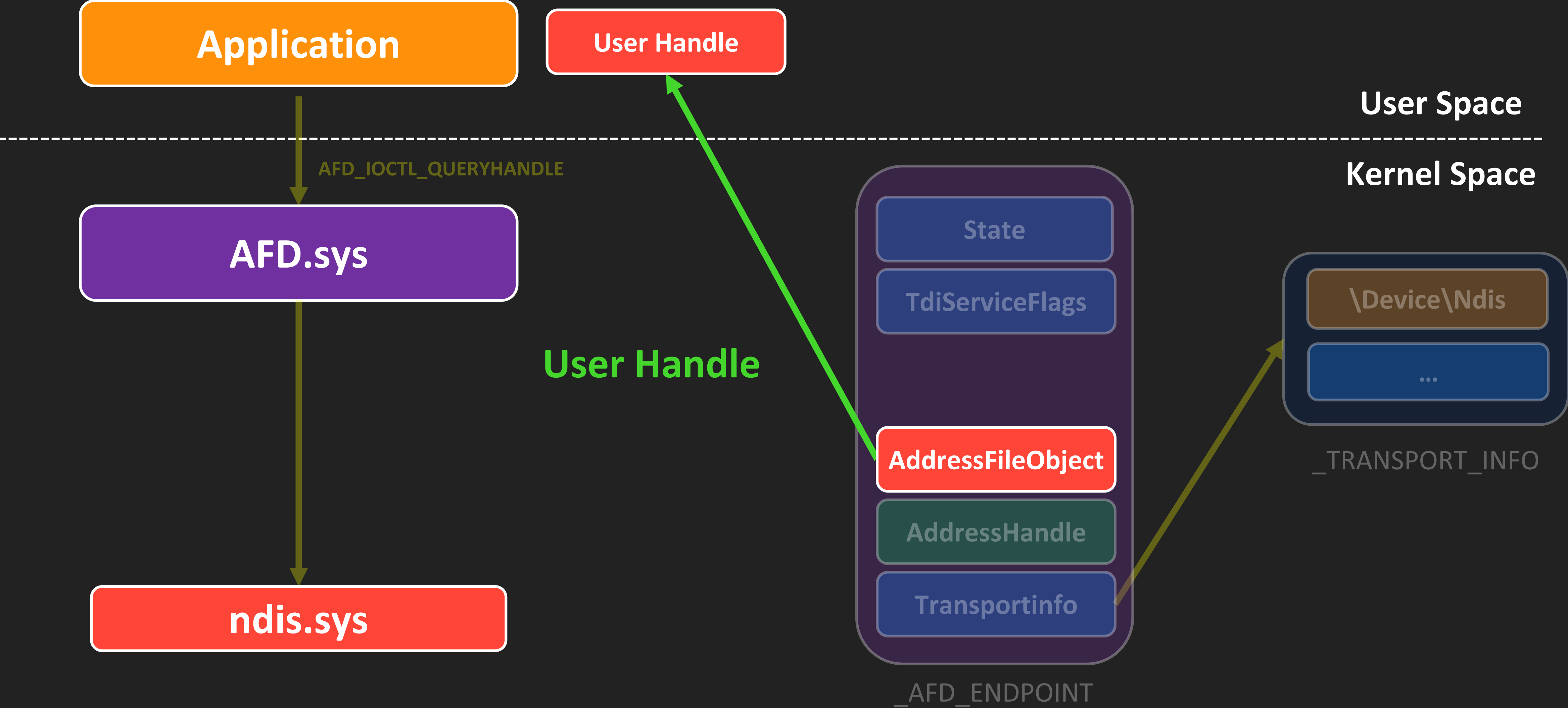
AfdQueryHandles

AfdQueryHandles

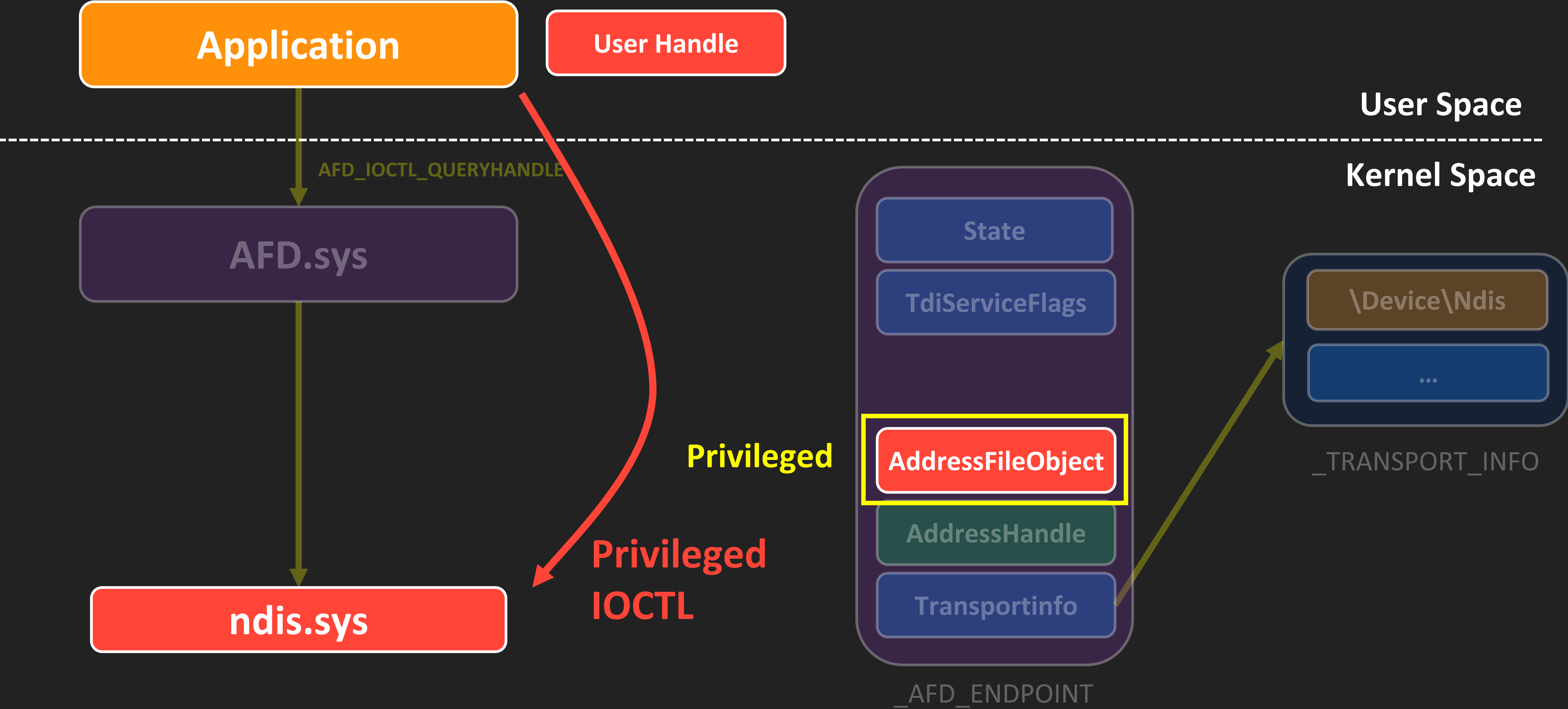
- Convert **EndPoint->AddressFileObject** into a **user handle** and return it to the user

```
ObOpenObjectByPointer(  
    Object: EndPoint->AddressFileObject,  
    HandleAttributes: 0x40u,  
    PassedAccessState: 0,  
    DesiredAccess: 0x20000000u,  
    ObjectType: (POBJECT_TYPE)IoFileObjectType,  
    AccessMode: (EndPoint->TdiServiceFlags & TDI_SERVICE_FORCE_ACCESS_CHECK) != 0 ? AccessMode : 0,  
    Handle: Output);
```

AfdQueryHandles



AfdQueryHandles



Vulnerabilities

- **netbt.sys**
 - **CVE-2025-55230**
 - **CVE-2025-47996**
- **ndis.sys**
 - **CVE-2025-55679**
 - **CVE-2025-55339**

Windows Kernel Logic Bug Class: Access Mode Mismatch in IO Manager

2019-MAR-14

James Forshaw

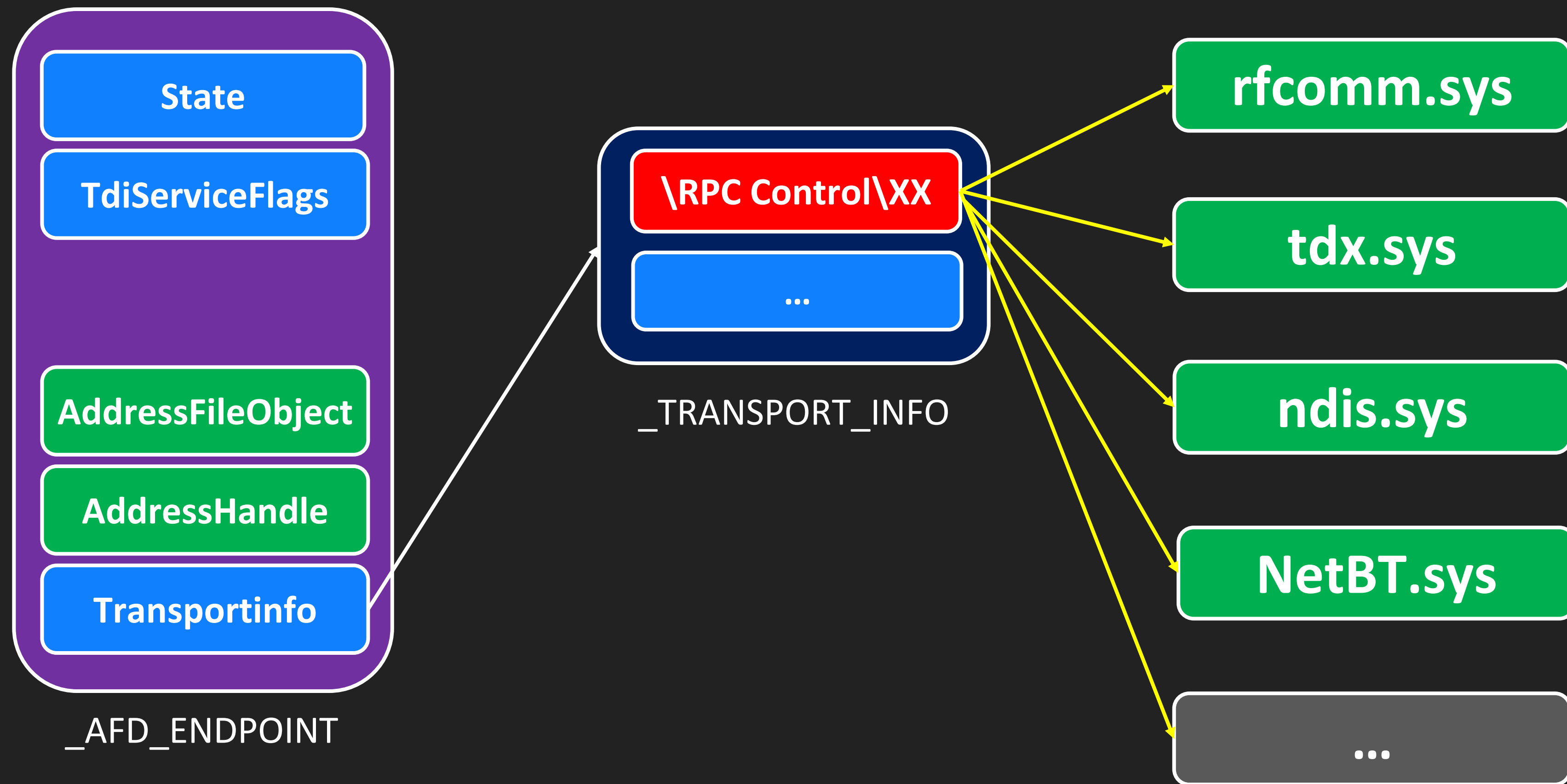
<https://googleprojectzero.blogspot.com/2019/03/windows-kernel-logic-bug-class-access.html>

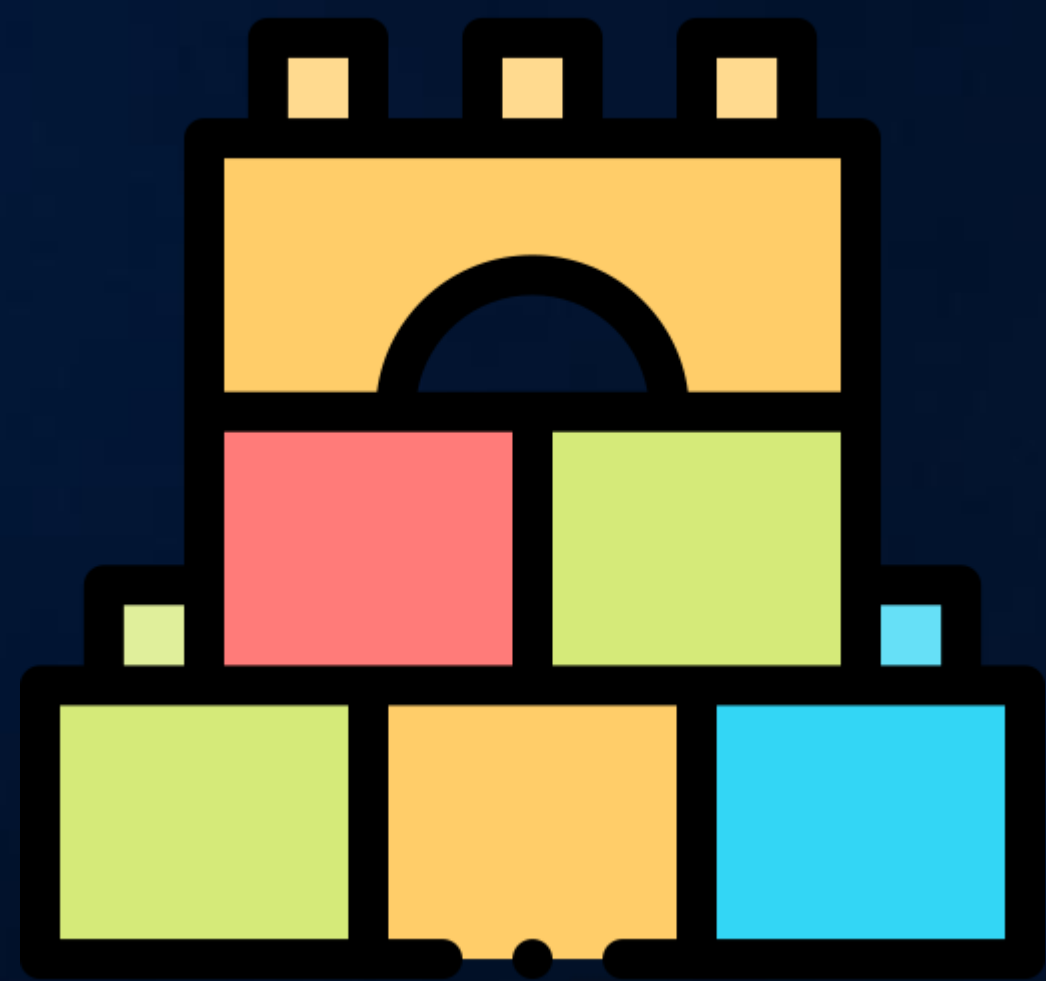


Object Manager Symbolic Links



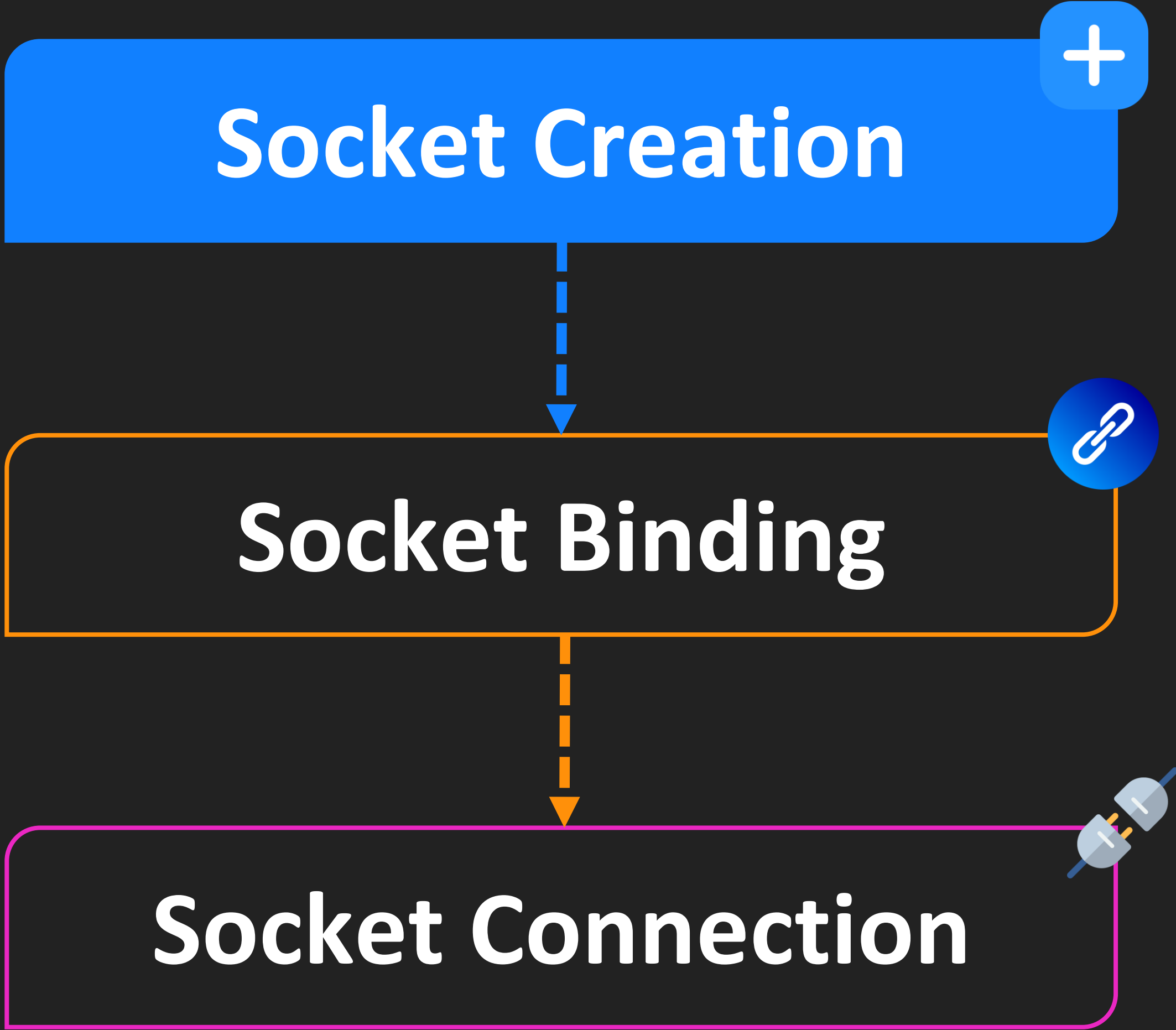
Symbolic Links



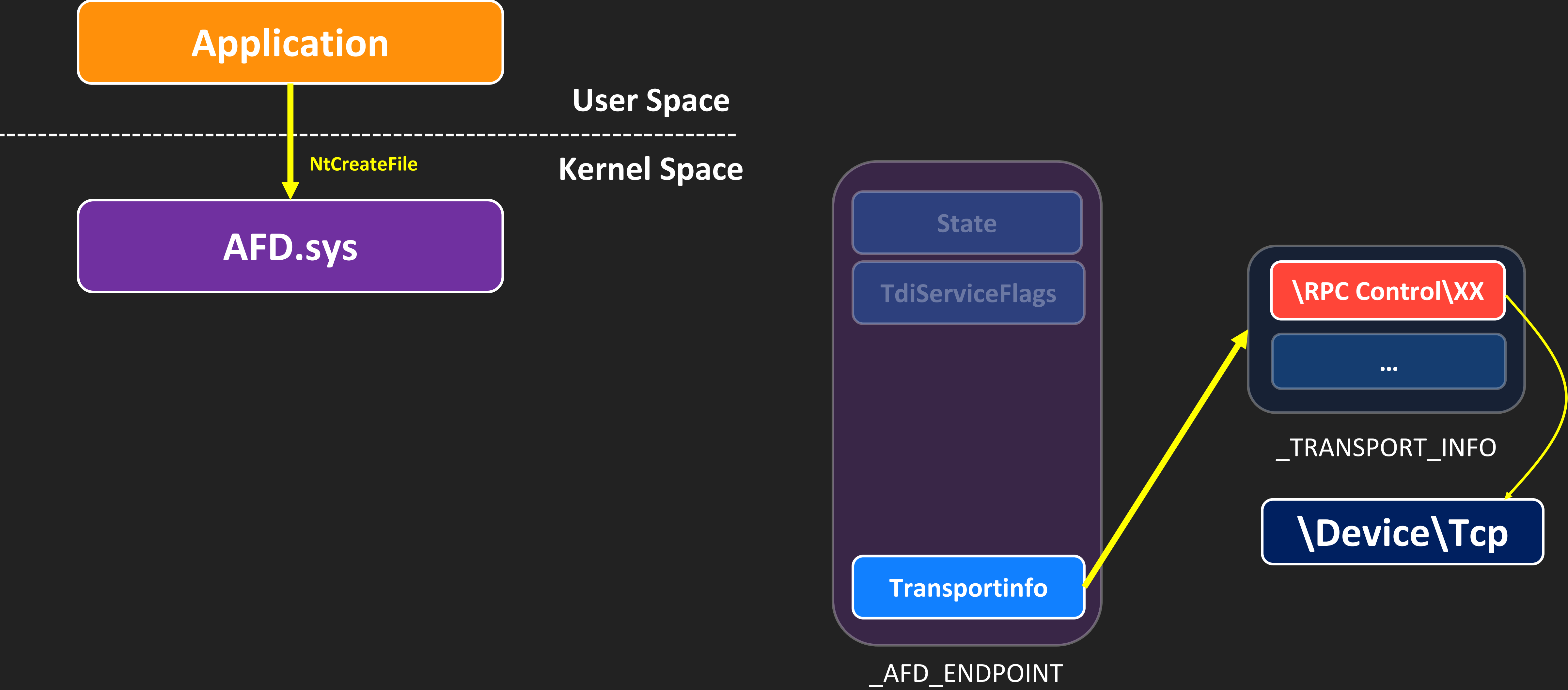


Assembling Vulnerabilities

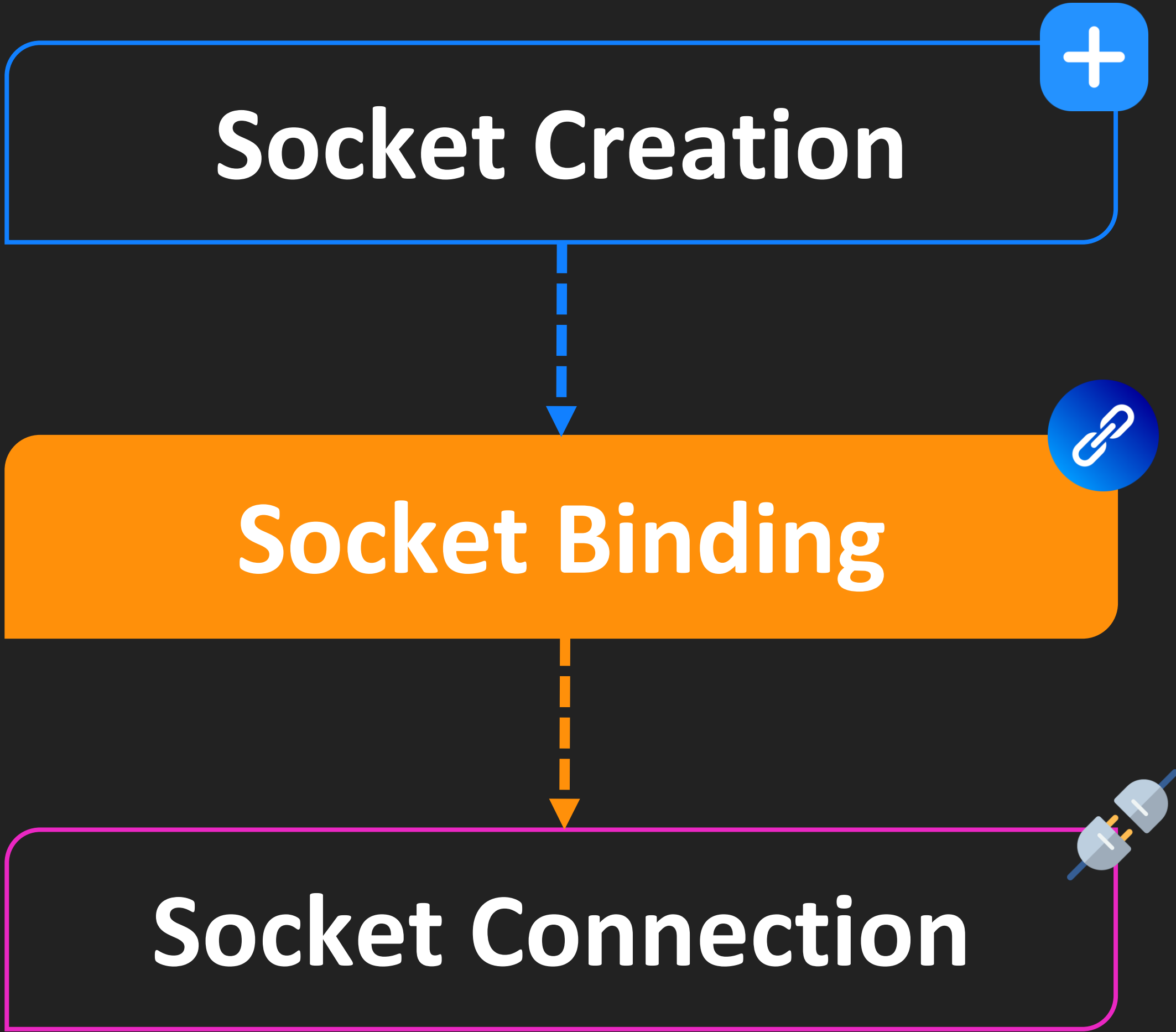
Socket Workflow



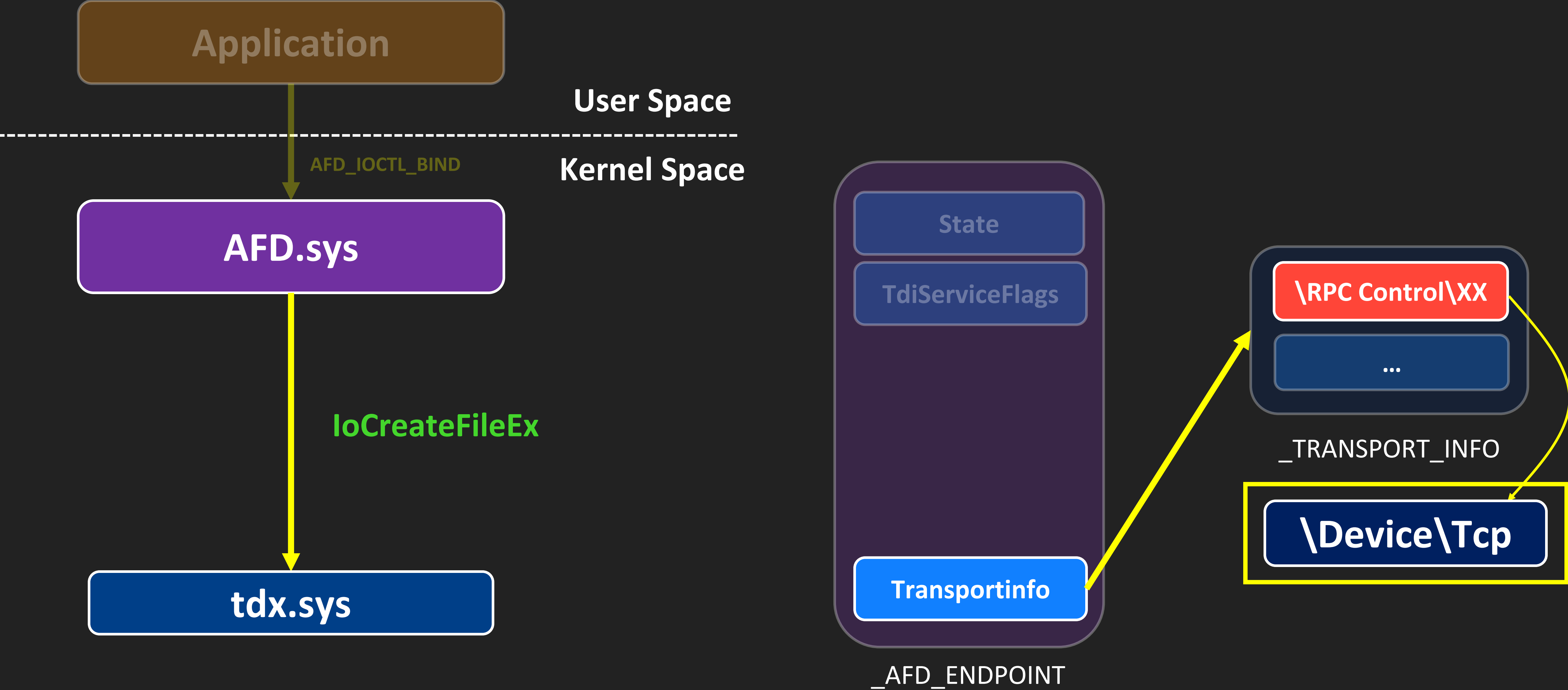
Socket Creation



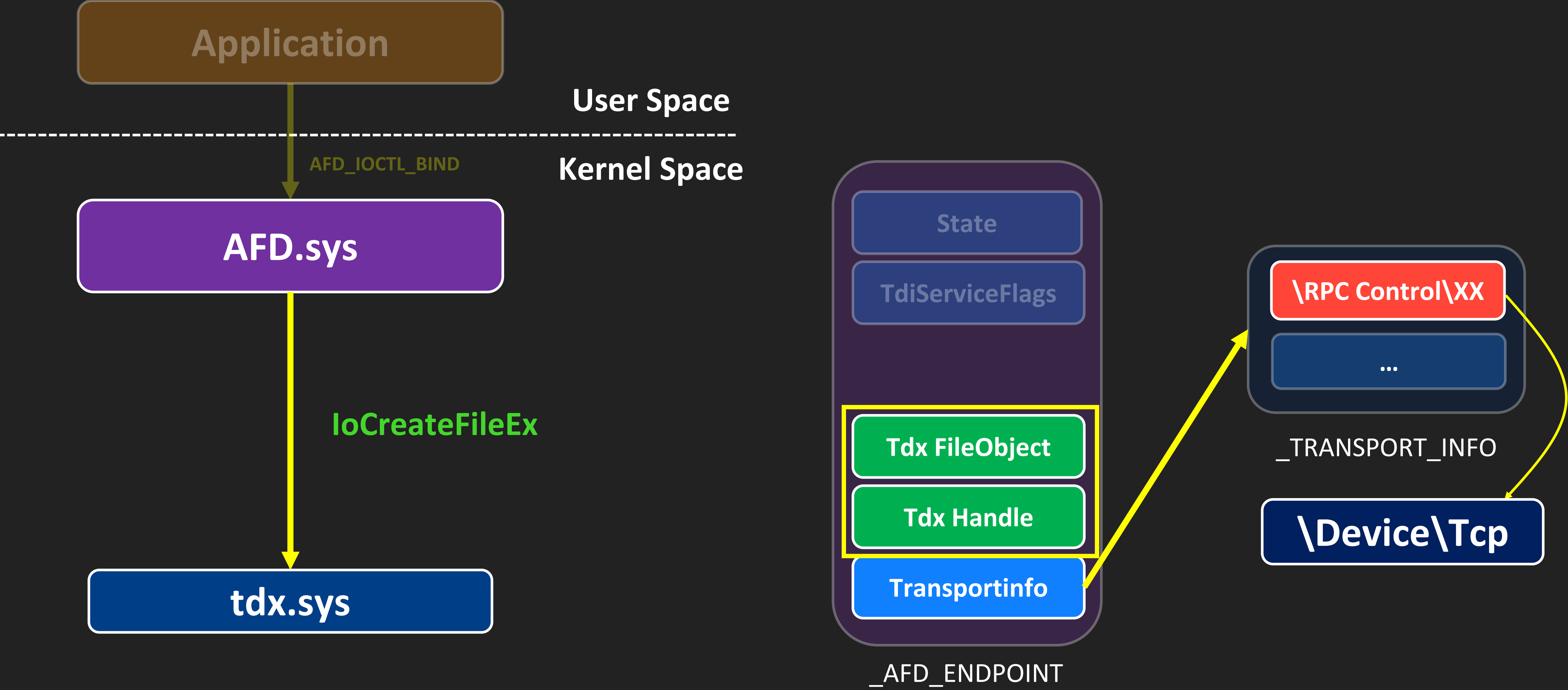
Socket Workflow



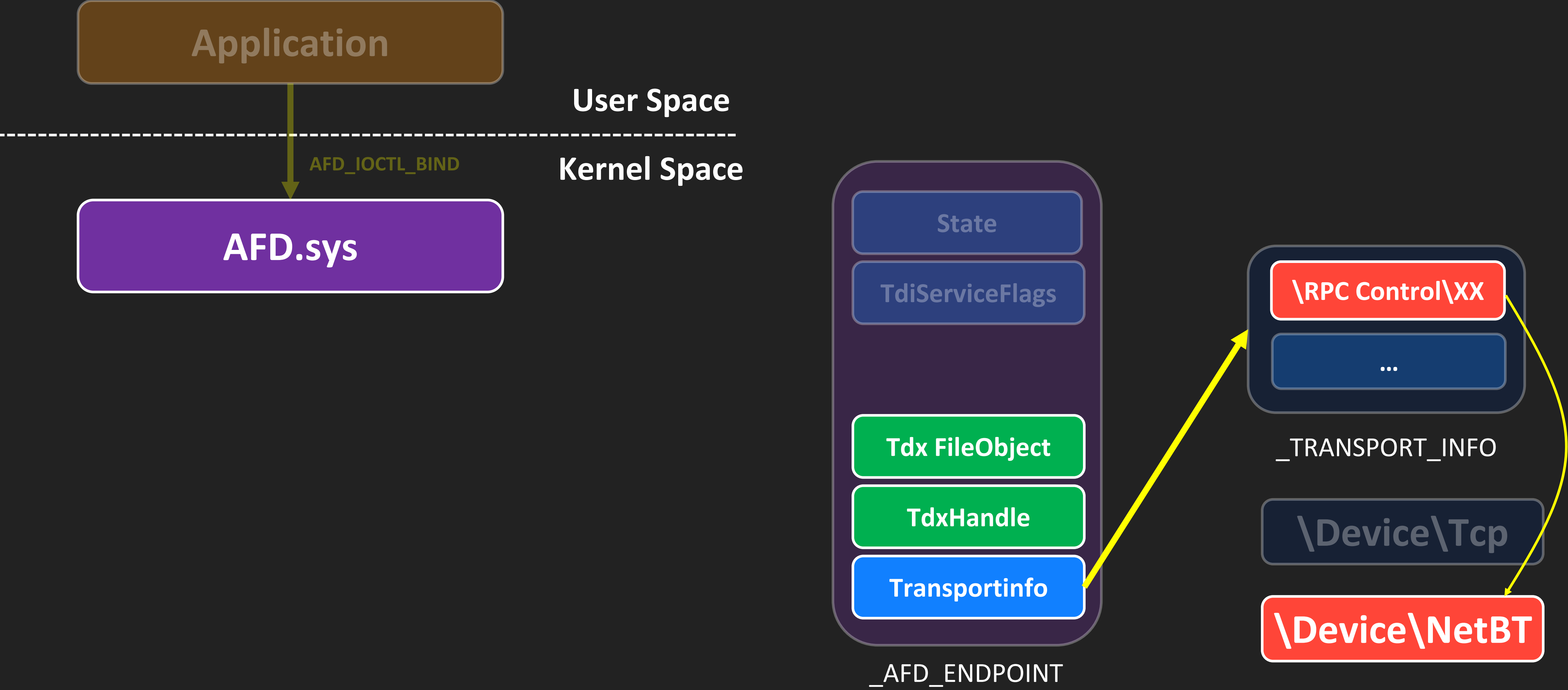
Socket Binding



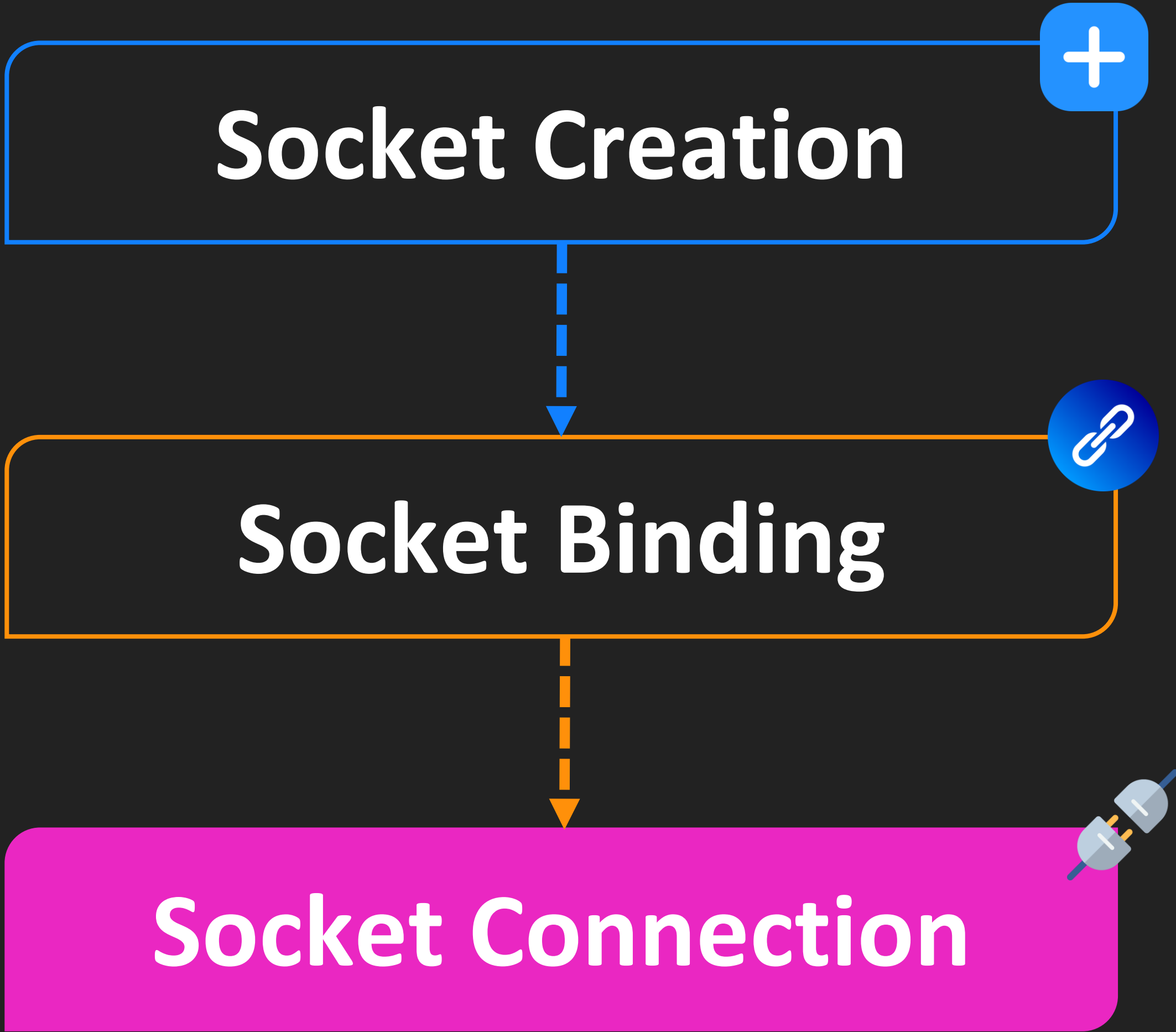
Socket Binding



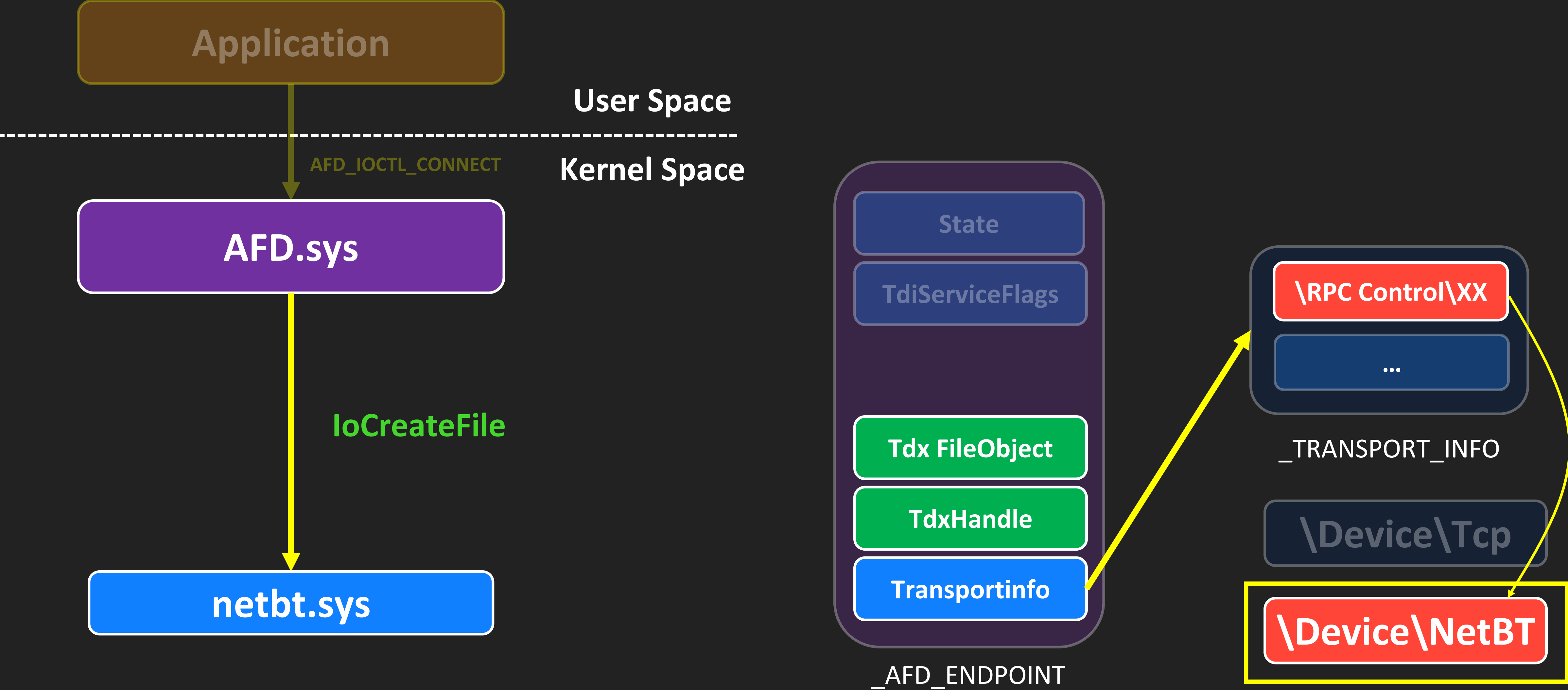
Repoint to NetBT



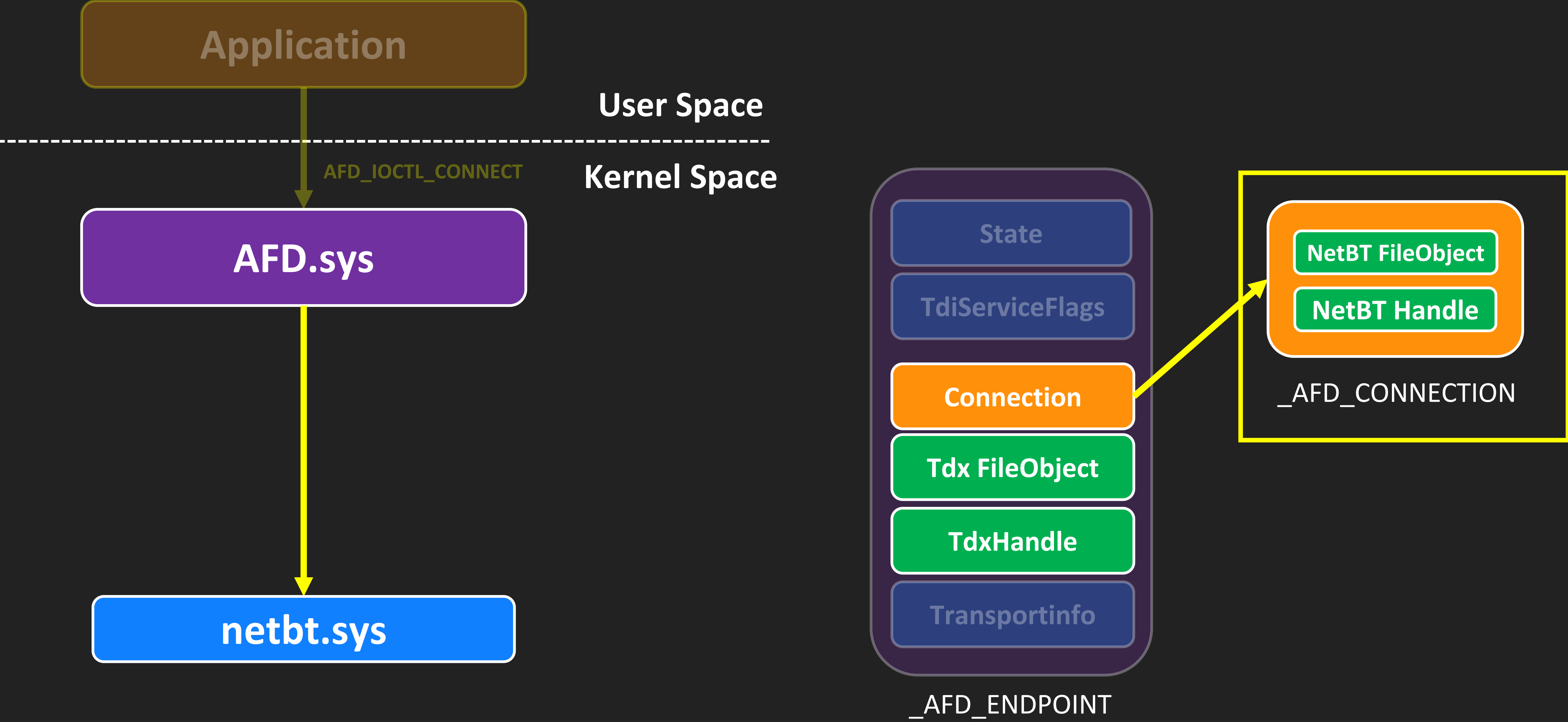
Socket Workflow



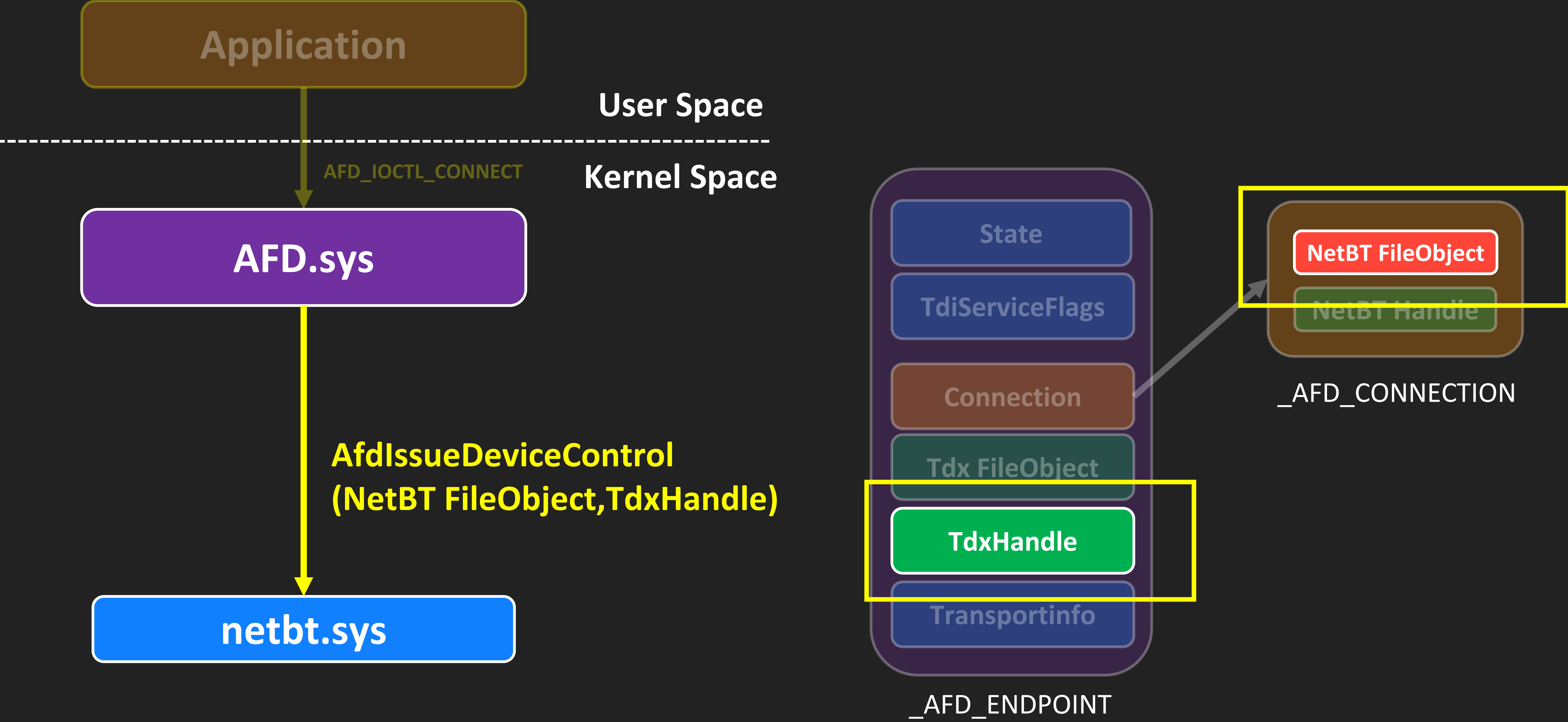
Socket Connection



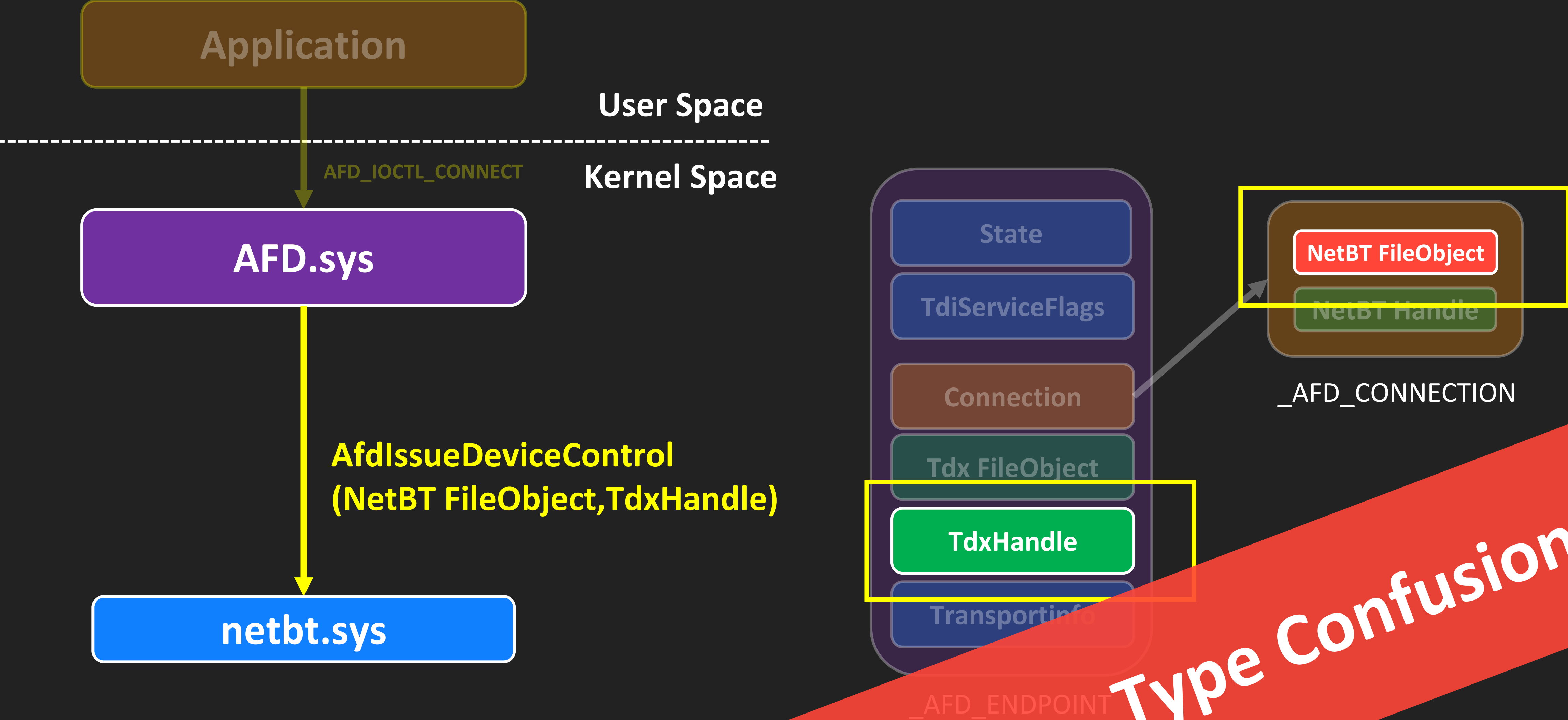
Socket Connection



Socket Connection



CVE-2026-20860



Could they lead to more **logic vulnerabilities**?



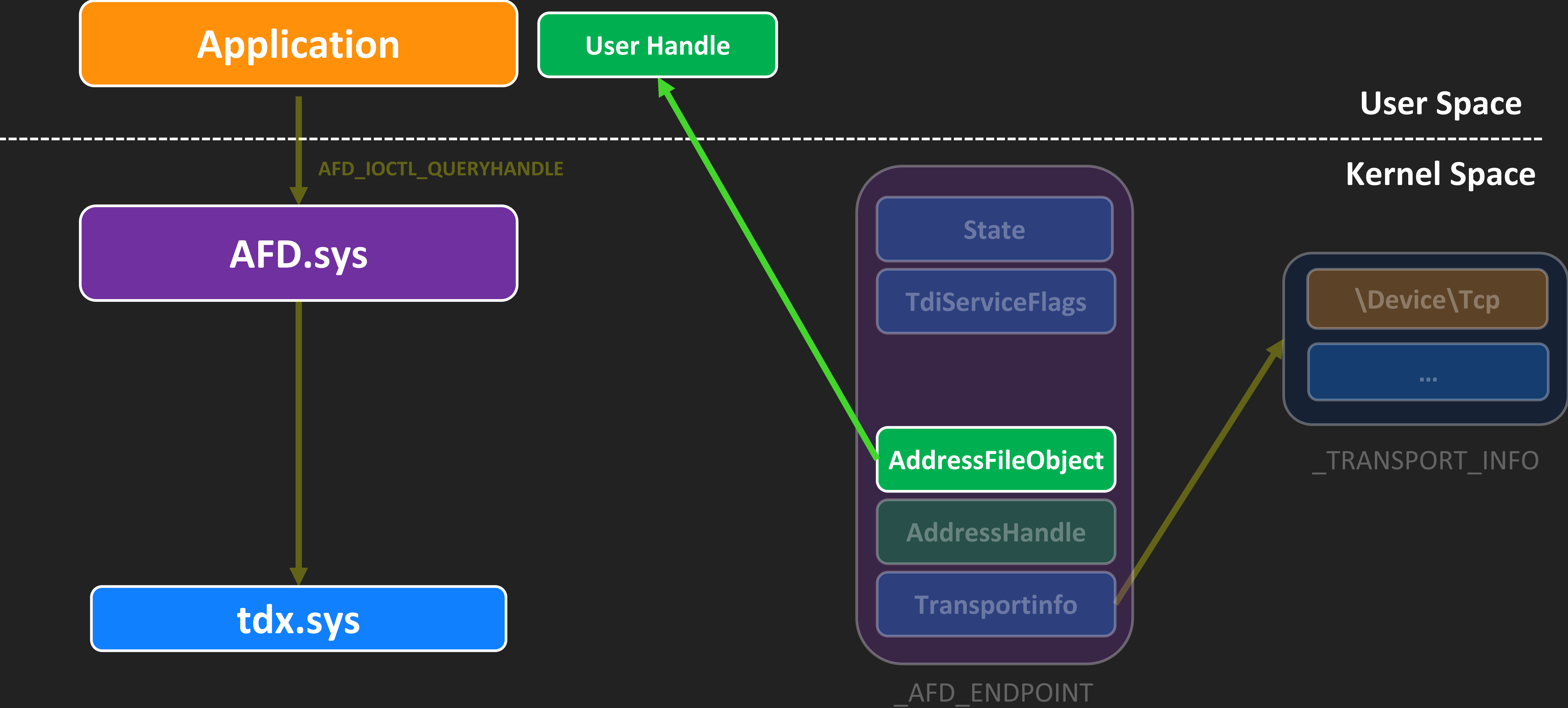
Could they lead to more **logic vulnerabilities**?



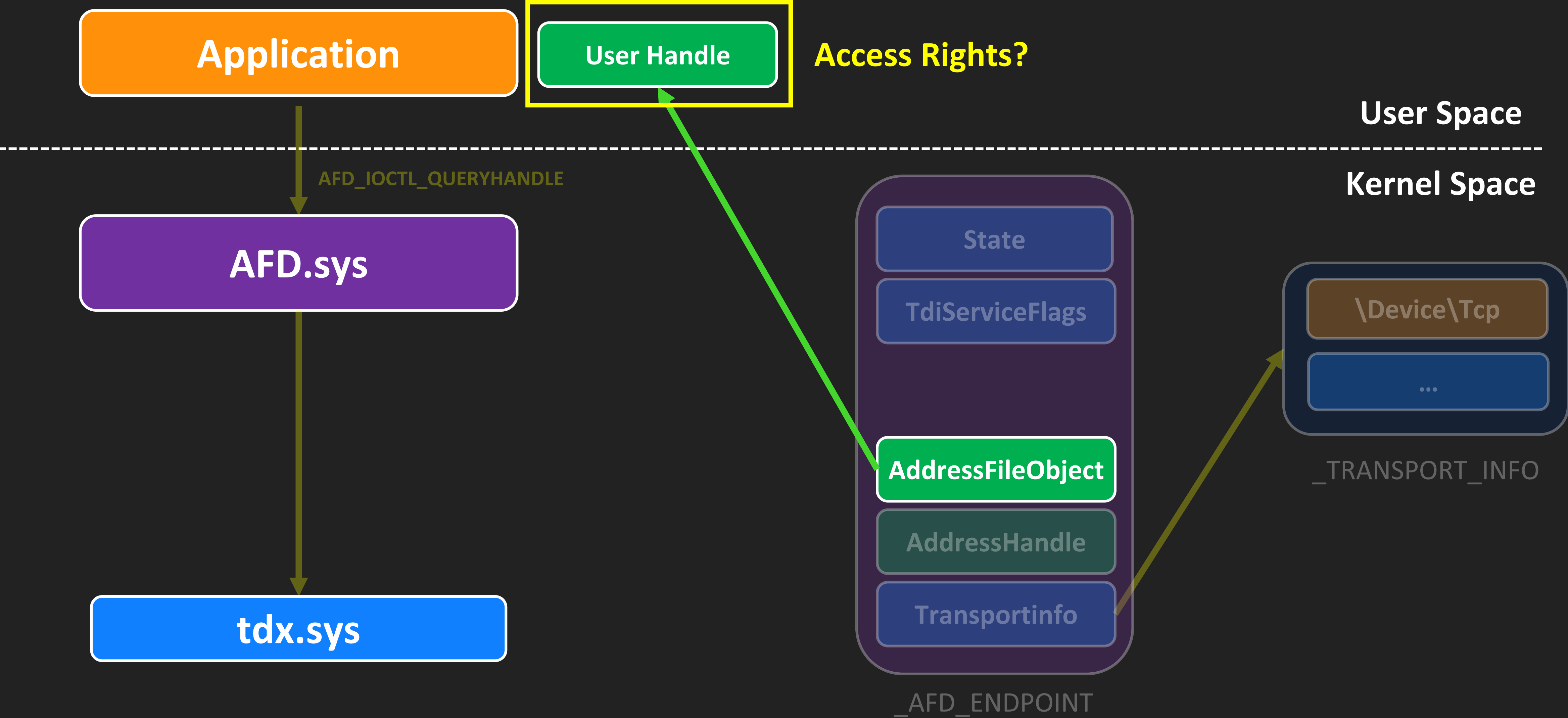


AfdQueryHandles **Revisited**

AfdQueryHandles



AfdQueryHandles



AfdQueryHandles

- Convert **EndPoint->AddressFileObject** into a **user handle** and return it to the user

```
ObOpenObjectByPointer(  
    Object: EndPoint->AddressFileObject,  
    HandleAttributes: 0x40u,  
    PassedAccessState: 0, MAXIMUM_ALLOWED  
    DesiredAccess: 0x20000000u,  
    ObjectType: (POBJECT_TYPE)IoFileObjectType,  
    AccessMode: (EndPoint->TdiServiceFlags & TDI_SERVICE_FORCE_ACCESS_CHECK) != 0 ? AccessMode : 0,  
    Handle: Output);
```

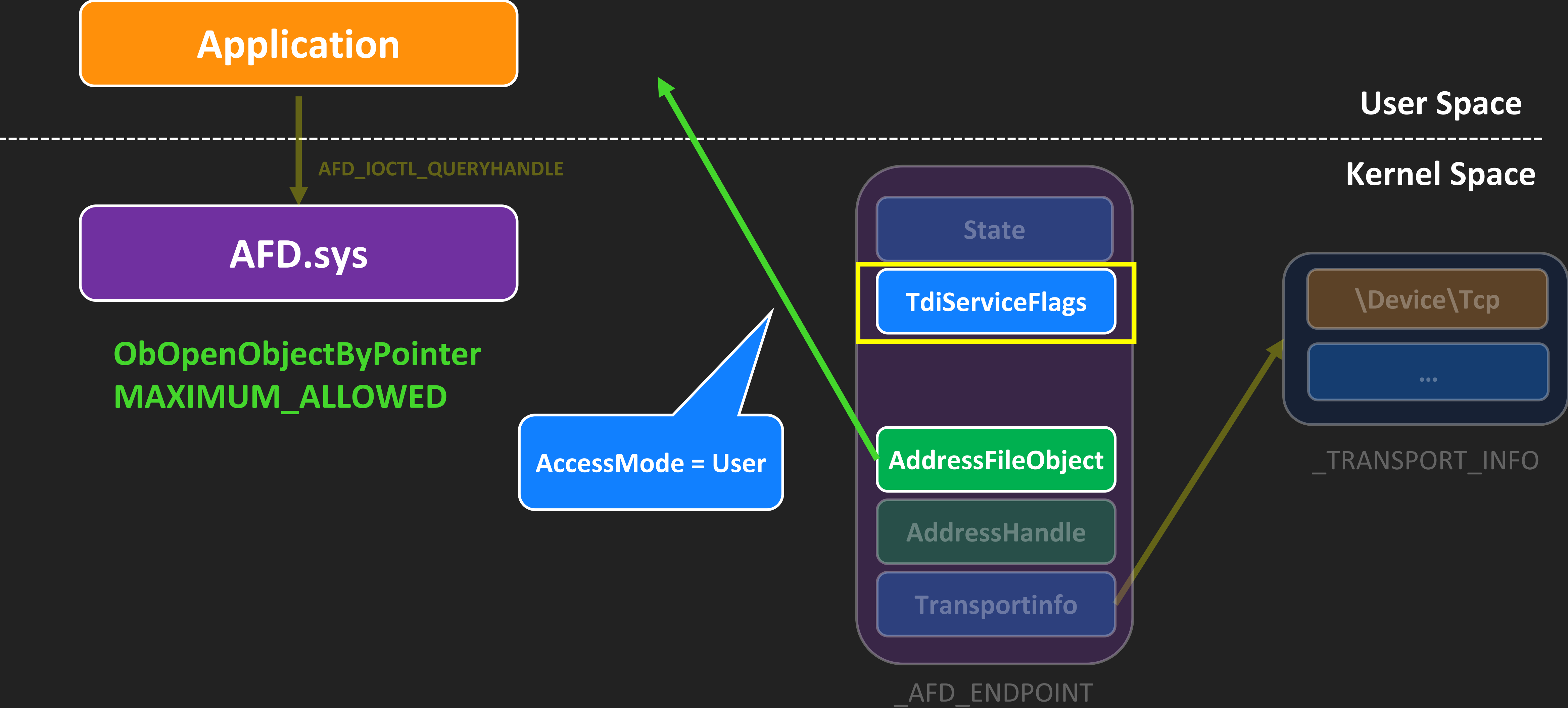
AfdQueryHandles

- Convert **EndPoint->AddressFileObject** into a **user handle** and return it to the user

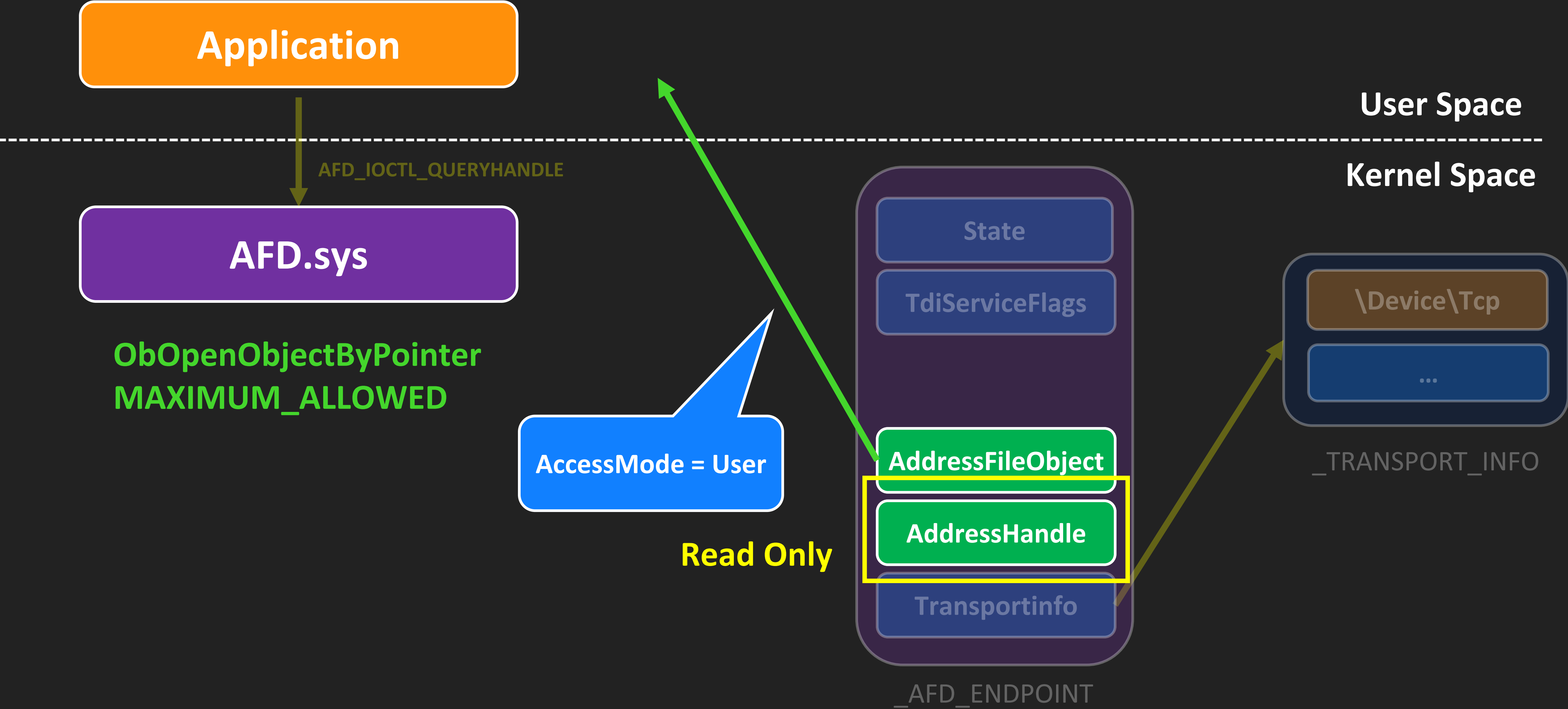
```
ObOpenObjectByPointer(  
    Object: EndPoint->AddressFileObject,  
    HandleAttributes: 0x40u,  
    PassedAccessState: 0,  
    DesiredAccess: 0x20000000u,  
    ObjectType: (POBJECT_TYPE)IoFileObjectType,  
    AccessMode: (EndPoint->TdiServiceFlags & TDI_SERVICE_FORCE_ACCESS_CHECK) != 0 ? AccessMode : 0,  
    Handle: Output);
```

AccessMode =
UserMode or **KernelMode**

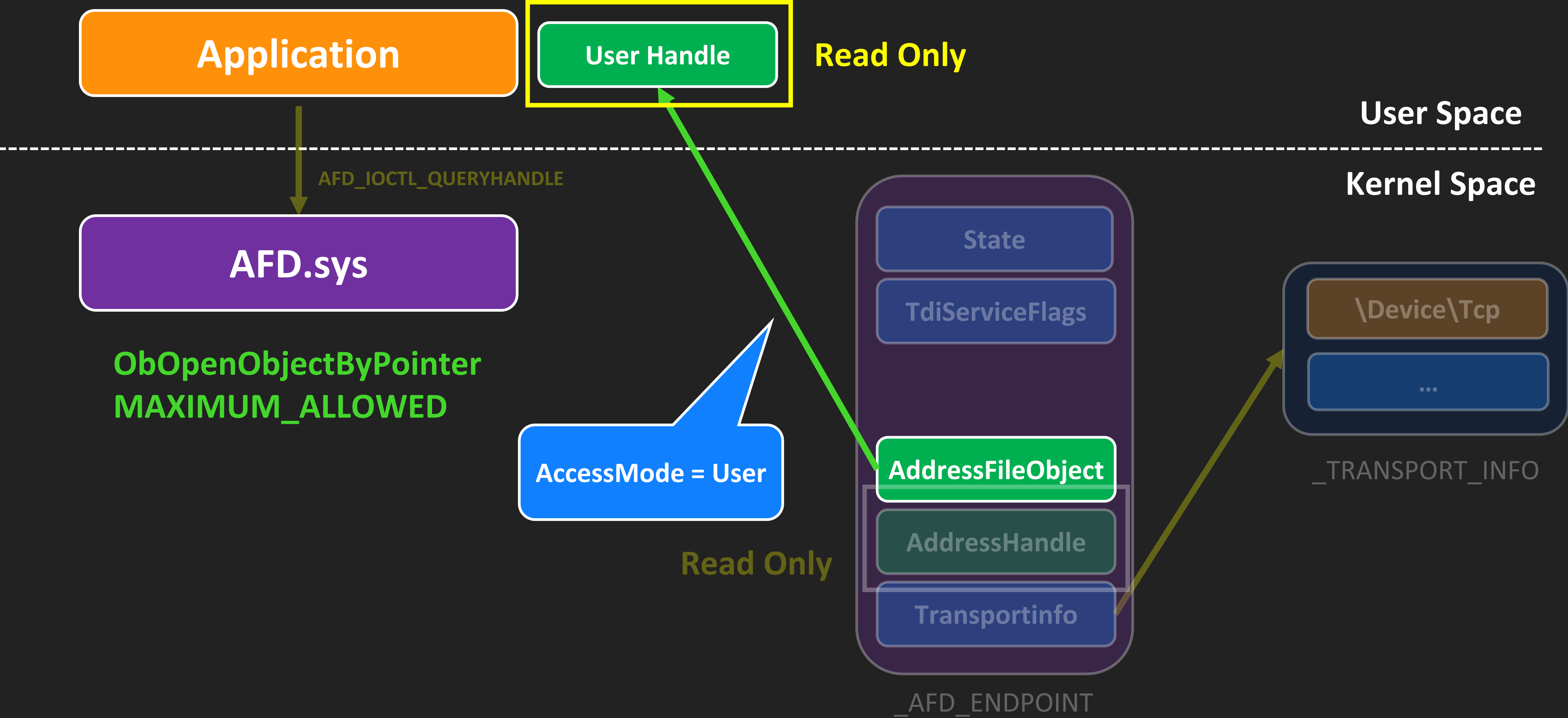
AfdQueryHandles



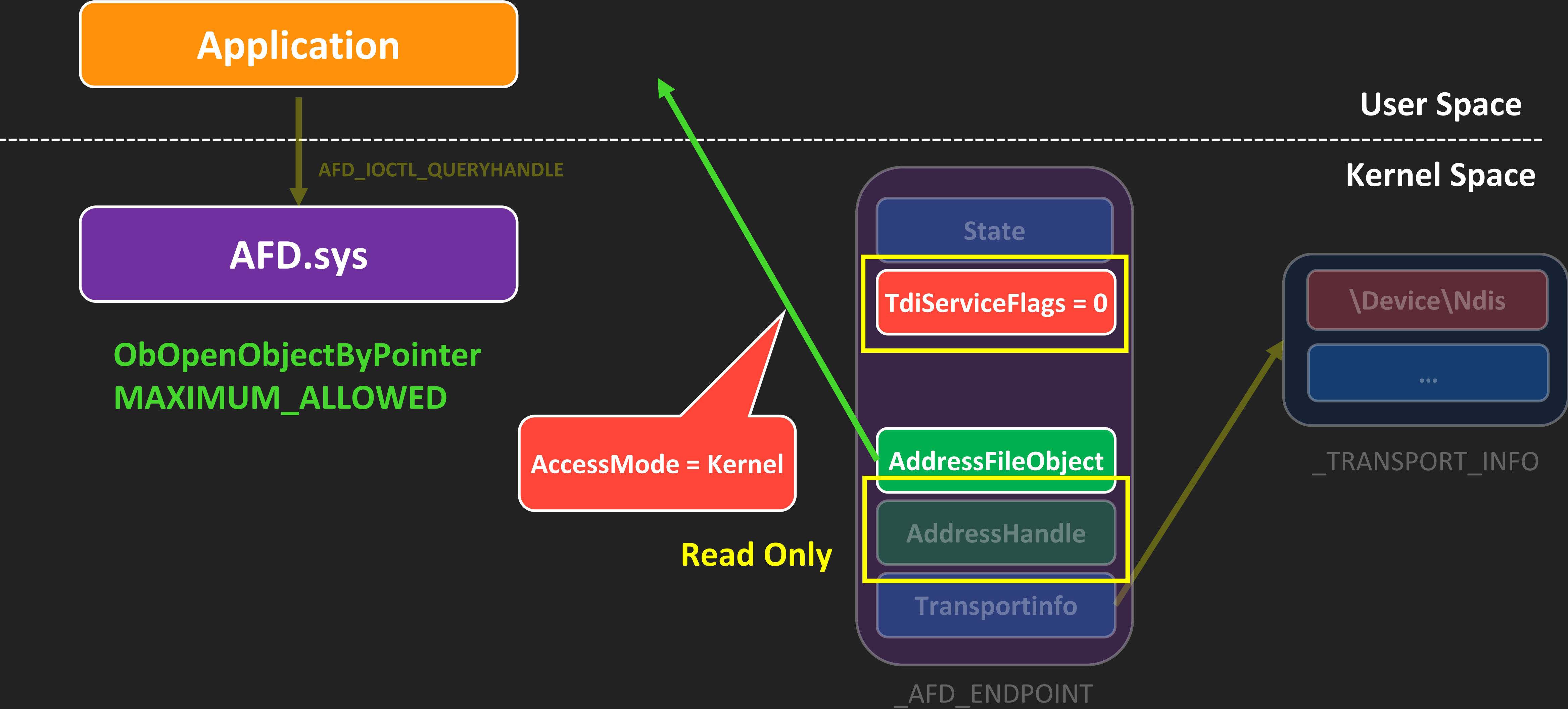
AfdQueryHandles



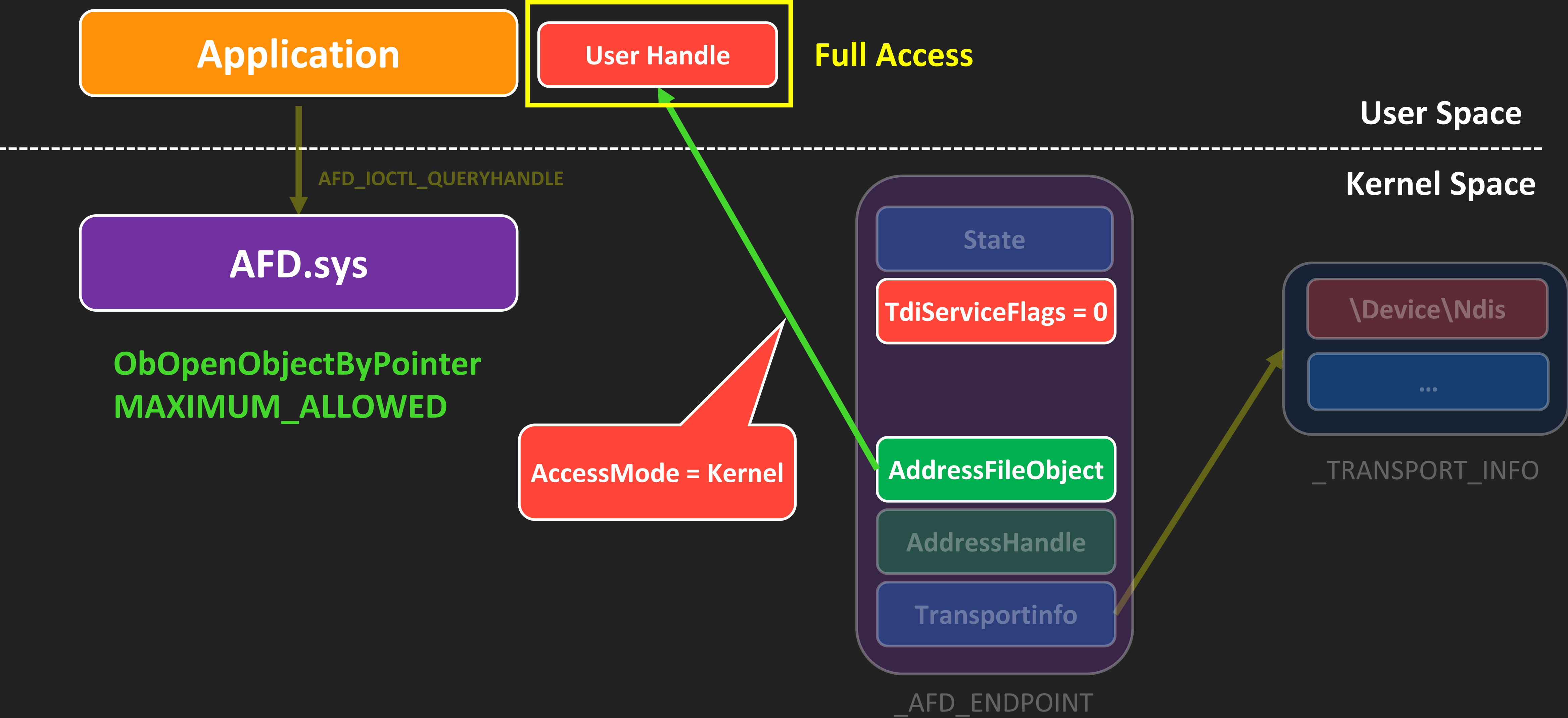
AfdQueryHandles



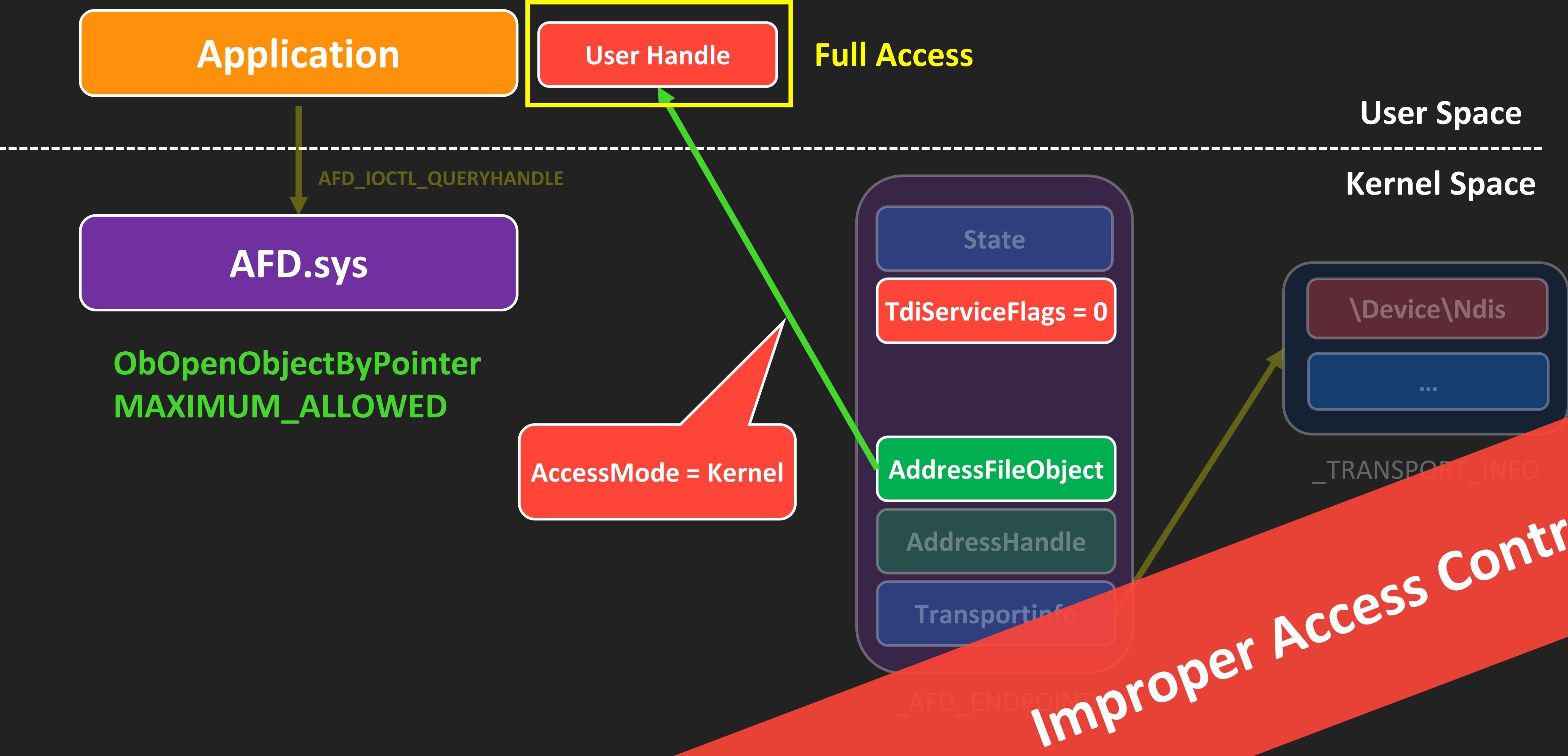
AfdQueryHandles



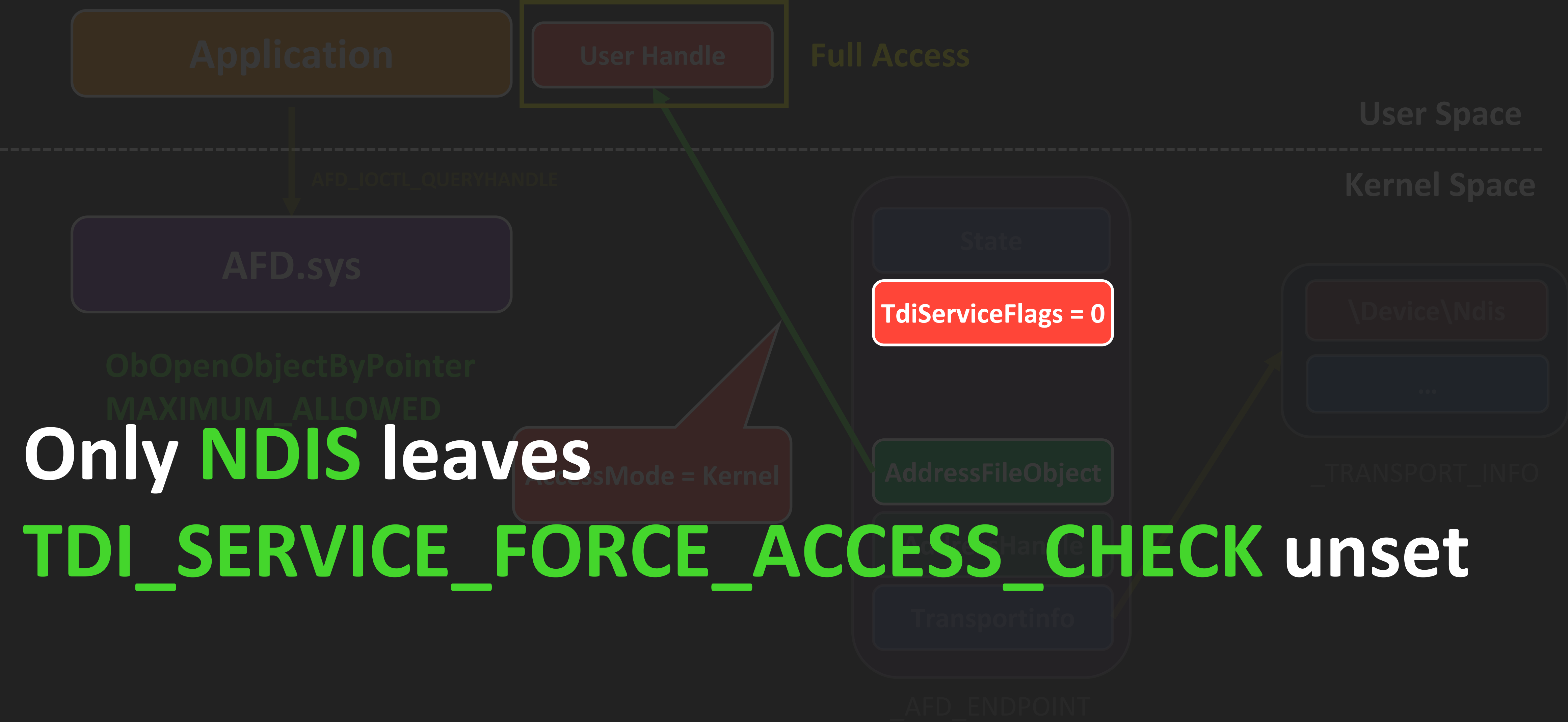
AfdQueryHandles



AfdQueryHandles



AfdQueryHandles



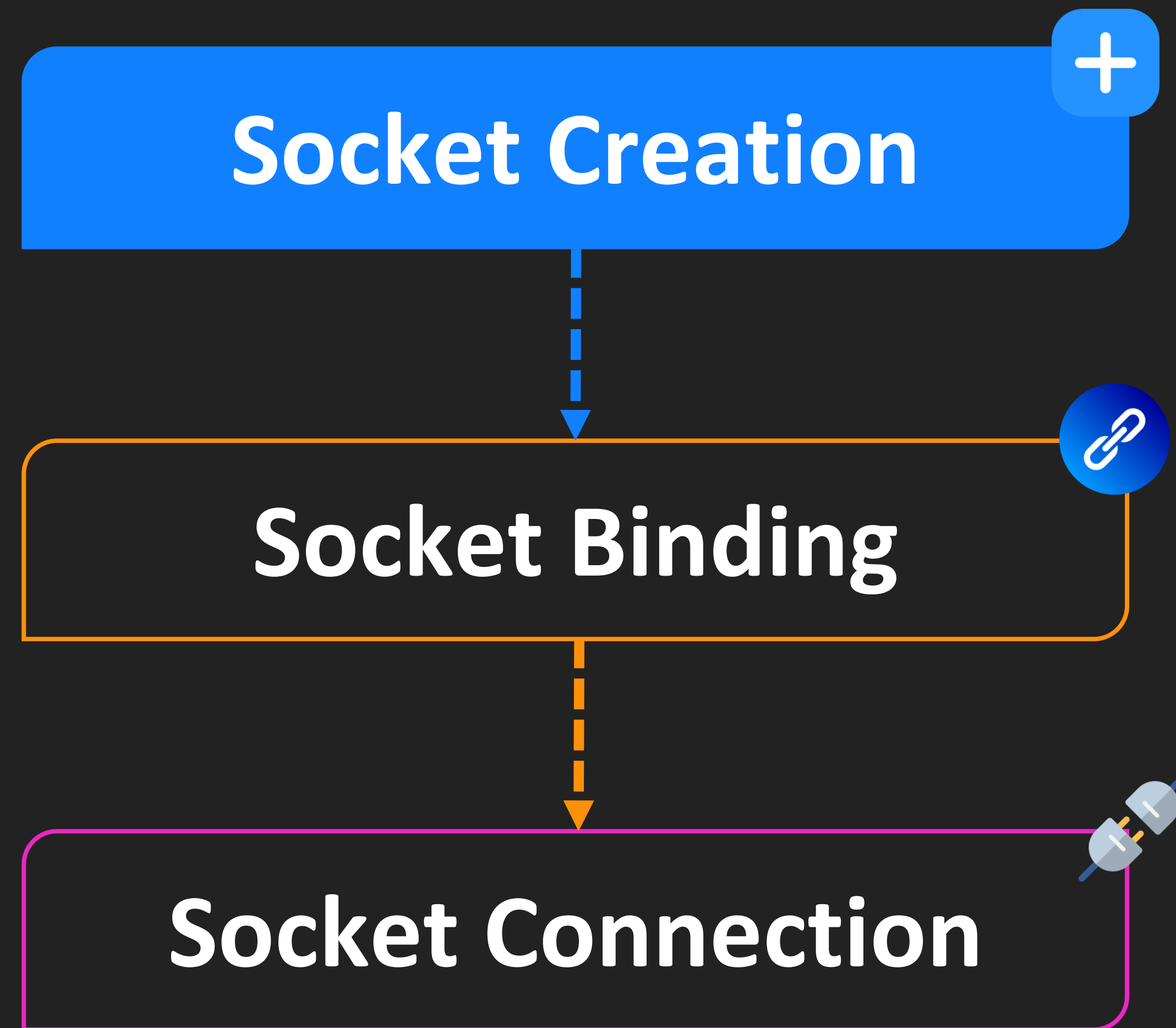




Object Manager Symbolic Links

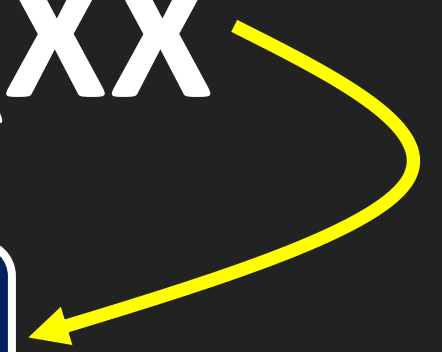


Socket Workflow

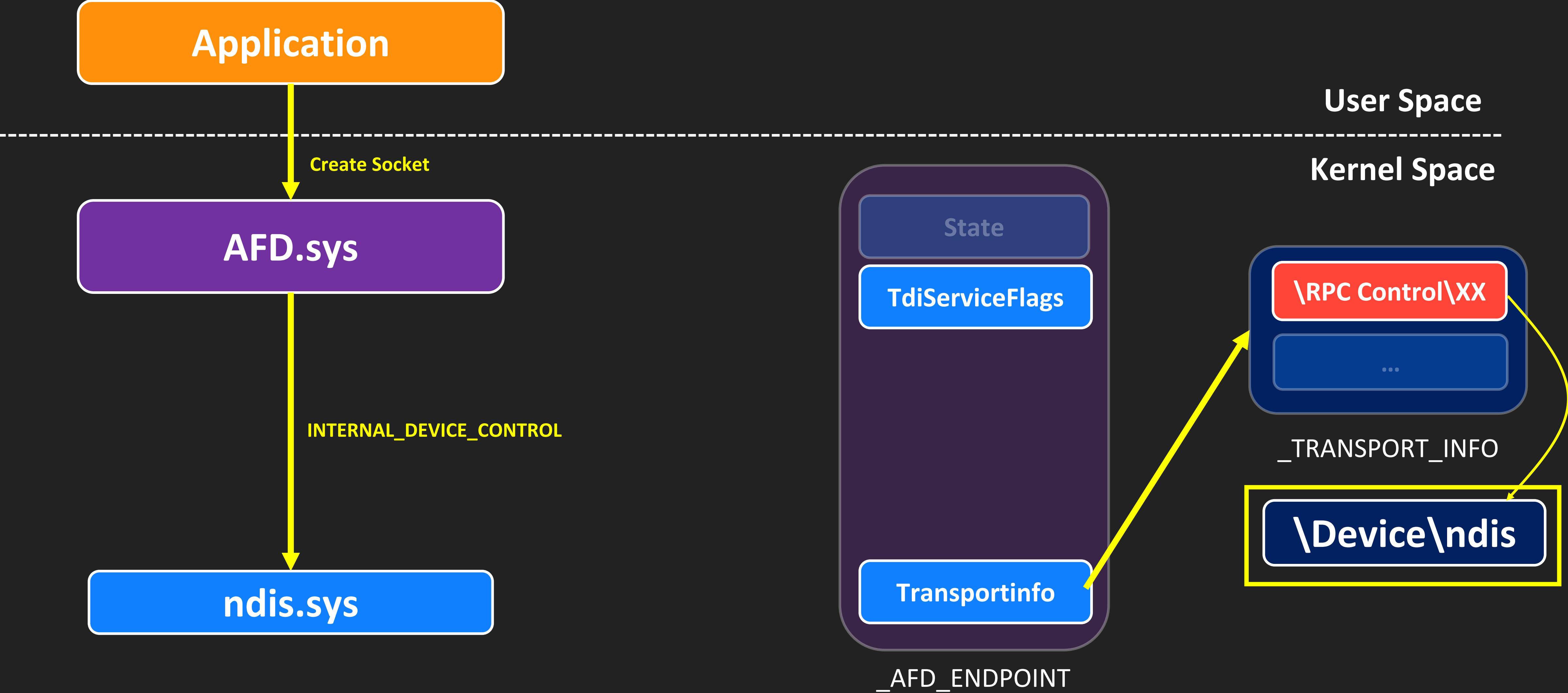


`\RPC Control\XX`

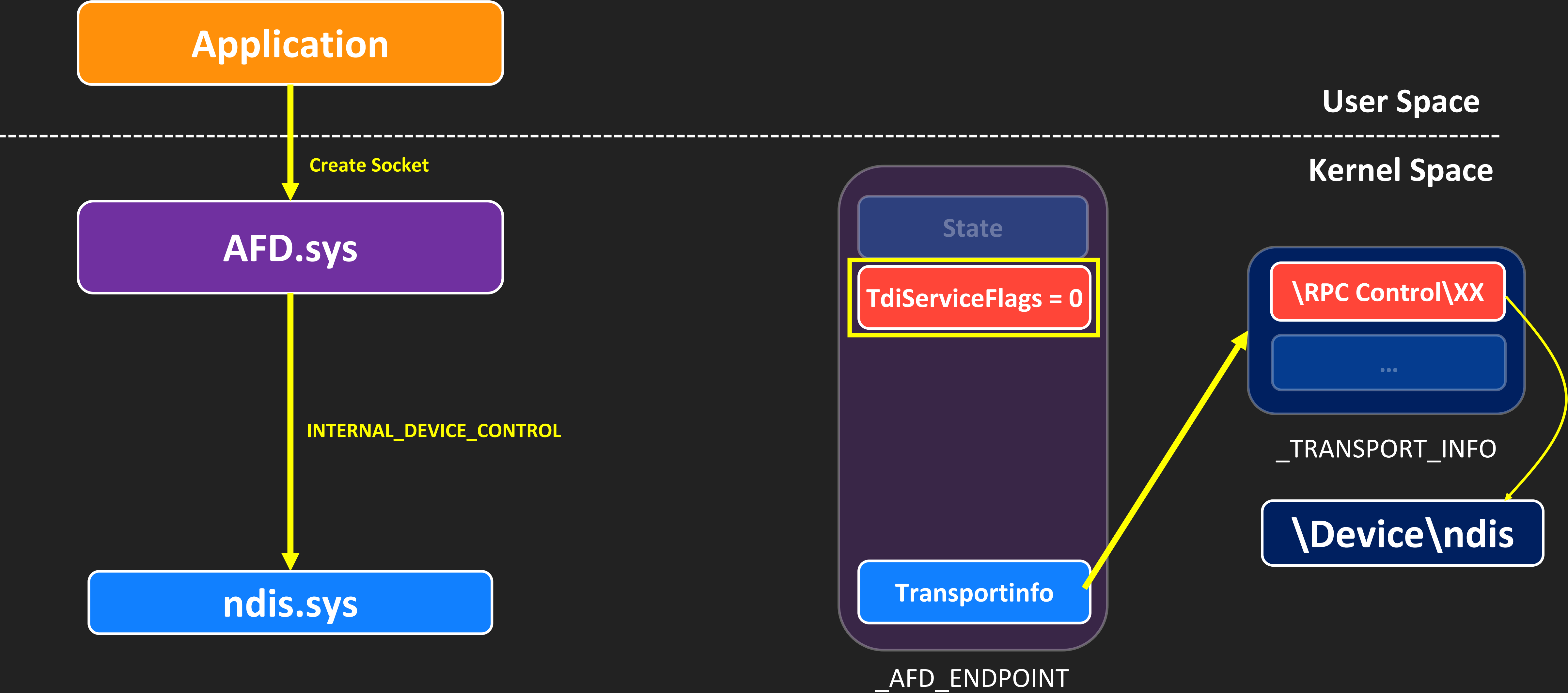
`\Device\ndis`



Socket Creation



Socket Creation

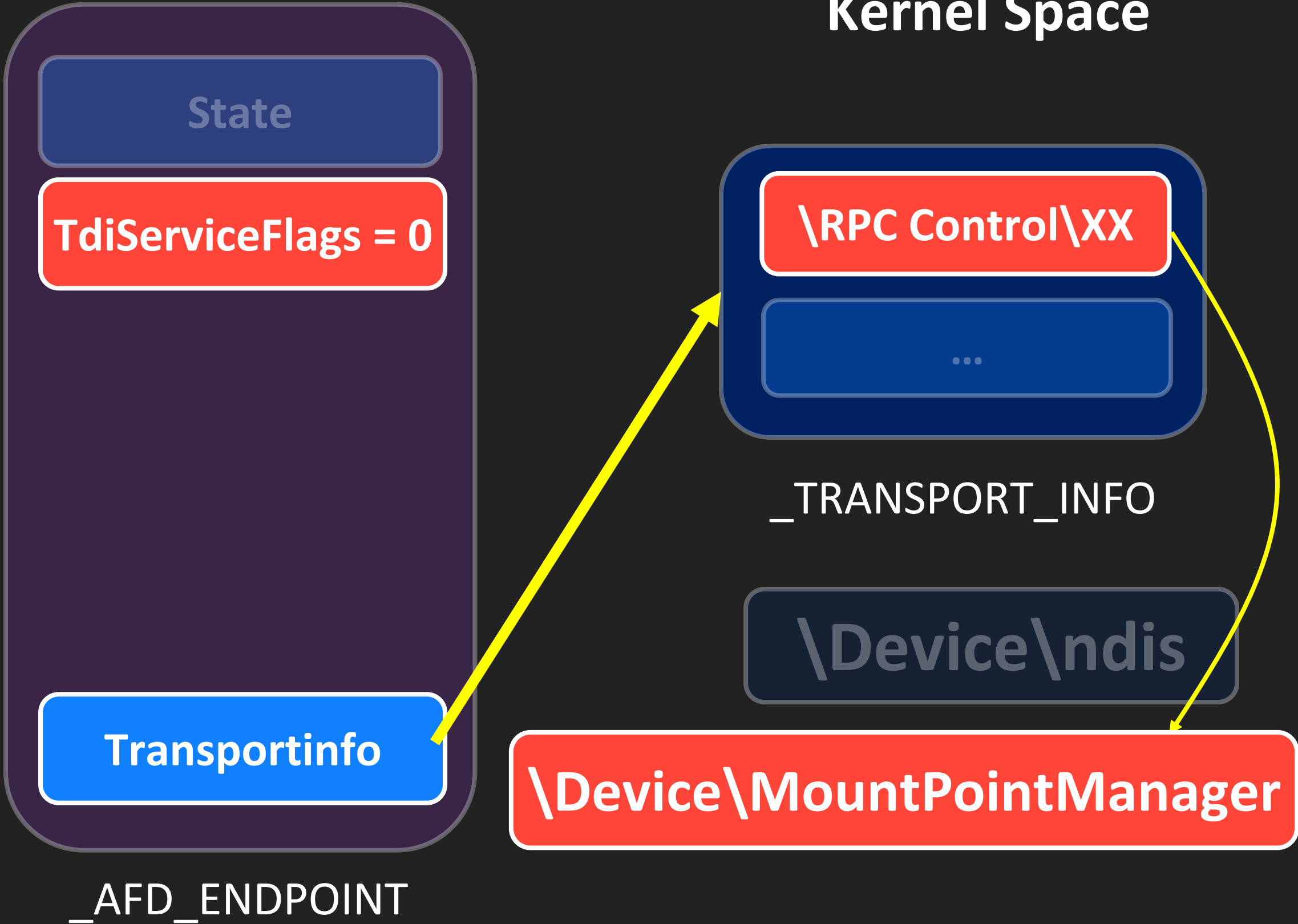


Repoint to another device

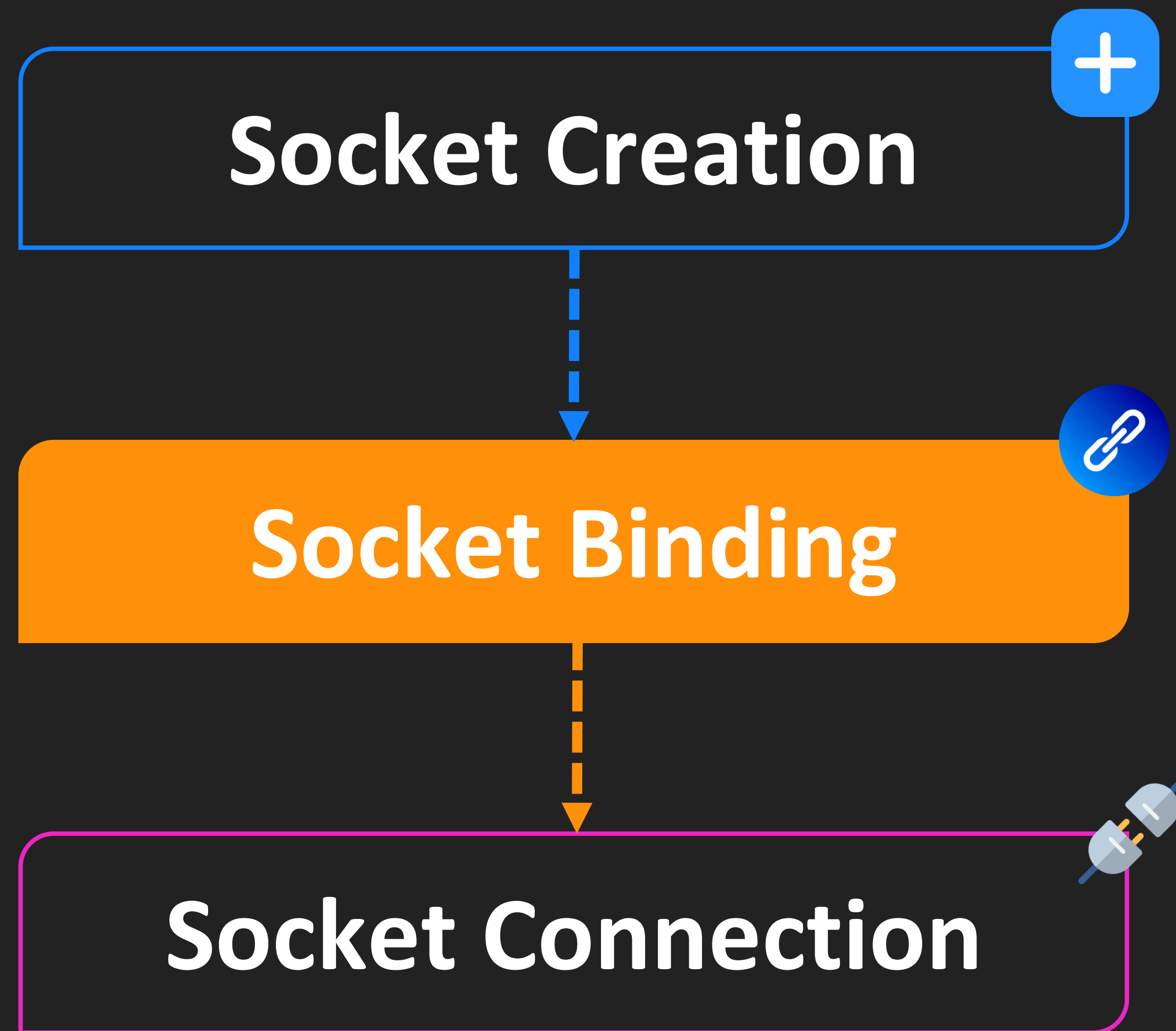
Application

User Space

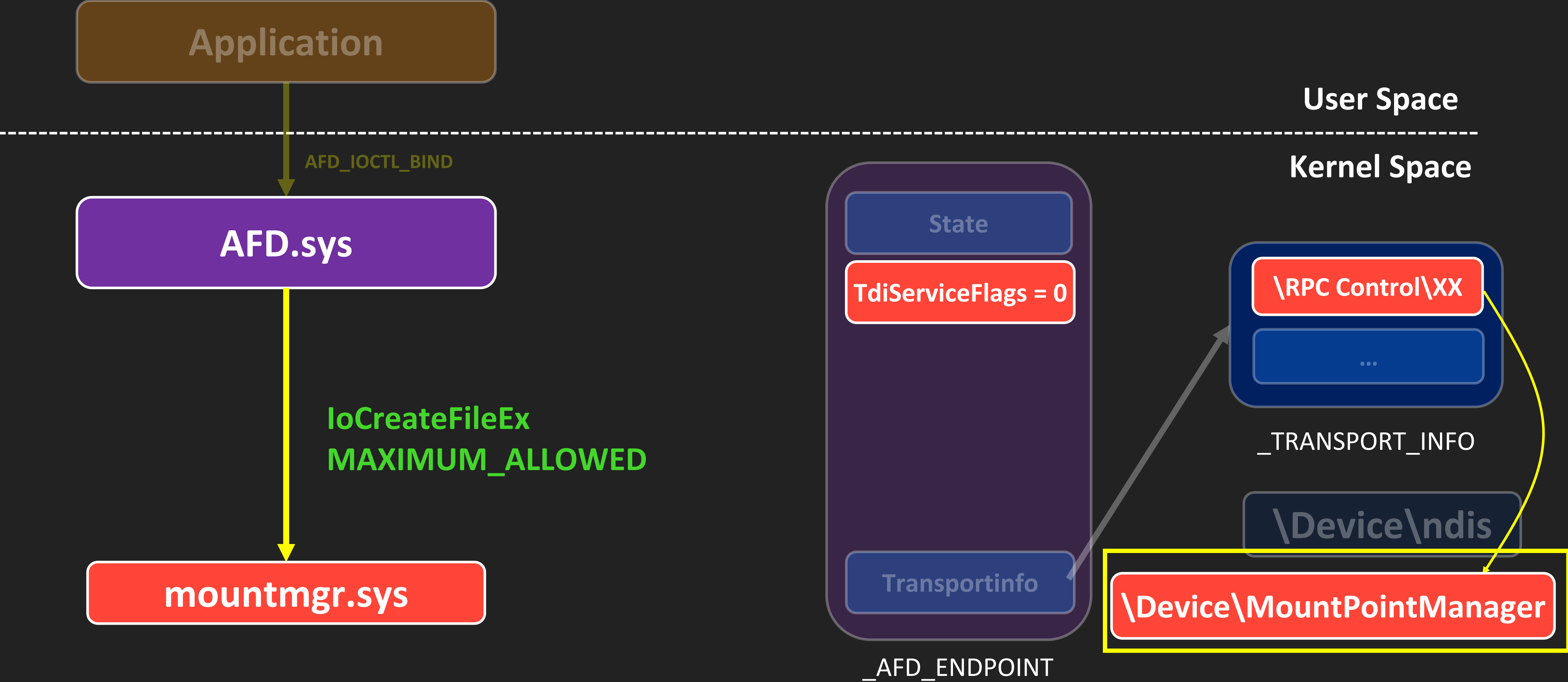
Kernel Space



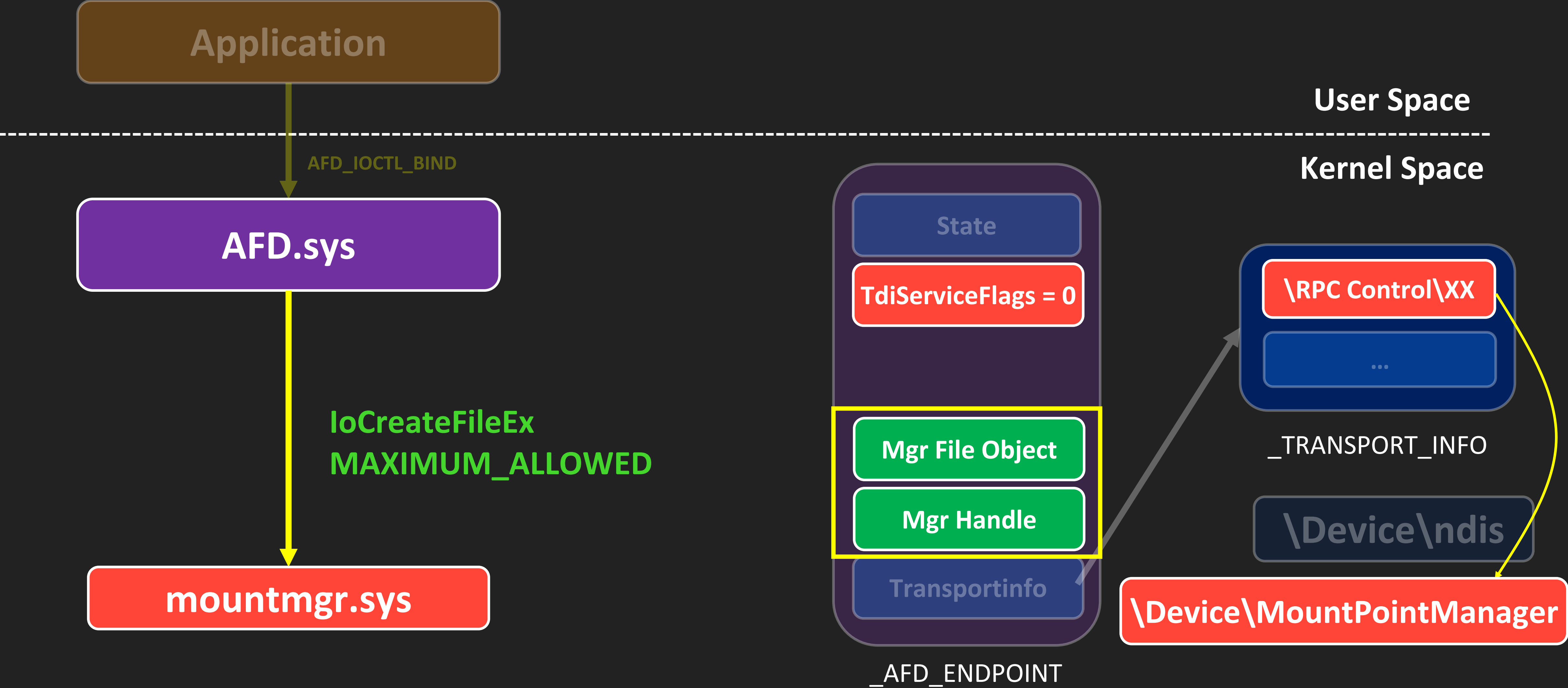
Socket Workflow



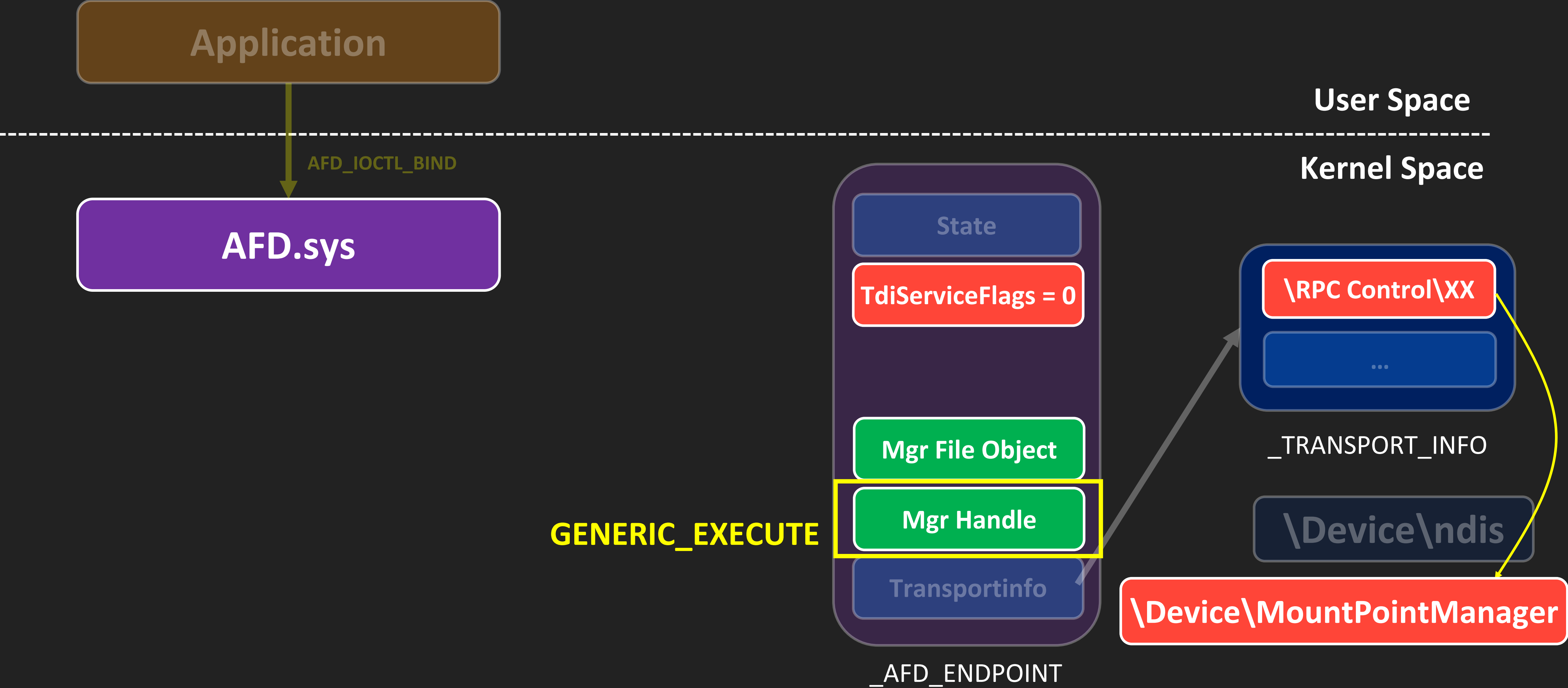
Socket Binding



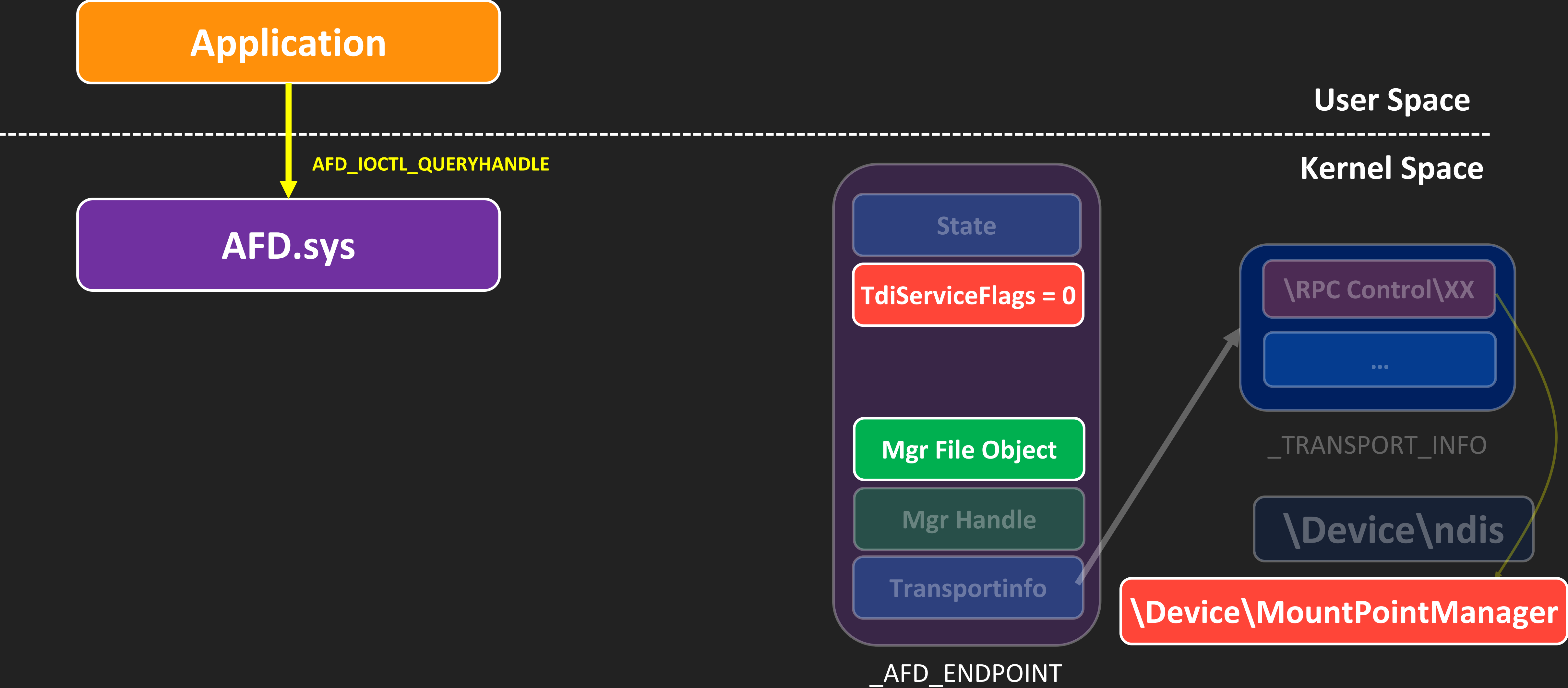
Socket Binding



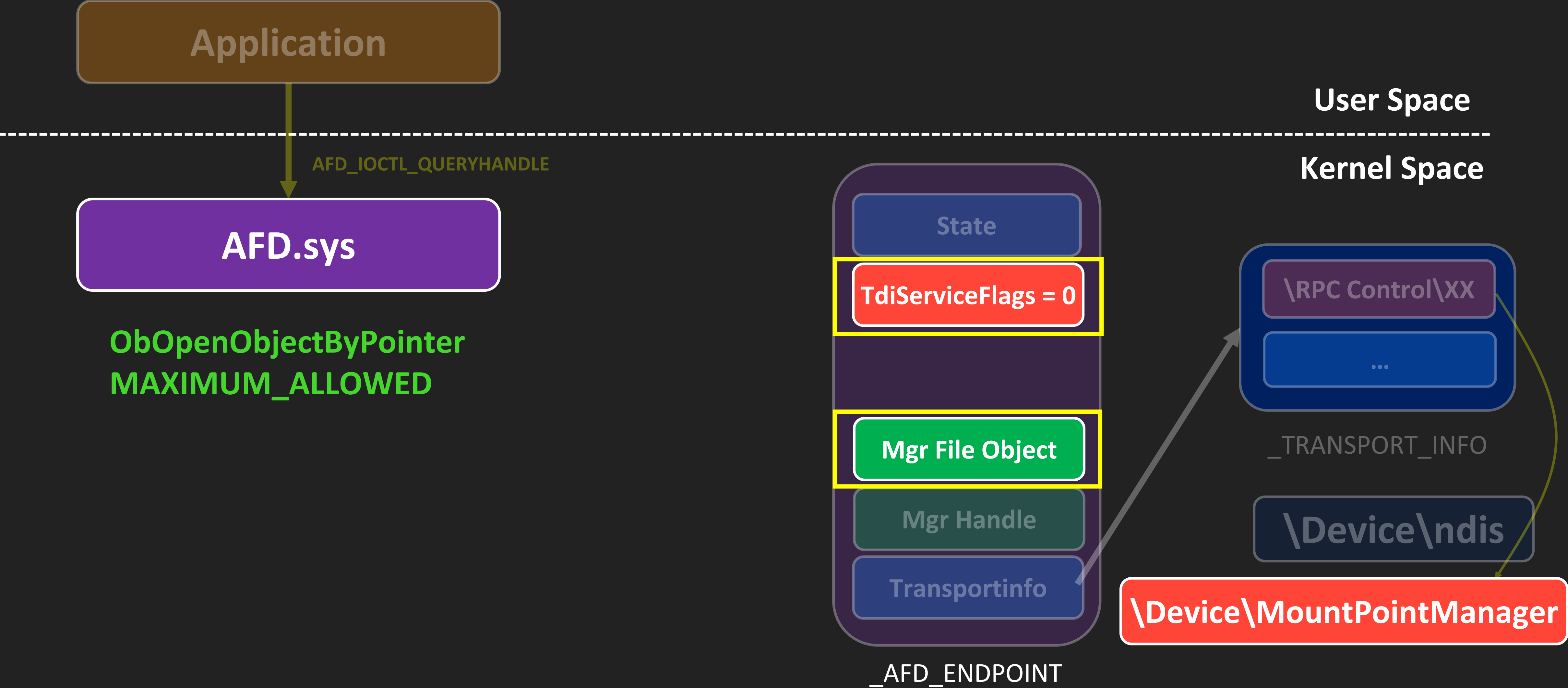
Socket Binding



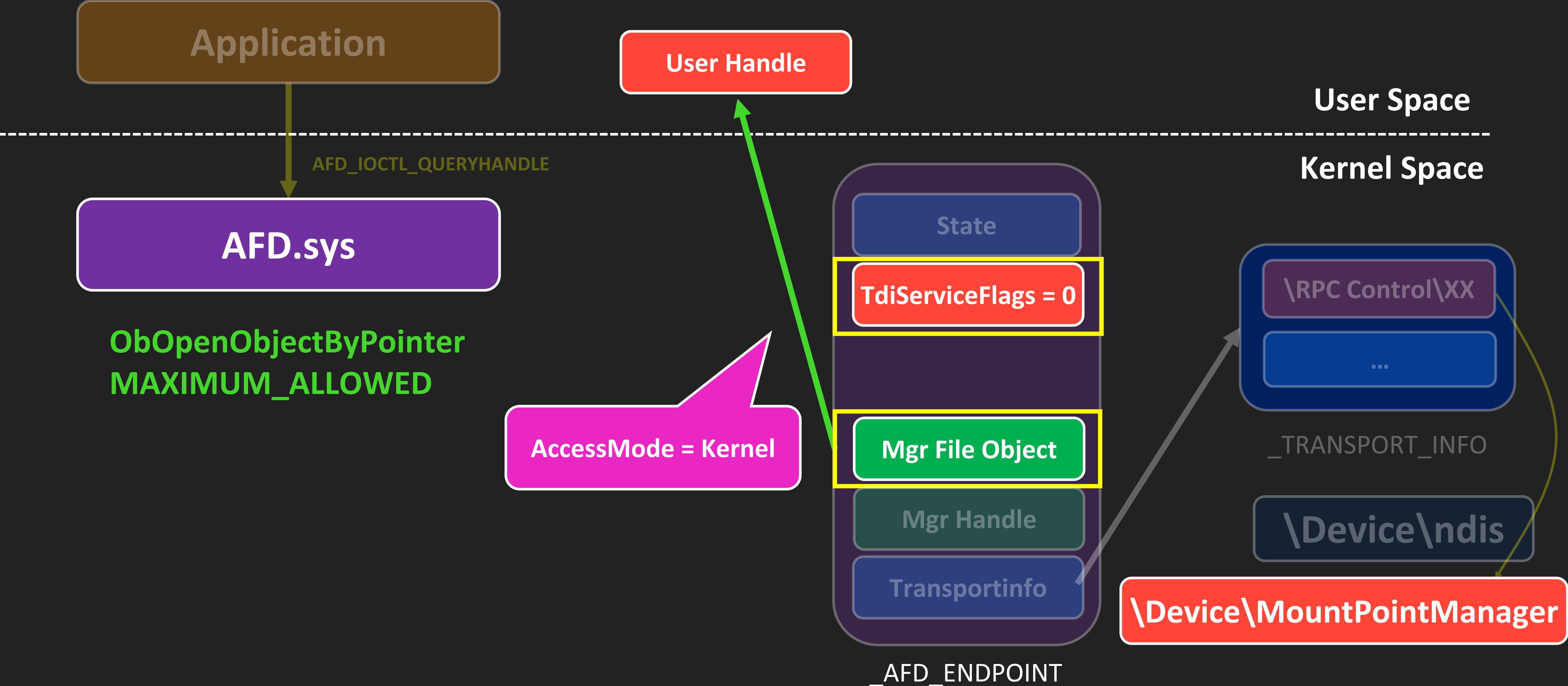
AfdQueryHandles



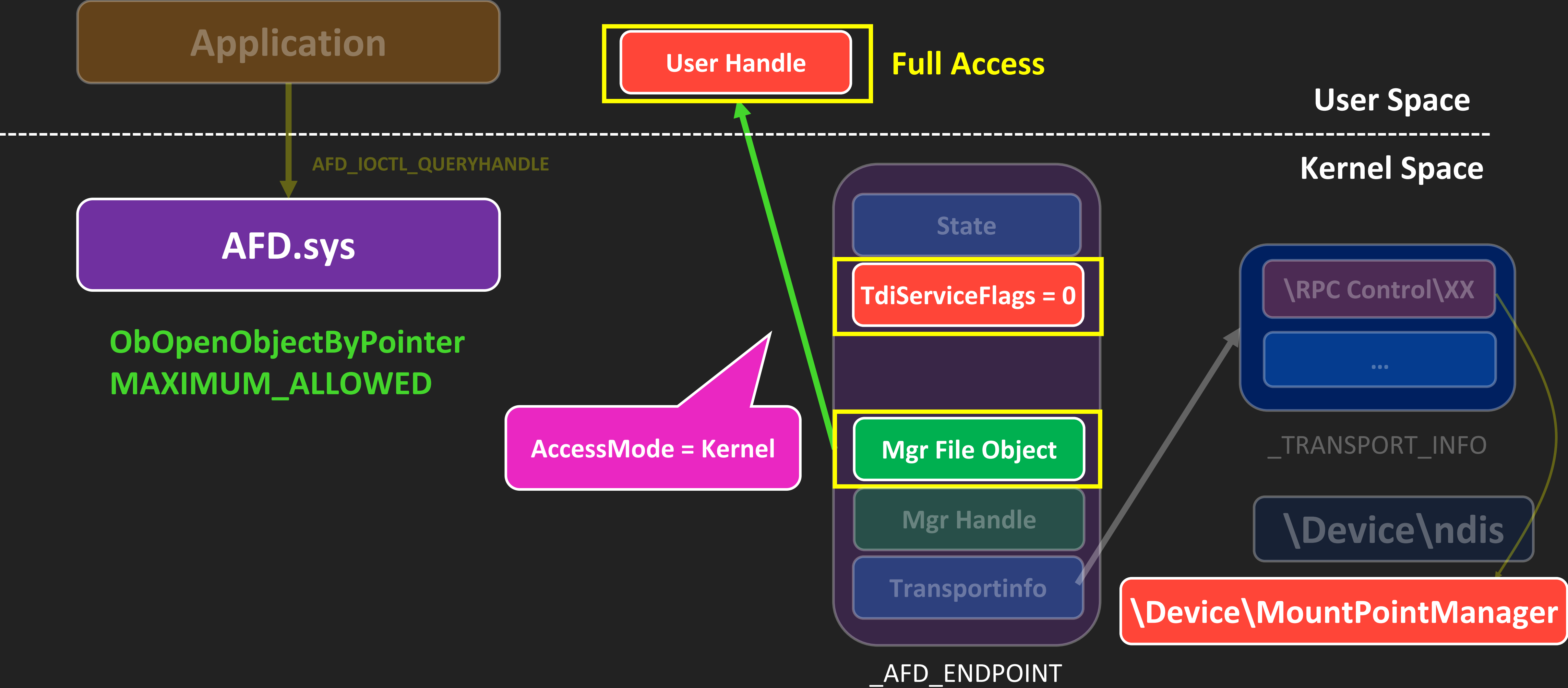
AfdQueryHandles



AfdQueryHandles



AfdQueryHandles



We have a **full-access** handle to
Mount Manager

Mount Manager

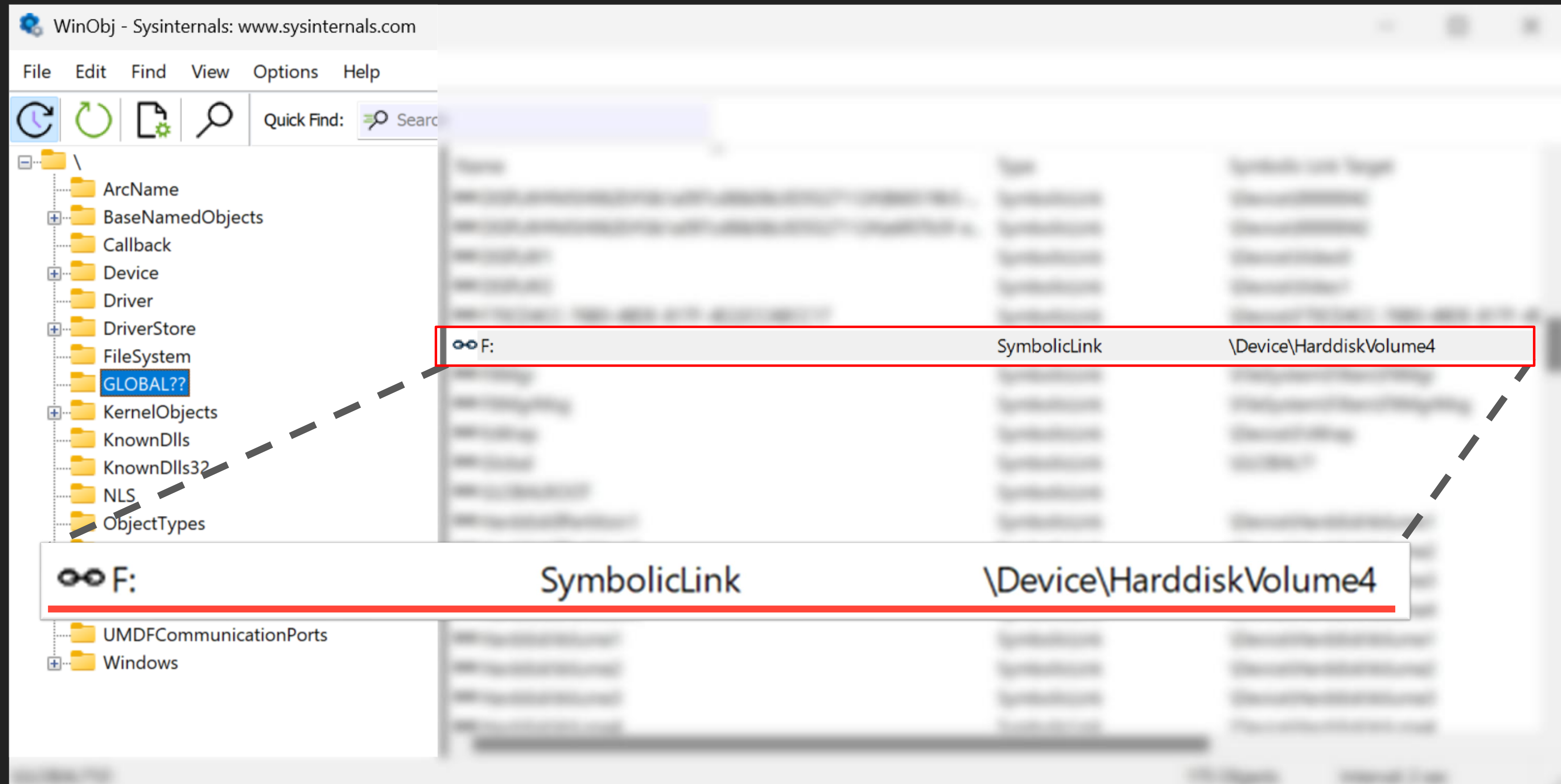
- IOCTL_MOUNTMGR_CREATE_POINT
- IOCTL_MOUNTMGR_DELETE_POINTS
- IOCTL_MOUNTMGR_VOLUME_MOUNT_POINT_CREATED
- IOCTL_MOUNTMGR_VOLUME_MOUNT_POINT_DELETED
- ...

Mount Manager

IOCTL_MOUNTMGR_CREATE_POINT

The mount manager clients can use this IOCTL to request that the mount manager create a persistent symbolic link name for the indicated volume.

Mount Manager



Mount Manager

Network Service

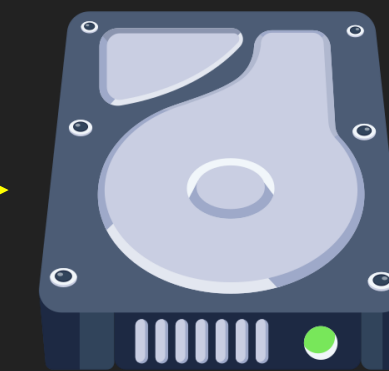
C:



\\??\C:

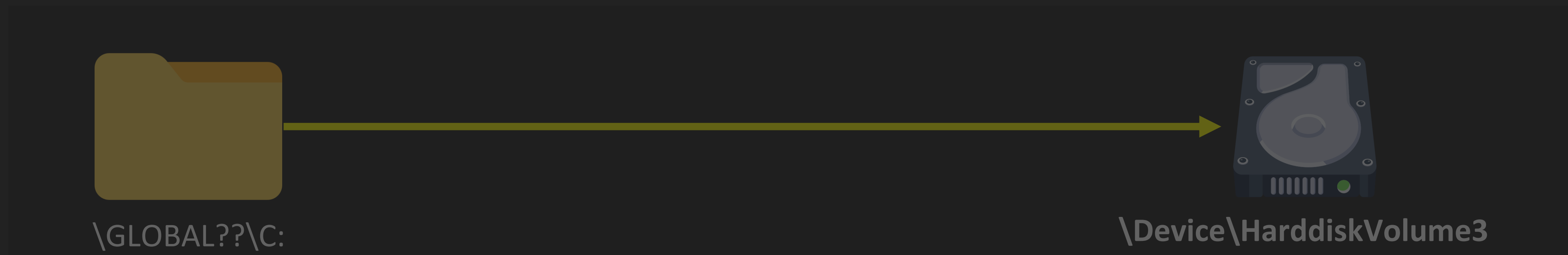


\\GLOBAL??\C:



\\Device\\HarddiskVolume3

Mount Manager



Privilege Escape to Network Service

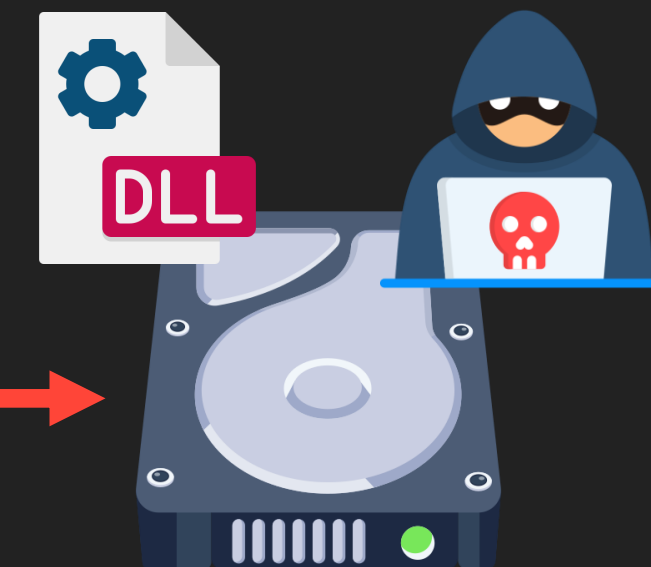
- Windows Media Sharing service



C:\...\netutils.dll



`\Sessions\0\DosDevices\00000000-000003e4\C:\...\netutils.dll`



`\Device\HarddiskVolume4\...\netutils.dll`

Mount Manager

Disk Management

File Action View Help

Volume	Layout	Type	File System	Status	Capacity	Free Sp...	% Free
(Disk 0 partition 1)	Simple	Basic		Healthy (E...	260 MB	260 MB	100 %
(Disk 0 partition 4)	Simple	Basic		Healthy (R...	2.00 GB	2.00 GB	100 %
Local Disk (C:)	Simple	Basic	NTFS (BitLo...	Healthy (B...	951.60 GB	33.25 GB	3 %

Disk 0

Basic

953.85 GB

Online

260 MB	Local Disk (C:)	2.00 GB
Healthy (EFI System P	951.60 GB NTFS (BitLocker Encrypted)	Healthy (Recovery Partition)
	Healthy (Boot, Page File, Crash Dump, Basic Data Partition)	

■ Unallocated

■ Primary partition

From Network Service to SYSTEM

- **SeImpersonatePrivilege**
 - Potatoes
 - ...
- **SMB loopback named pipe impersonation**





Recycle Bin



Microsoft
Edge



poc



Learn about
this picture

Command Prompt

```
Microsoft Windows [Version 10.0.26200.6584]  
(c) Microsoft Corporation. All rights reserved.
```

```
C:\Users\lowpriv>cd Desktop
```

```
C:\Users\lowpriv\Desktop>cd poc
```

```
C:\Users\lowpriv\Desktop\poc>
```



Search



3:02 AM
7/9/2026



Status: Running

Exploit

- **No Memory Corruption**
- **No Race Condition**
- **Logic-Only Exploit**
- **100 % Success Rate**



Exploitability

The following table provides an [exploitability assessment](#) for this vulnerability at the time of original publication.

Publicly disclosed

No

Exploited

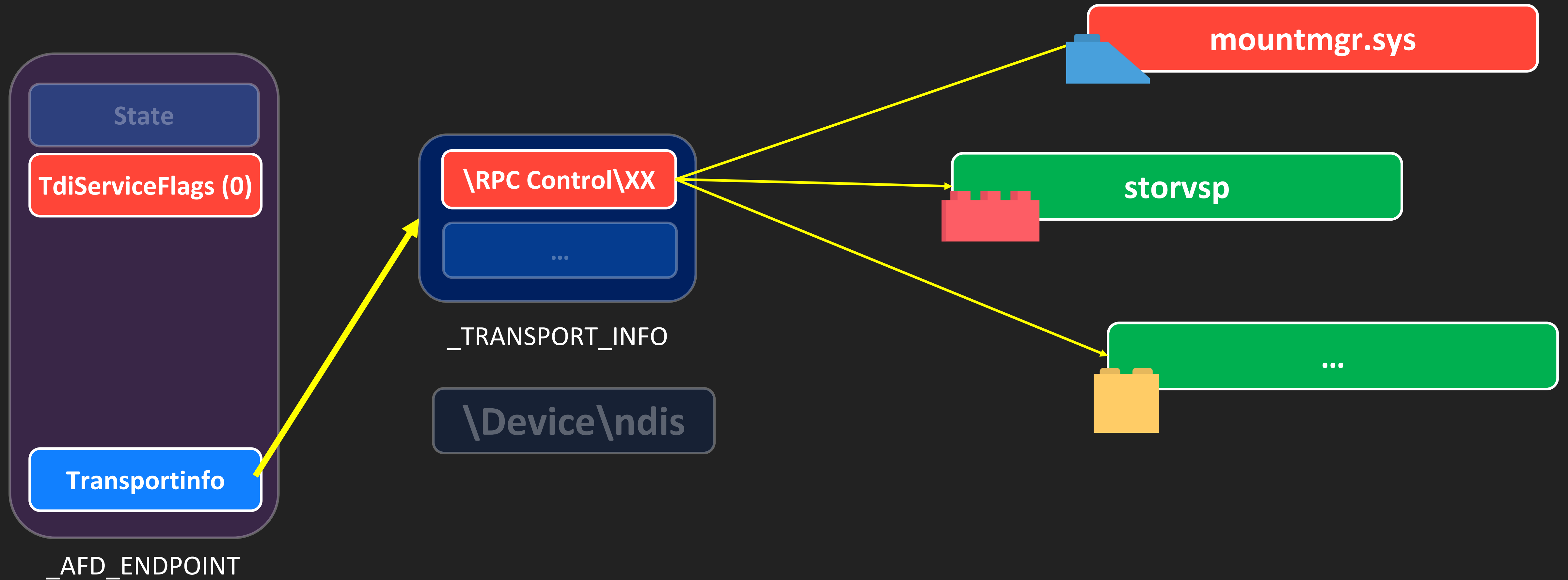
No

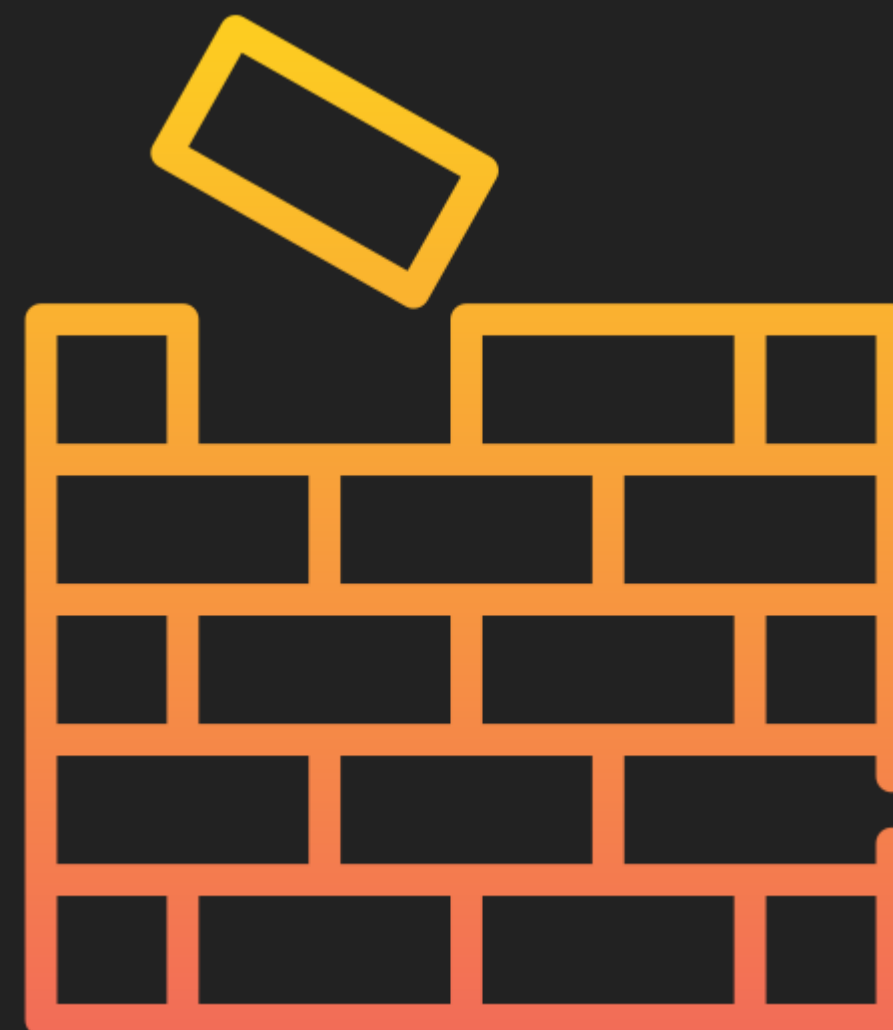
Exploitability assessment

Exploitation Unlikely



More Gadgets





Patch

AfdQueryHandles

```
ObOpenObjectByPointer(  
    Object: Endpoint->AddressFileObject,  
    HandleAttributes: 0x40u,  
    PassedAccessState: 0,  
    DesiredAccess: 0x2000000u,  
    ObjectType: (POBJECT_TYPE)IoFileObjectType,  
    AccessMode: (Endpoint->TdiServiceFlags & TDI_SERVICE_FORCE_ACCESS_CHECK) != 0 ? AccessMode : 0,  
    Handle: Output);
```

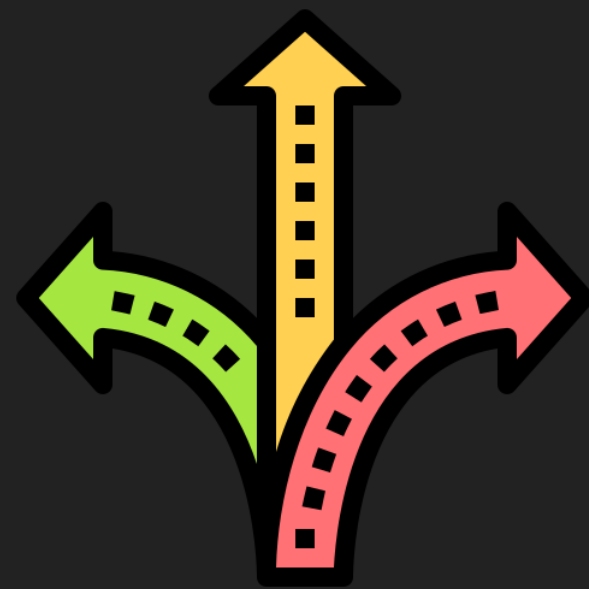


```
ObOpenObjectByPointer(  
    Object: Endpoint->AddressFileObject,  
    HandleAttributes: 0x40u,  
    PassedAccessState: 0,  
    DesiredAccess: 0x2000000u,  
    ObjectType: (POBJECT_TYPE)IoFileObjectType,  
    AccessMode,  
    Handle: Output)
```

Is that the end of it ?



An Alternative Composition Path (CVE-2026-25176)



AfdCreateConnection

```
__int64 __fastcall AfdCreateConnection(...){
    ...
    ObjectAttributes.ObjectName = &Object->TransportDeviceName;
    ObjectAttributes.Attributes = OBJ_CASE_INSENSITIVE | OBJ_KERNEL_HANDLE ;
    ObjectAttributes.SecurityDescriptor = 0;
    strcpy(v30, "ConnectionContext");
    EaBuffer[1] = 0x81100;
    Status = IoCreateFile(
        ...
        &ObjectAttributes,
        &IoStatusBlock,
        ...
        Disposition: FILE_CREATE,
        EaBuffer,
        EaLength: 0x22u,
        ...
        Options: 0x100);
}
```

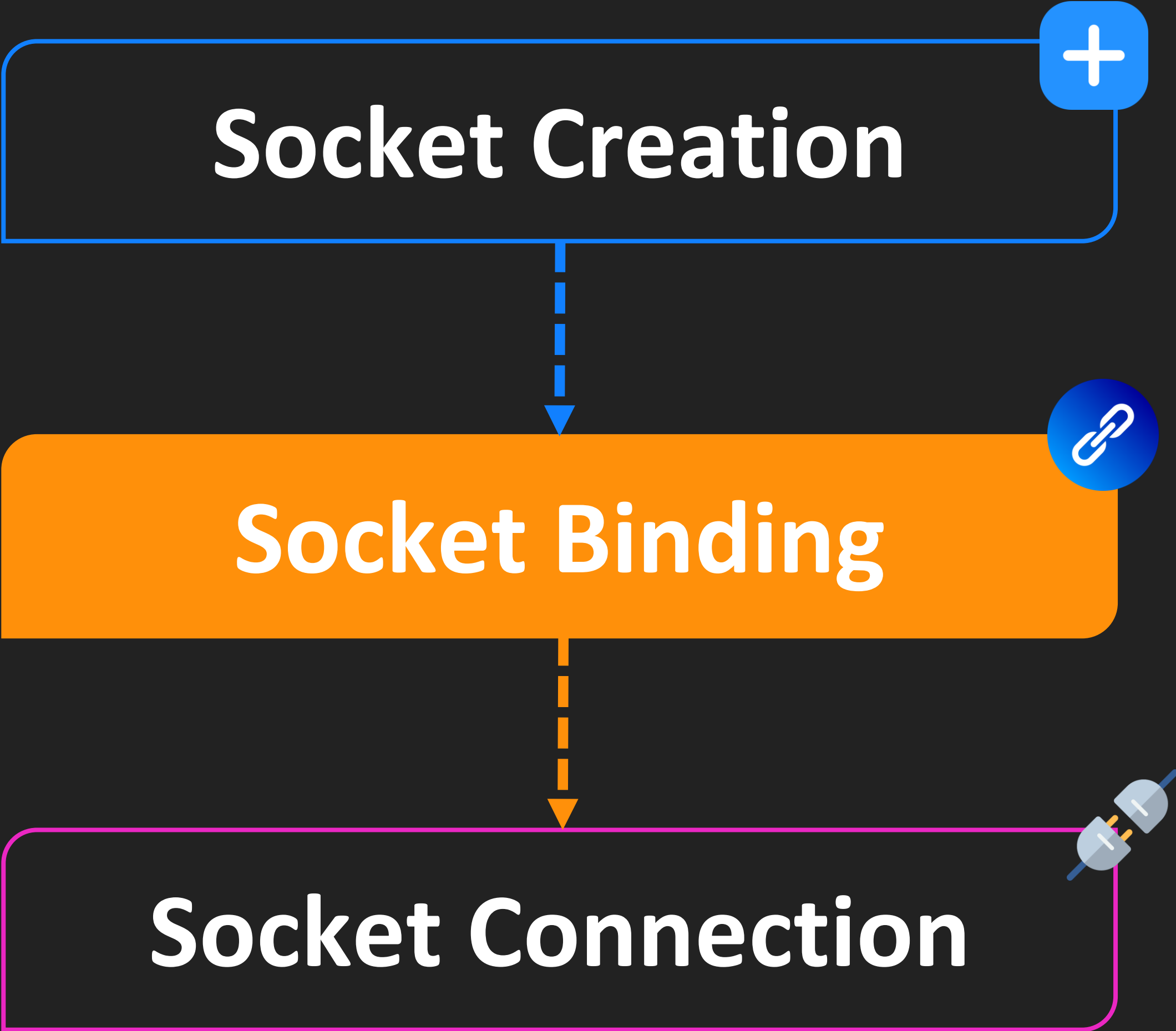
No IO_FORCE_ACCESS_CHECK



Compose with **Files**

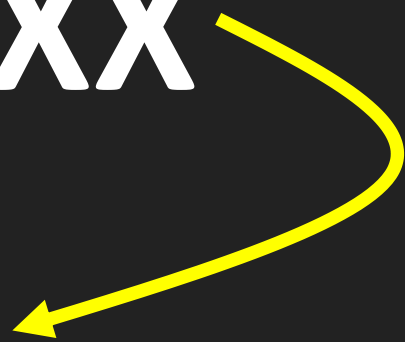


Socket Workflow



`\RPC Control\XX`

`\Device\ndis`

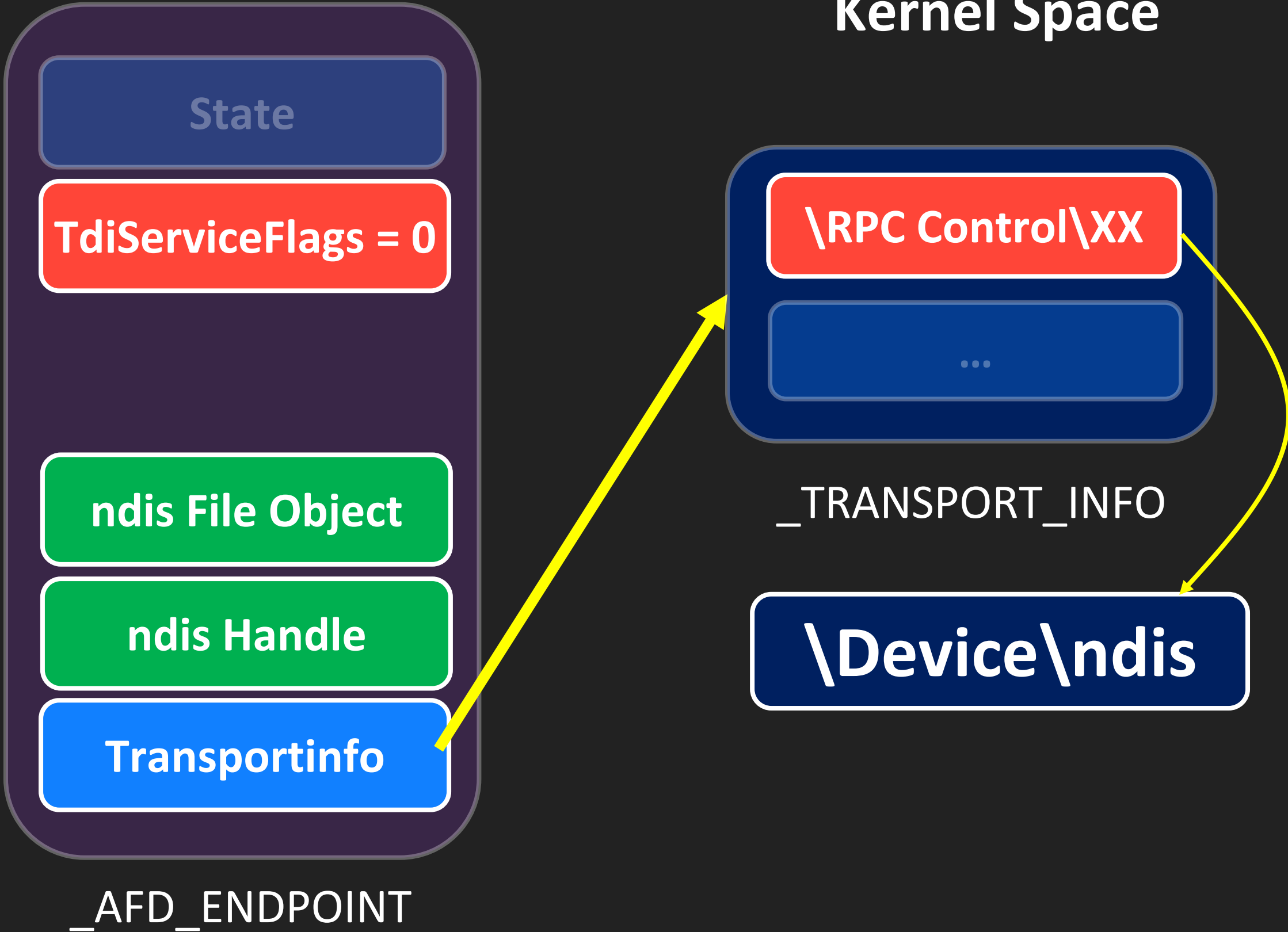


Socket Binding

Application

User Space

Kernel Space

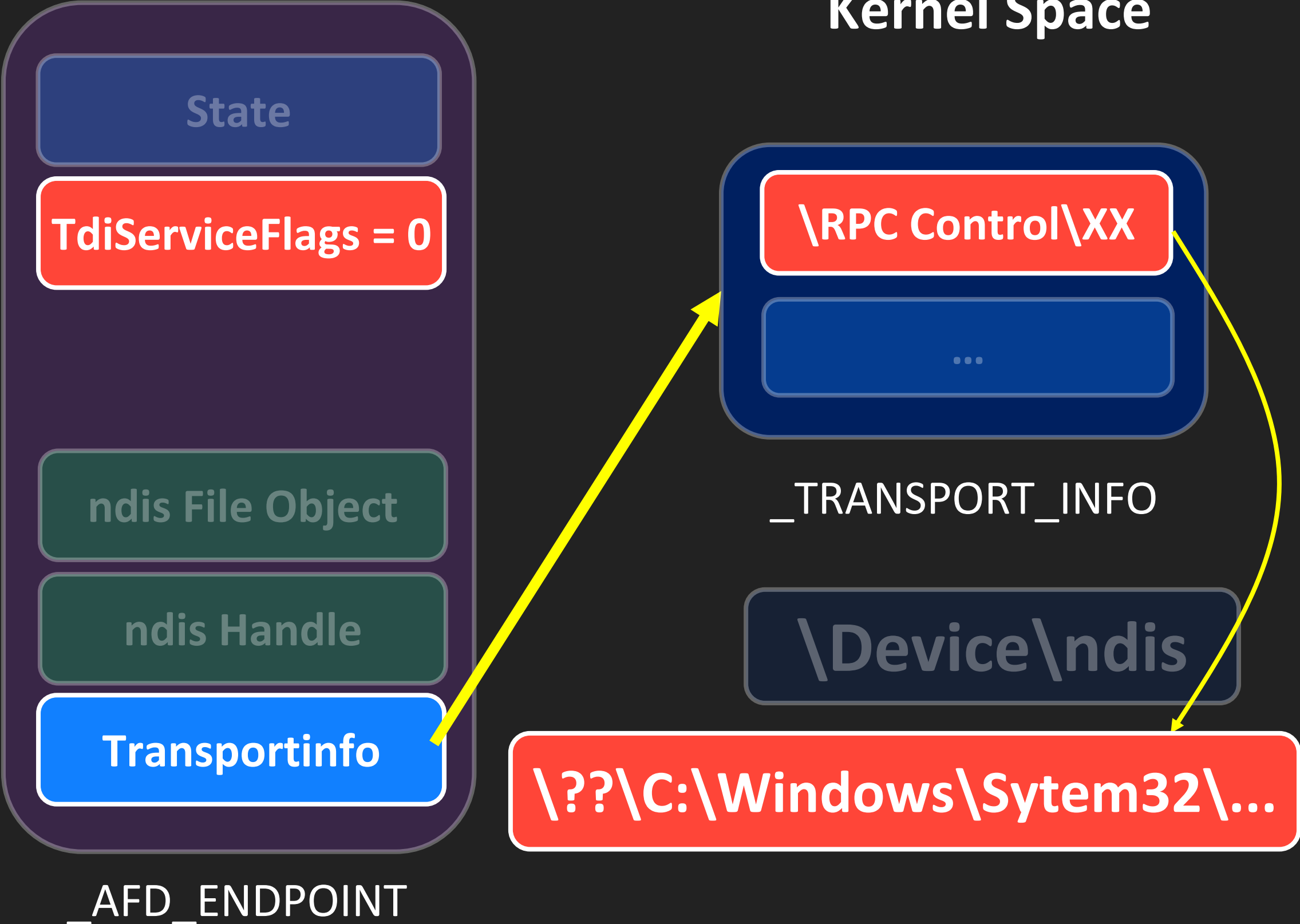


Repoint to files

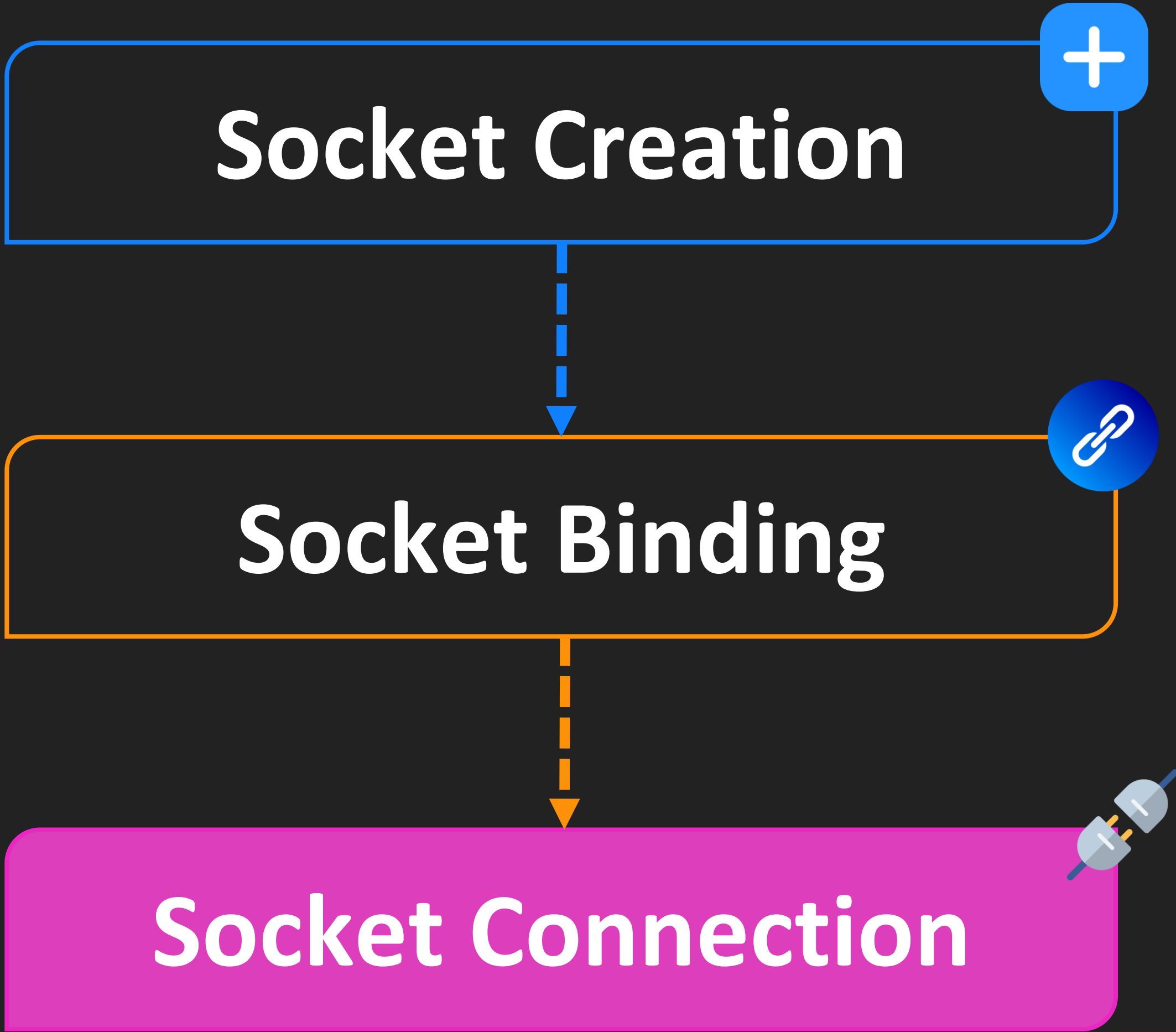
Application

User Space

Kernel Space



Socket Workflow

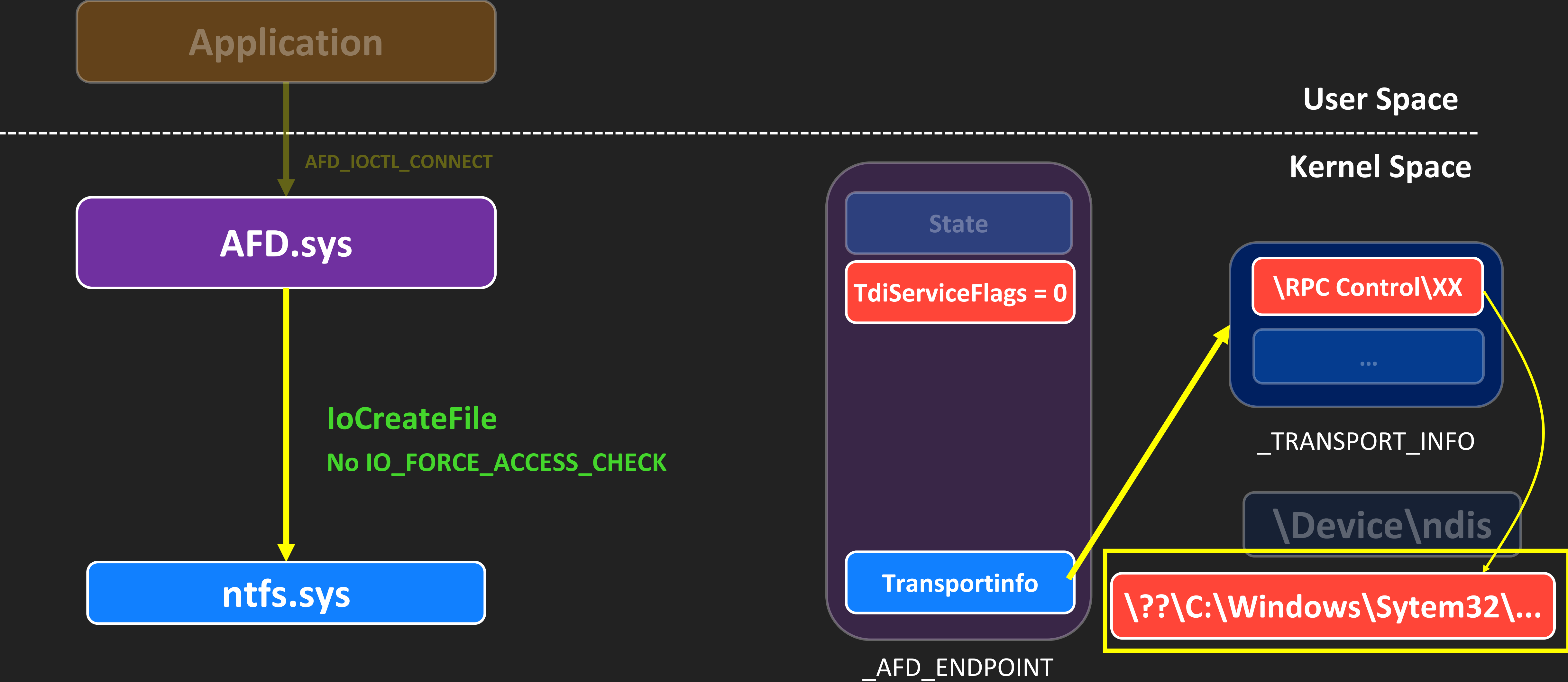


\RPC Control\XX

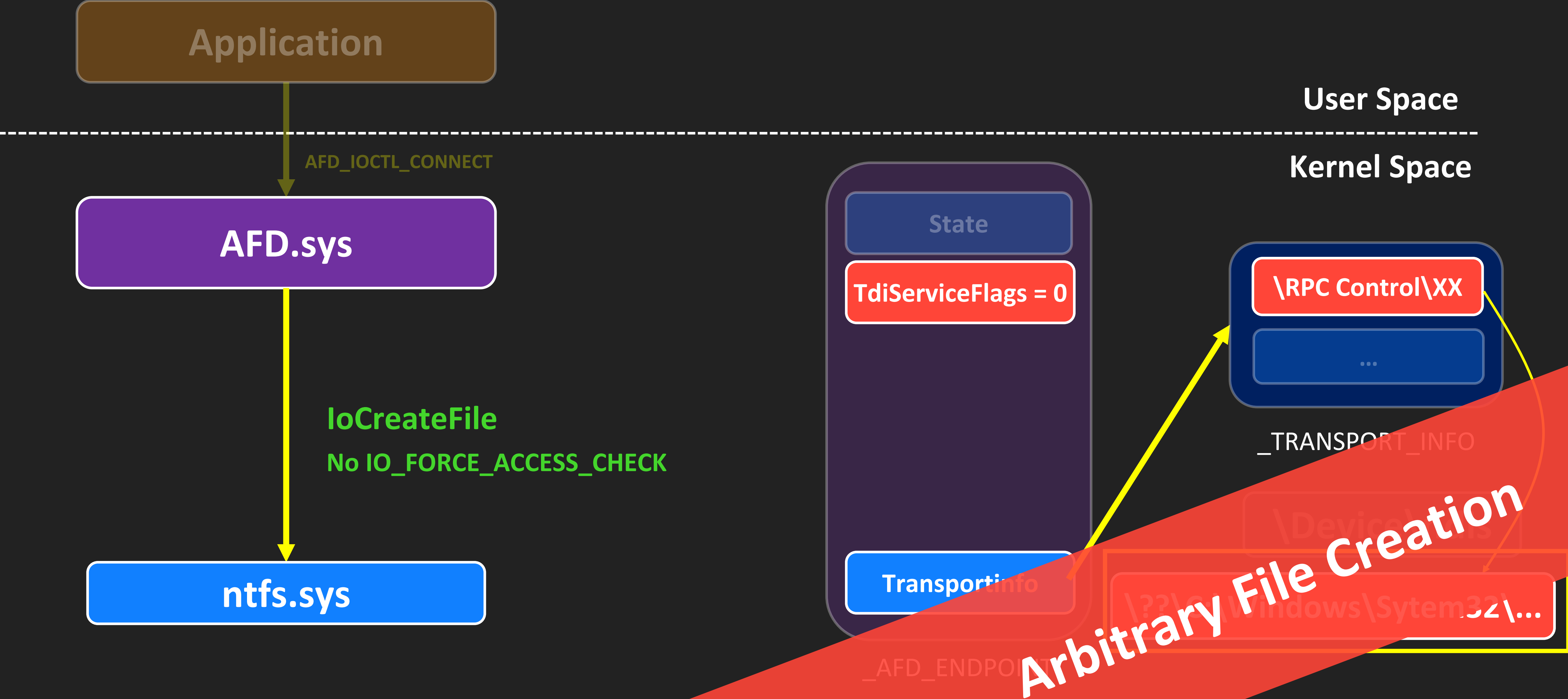
\Device\ndis

\\??\C:\Windows\System32\...

Socket Connection



CVE-2026-25176



From Arbitrary File Creation to SYSTEM

- MicrosoftEdgeElevationService
 - CLSID: {1FCBE96C-1697-43AF-9140-2897C7C69767}
 - Runs **elevation_service.exe** as **LocalSystem** from the Edge version directory
 - Hijack **ntasn1.dll**



File Action Media View Help



```
Command Prompt
Microsoft Windows [Version 10.0.26200.7623]
(c) Microsoft Corporation. All rights reserved.

C:\Users\lowpriv>cd Desktop

C:\Users\lowpriv\Desktop>cd poc

C:\Users\lowpriv\Desktop\poc>
```



Search

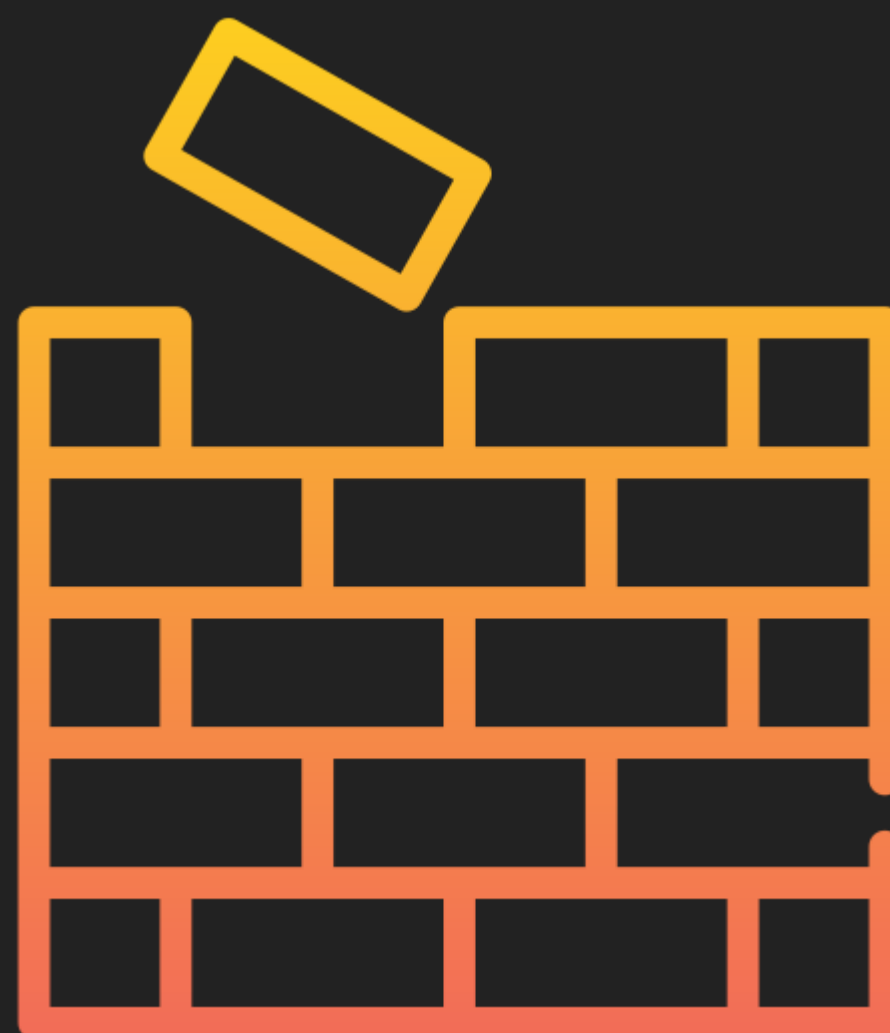


1:07 AM
7/24/2026



Status: Running





Patch again

AfdCreateConnection

```
__int64 __fastcall AfdCreateConnection(...){  
    ...  
    Options = IO_NO_PARAMETER_CHECKING | IO_FORCE_ACCESS_CHECK;  
    ObjectAttributes.ObjectName = &Object->TransportDeviceName;  
    ObjectAttributes.Attributes = 0x240;  
    strcpy(v30, "ConnectionContext");  
    EaBuffer[1] = 0x81100;  
    Status = IoCreateFile(  
        ...  
        &ObjectAttributes,  
        &IoStatusBlock,  
        ...  
        Disposition: FILE_CREATE,  
        EaBuffer,  
        EaLength: 0x22u,  
        ...  
        Options: Options);  
    }  
}
```

IO_FORCE_ACCESS_CHECK

The **vulnerable logic** had been present for
nearly **20 years**

Sandbox Escape ?

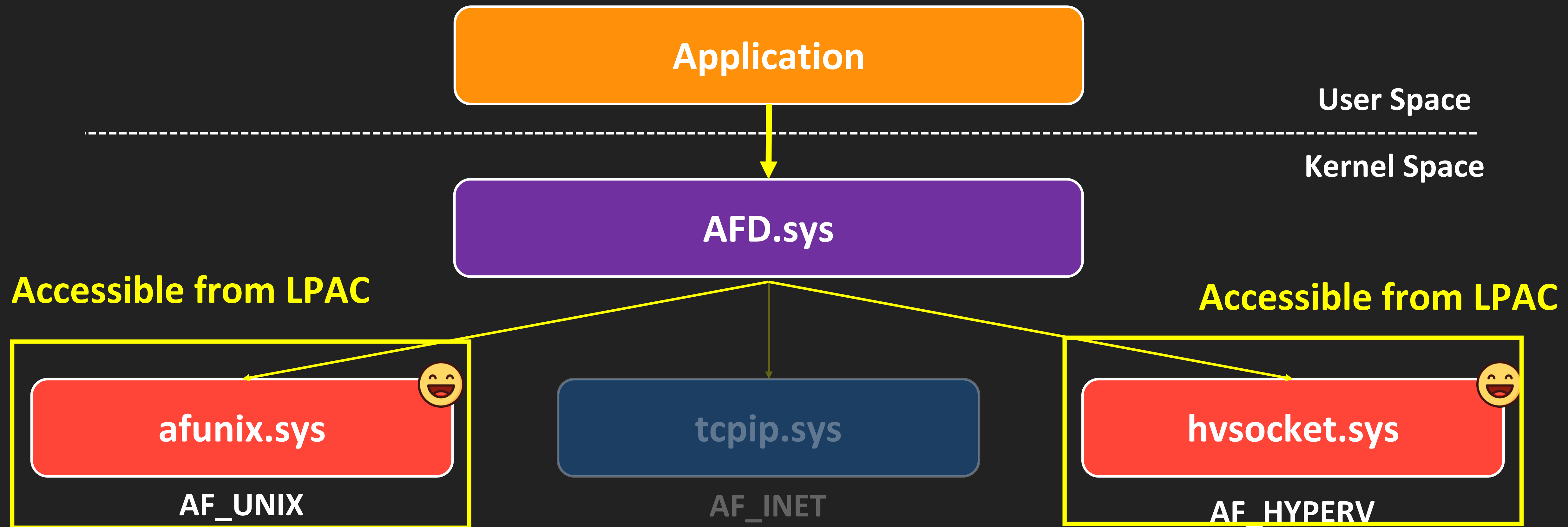
Less Privileged AppContainer (LPAC)

LPAC

- **TCP** and **UDP** connections are **restricted**
- Object Manager **symbolic links** are **restricted**
- Most devices are also inaccessible
 - Not possible in **TDI** mode ?

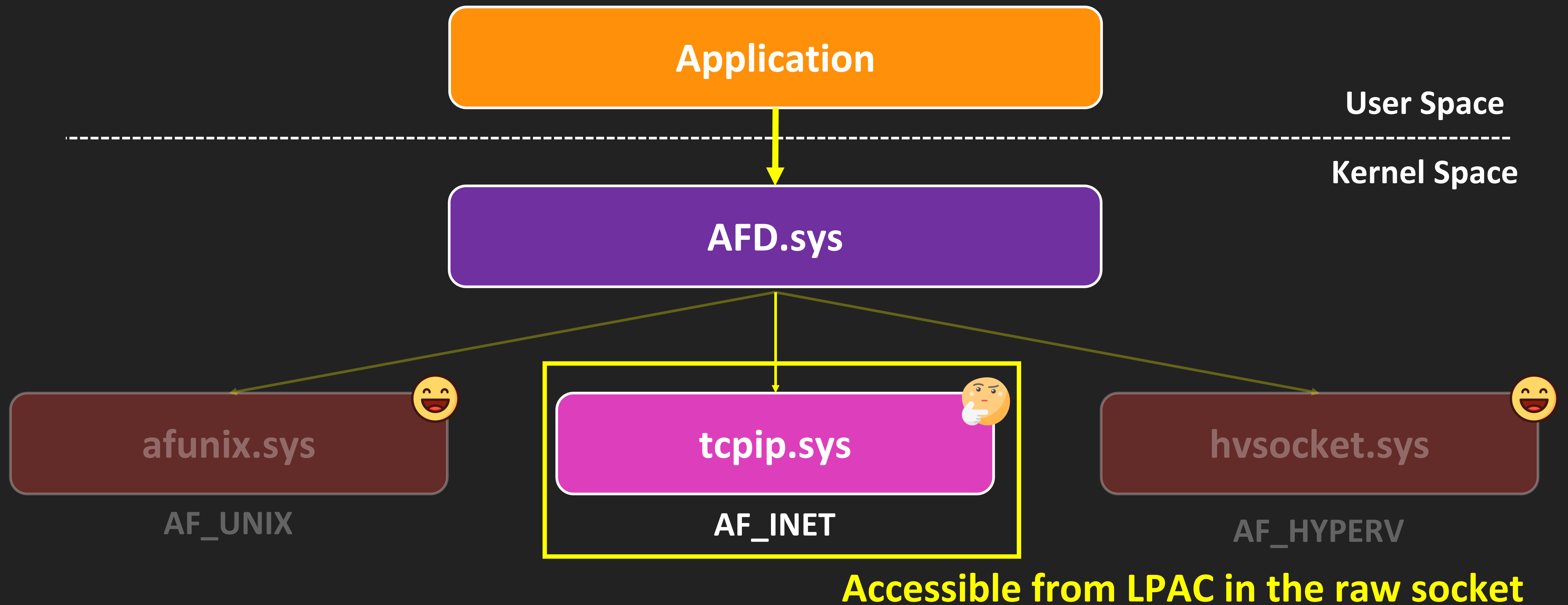
LPAC

- TLI



LPAC

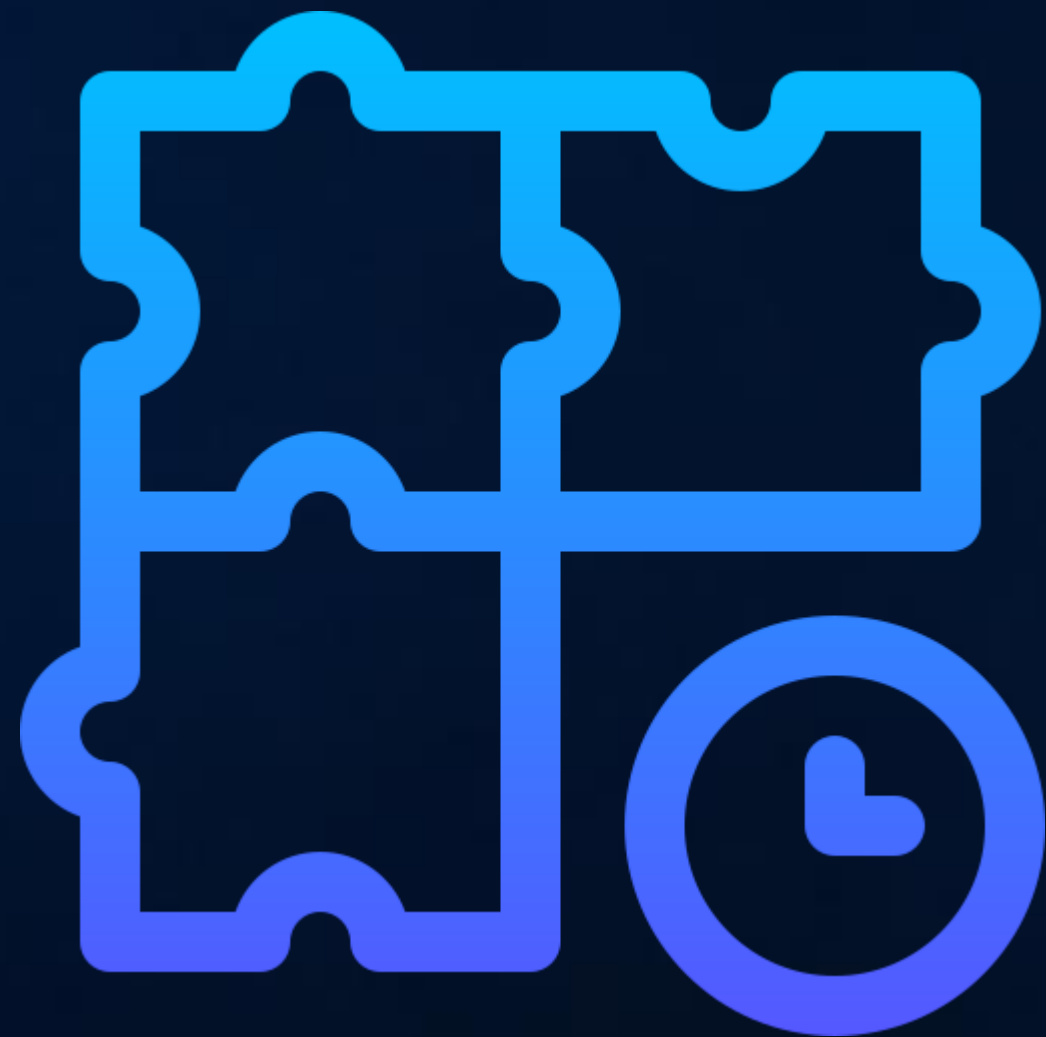
- TLI



Vulnerabilities

- **afd.sys**
 - **CVE-2026-26168**
 - **CVE-2026-26177**
 - **CVE-2026-45601**
 - **CVE-2026-34335**
 - **CVE-2026-35416**
 - **CVE-2026-45603**





What's Next

What's Next

- Assembling Vulnerabilities
 - May also apply to **other drivers**

What's Next

- Assembling Vulnerabilities
 - May also apply to **other drivers**
- Assembling Attack Surfaces
 - **IOCTL Relay**

Takeaways

- **Cross-layer composition** reveals a larger attack surface
- **Over-trusting** upstream inputs creates fragile assumptions
- More transport and device compositions **remain unexplored**

Heavily audited components
can still hide bugs

New **ideas**, new **perspectives**
can still uncover new **vulnerabilities**

Special Thanks

- Orange Tsai
- Henry Huang
- Microsoft Security Response Center (MSRC)
- DEVCORE Research Team
- Anthony & Shanna from BlackHat USA Speaker Coaching Program

Reference

- [Blackswan Technical Writeup](#) - Erik Egsgard
- [Improving AFD Socket Visibility for Windows Forensics & Troubleshooting](#) - Denis Nagayuk & Francisco Dominguez
- [Windows Kernel Logic Bug Class: Access Mode Mismatch in IO Manager](#) - James Forshaw
- [Windows Drivers are True'ly Tricky](#) - James Forshaw
- [Sharing a Logon Session a Little Too Much](#) - James Forshaw

Is that the end of it ?



CVE-2026-34335

CVE-2026-45601

CVE-2025-53137

CVE-2026-25176

CVE-2026-34345

CVE-2025-53134

CVE-2025-54093

CVE-2026-20860

CVE-2026-34344

CVE-2025-55339

CVE-2025-49762

CVE-2026-26168

CVE-2026-42911

CVE-2026-24293

CVE-2026-27921

CVE-2025-53147

CVE-2026-26173

CVE-2025-47996

CVE-2025-60719

CVE-2025-62213

CVE-2026-26182

CVE-2025-55230

CVE-2025-62217

CVE-2026-26177

CVE-2025-58714

CVE-2026-27922

CVE-2026-27908

CVE-2026-41088

CVE-2026-45596

CVE-2026-45603

CVE-2026-45598

CVE-2025-55679

CVE-2025-59242

CVE-2026-35416

CVE-2025-54099

CVE-2026-20831

CVE-2026-21238

DEV✓CORE

Thanks!

 scwuaptx

 angelboy@devco.re